Economic Incentives to Enhance Supply Chain Security

The rising frequency of supply-chain disruptions–driven by physical shocks and cyber intrusions–underscores the need for coordinated action between governments and the private sector. Firms, however, often underinvest in security: benefits are diffuse, spillovers go unpriced, and returns are slow to materialize. We develop a game-theoretic framework in which a government seeks to raise security investment by firms that hold private information about their inherent network security and effort, under noisy and costly verification. We study two instruments that mirror practice: a subsidy (mitigation, tied to pre-incident audits) and insurance (contingency, tied to post-incident inspections). Each has distinct strengths. Insurance performs best when network security is low and incidents remain likely under shirking, making denied coverage a credible threat. Subsidies perform best when baseline security is moderate to high and pre-incident verification is credible, allowing the government to internalize spillovers before attacks occur. These patterns create regional complementarity: where one instrument is weak, the other is typically strong. Using an efficiency index—prevention per unit of agency cost—we show how to choose between them in overlap regions. We then examine hybrid mechanisms that splice mitigation and contingency. Both the delayed-inspection variant (subsidy up front; coverage conditioned ex post) and the early-audit variant (verify first; activate subsidy and coverage) can outperform pure instruments: they are more resilient to rising verification costs, dominate subsidies in low-type pooling windows, and can beat insurance when firms face a large investment-benefit gap. Our results inform practice. First, invest in the accuracy of audits and inspections; precision can matter more than the size of transfers. Second, segment instruments by network security: use insurance in low-security segments and subsidies in moderate-to-high-security segments. Third, deploy hybrids when monitoring is expensive or when investment gaps are large; hybrids preserve incentives while economizing on checks.

Key words: Supply chain security; economic incentives; business insurance; subsidy; effort verification.

1. Introduction

Protecting supply chains is essential to economic stability, industrial productivity, consumer satisfaction, and public safety. Goods and information must move intact through dense, multi-tier networks to preserve value and functional utility. Disruptions–whether from physical threats such as theft, counterfeiting, smuggling, and terrorism, or from cyber threats including data breaches, ransomware, and system failures–translate into financial losses, manufacturing delays, diminished product quality, and potential harm to consumers. Because physical logistics and digital platforms are tightly intertwined, weaknesses in one domain propagate to the other. Ensuring robust supply-chain security is therefore a shared priority for industry and government, yet designing effective programs is challenging: global networks are complex, investment is costly, verification is imperfect, and meaningful progress requires coordinated incentives and governance.

Private supply chains face adversary risk in both the physical and digital layers. On the physical side, enforcement actions routinely uncover counterfeit goods flowing into legitimate channels–for example, U.S. Customs and Border Protection's 2019 seizure of counterfeit Apple AirPods and Lightning cables valued at over $400,000–defrauding consumers and creating safety hazards when products fail to meet standards (City-News-Service 2023). On the digital side, rapid digitization–accelerated by smart-city infrastructure and e-commerce–has produced multi-tier, platform-integrated e-commerce supply chains (ESCs). These systems lower operating costs, broaden market access, and improve service, but increased connectivity also heightens exposure to ransomware, data exfiltration, phishing, and denial-of-service attacks. Prominent incidents such as the 2013 Target breach (Jones 2021, Ramakrishnan and Bose 2019), initiated via a *third-party* vendor, show how a single weak link can trigger cascading losses across tiers. A recent Forbes analysis further notes that vulnerabilities in supplier systems top retailers' cyberthreat lists (Panel 2023).

Physical and digital risks are increasingly inseparable. Even highly digital ESCs depend on physical logistics; conversely, cyberattacks on digital platforms can halt physical flows. The COVID-19 pandemic exposed these interdependencies: post-pandemic surveys report that roughly 60% of businesses do not thoroughly understand the risk of third-party data breaches (PWC 2022), creating conditions for cascading failures in ESCs where firms actively interlink systems with global suppliers. Traditional physical-risk tactics (e.g., multi-sourcing) can inadvertently widen the cyber attack surface by multiplying data exchange points. The SolarWinds campaign exemplifies the scale of the problem, infiltrating thousands of organizations–including multiple U.S. federal agencies and private networks–by exploiting vulnerabilities across supply-chain layers. The upshot is a joint physical-cyber security problem that calls for coherent incentives across both layers.

Governments have begun to respond with strategies that jointly advance national security and economic resilience. These policies emphasize targeted investments, standards, and incentive mechanisms to harden critical supply chains. President Biden's Executive Order 14017, America's Supply Chains, exemplifies this approach through initiatives such as establishing a Supply Chain Resilience Center, promoting secure smart-manufacturing standards, and mobilizing investment to strengthen critical infrastructure and diversify networks (The-White-House 2023). Implementation, however, hinges on private-sector participation, which is constrained by financing frictions and uncertainty over returns to security. Firms frequently prioritize actions with reputational payoffs over costly controls whose benefits are diffuse and slow to materialize. As a result, *privately optimal security often falls short of the socially optimal level*. Recognizing this alignment problem, U.S. Presidential Executive Order 13636 directed agencies–including the Department of Homeland Security (DHS)–to evaluate incentive mechanisms that stimulate private investment in security. DHS characterizes incentives along two dimensions: *effectiveness* (ability to induce meaningful security investment) and *equity* (how costs are shared between government and firms). Instruments range from high-effectiveness, direct mechanisms (e.g., subsidies, liability protection) to indirect approaches (e.g., tax credits and insurance).

This manuscript investigates two mechanisms at opposite ends of that spectrum–and a third that combines them. First, government subsidies–a direct, proactive *mitigation* instrument–place the verification gate *ex ante*: transfers are tied to *pre-incident audits* that verify effort and trigger (or withhold) payments before any disruption[1]. Second, business insurance–an indirect, reactive *contingency* instrument–places the gate *ex post*: payouts are tied to *post-incident inspections* that verify losses and compliance only when a claim is filed[2]. This relocation of the verification gate–from effort before the event to realized loss after the event–changes what is conditioned, when costs are incurred, and how noise affects deterrence and screening. In practice, both instruments are policy-relevant in physical and cyber settings: pre-incident grants/rebates tied to compliance attestations are common in decentralized supply networks, while claims-contingent coverage (including public backstops) is a workhorse for correlated risks. We then study *hybrid mechanisms* that splice mitigation and contingency by combining an ex-ante effort gate with an ex-post coverage gate.

These observations place our study within an active debate in the POM literature on how operations-management research should address security risks created by increasingly digital, interconnected, and data-intensive supply chains. Kumar et al. (2018) emphasize that the OM–IS interface is especially important for studying technology-enabled operations, including smart cities, IoT, Industry 4.0, blockchain, digital platforms, and other settings in which operational decisions and information systems are deeply intertwined. More recently, Kumar and Mallipeddi (2022) argue that cybersecurity has become a critical POM research domain and call for models that help organizations, supply chains, and governments develop robust strategies for reducing both the likelihood and consequences of cyberattacks. Our paper responds to this call by studying a specific incentive-design problem that arises when security vulnerabilities are embedded in multi-tier supply networks and when the government cannot perfectly observe either a firm's baseline network security or its security effort.

This leads to three research questions. First, when does a firm underinvest in supply-chain security relative to the social optimum? Second, when should a policymaker use an ex-ante audit-based subsidy rather than an ex-post inspection-based insurance mechanism? Third, can hybrid mechanisms that combine preventive and claims-contingent verification outperform pure subsidy or pure insurance programs? These questions speak directly to ongoing policy debates around whether governments should rely on certification based mitigation programs, claims-contingent backstops, or layered instruments that combine the two.

[1] This mirrors widely used public practices in physical and cyber settings. One example is CBP's C-TPAT, a voluntary supply-chain security program in which certified firms receive ex-ante operational benefits (such as reduced examinations, front-of-line inspections, FAST-lane access) conditional on meeting documented security criteria and periodic validations; this is a classic pre-incident compliance gate used to harden logistics networks (`https://www.cbp.gov/border-security/ports-entry/cargo-security/CTPAT`). Another example is DHS/FEMA's Port Security Grant Program (PSGP), which provides pre-incident grants to port authorities and private-sector partners to fund access control, surveillance, and other mitigation investments, prioritized by risk and tied to approved security plans, i.e., funding contingent on compliance planning (`https://www.fema.gov/grants/preparedness/port-security`).

[2] This corresponds to claims-contingent public backstops used when private markets face uncertainty and correlation. One example is the Terrorism Risk Insurance Program (TRIA), a federal backstop that shares post-event losses with private insurers after certified terrorist acts (`https://content.naic.org/insurance-topics/terrorism-risk-insurance-act`). TRIA was created after the September 11, 2001 attacks on the World Trade Center and the Pentagon because uncertainty and correlation made private cover scarce–an archetype of public reinsurance for tail, correlated risks. Another example is the National Flood Insurance Program (NFIP), a federal program that pays claims after flood events, with community participation tied to mitigation standards (see FEMA's NFIP resources).

Evaluating these instruments requires explicit attention to verification. Audits and inspections are costly and imperfect; information asymmetry generates both adverse selection (hidden type; baseline network security) and moral hazard (hidden action; compliance effort). Incentive-based approaches that condition transfers on *noisy* audits/inspections are often more implementable than prescriptive mandates in multi-tier, privately owned supply networks and align with established theory and practice in OM and economics (Laffont and Martimort 2009, Nikoofal and Gümüş 2020, Babich and Tang 2012). Crucially, even though firms choose effort before any incident under both contracts, the *channel* through which incentives operate differs: the subsidy's ex-ante audit provides a direct lever on effort that does not rely on an incident occurring, whereas insurance's ex-post inspection is claim-triggered and its deterrence weakens as incidents become rarer in safer networks.

We develop a game-theoretic model with a firm embedded in a supply network and a government social planner. The firm privately knows its baseline network security and chooses whether to undertake costly security compliance; the government designs contracts under noisy, costly verification. We analyze the socially optimal benchmark and then characterize equilibrium outcomes under subsidy and insurance. A central structural finding is that, with asymmetric information and imperfect verification, *both* mechanisms generate pooling equilibria rather than full separation. Depending on the environment, outcomes fall into a *high-type pooling window* (contracts calibrated to induce higher-security firms) or a *low-type pooling window* (calibrated to induce lower-security firms). We then compare instruments across environments that differ by verification cost/accuracy and baseline security. Where both are feasible, we use an *efficiency index* (prevention per unit of agency cost) to select the instrument that delivers more protection per dollar.

Three results emerge from our study. The first one explains comparative performance and complementarity aspect. Insurance performs best when baseline security is low and incidents remain likely if firms shirk: post-incident inspections occur often enough to make denied coverage a credible threat, and insurance premiums help screen mimicking. Subsidies perform best when baseline security is moderate to high and pre-incident verification is credible: they internalize spillovers before attacks occur with relatively light audits. These patterns create *regional complementarity*: where one instrument struggles, the other typically works. The second result defines pooling structure and boundaries. Because adverse selection and moral hazard interact, the pure mechanisms deliver pooling equilibria. Specifically, we characterize the high-type and low-type windows and show how their boundaries shift with the cost and accuracy of verifications. Third, we evaluate the value of hybrid contracts. We examine two variants: a delayed-audit hybrid (subsidy paid up front; coverage conditioned on a later inspection) and an early-audit hybrid (verify first; then activate subsidy and coverage). Both can outperform pure instruments–since compliance is more resilient to rising verification costs–they consistently dominate subsidies in low-type pooling windows and can beat insurance when the investment-benefit gap is large.

2. Related Literature

The private sector sits on the front line of homeland security and holds much of the relevant operational information. Therefore, designing government interventions that induce security investment in private firms has attracted growing attention. The literature spans two related streams: settings where the private sector owns physical infrastructure (Nikoofal et al. 2023, Bakshi and Gans 2010, Tang 2006) and settings where it operates cyber systems (Kumar and Mallipeddi 2022, Luo and Choi 2022).

In the physical-infrastructure stream, work largely studies government resource allocation against terrorism and natural disasters–often via defender-attacker formulations (Jenkins et al. 2024, Baron et al. 2018, Shan and Zhuang 2013, Golany et al. 2009, Zhuang and Bier 2007). A prominent line analyzes containerized supply chains (Nikoofal et al. 2023, Bagchi and Paul 2017, Bakshi and Gans 2010, Bakshi et al. 2011), which mainly develop economic models to evaluate the effectiveness of reduced port inspections in encouraging security compliance by private sector. The cyber-systems stream connects cybersecurity and public contracting, focusing on how policy can reshape incentives for patching, disclosure, and investment. The vulnerability-discovery literature evaluates the social value of finding and fixing software flaws (Cheung and Bell 2021, August and Tunca 2011) and its implications for operations and supply chains (Choi et al. 2022, Olsen and Tomlin 2020, Kumar et al. 2018, Nagurney et al. 2015). Unlike most prior work that centers on vendor-customer or customer-customer coordination, we take the government's perspective and ask how a principal can minimize social loss when firms privately know their baseline network security and effort. Several papers are close in spirit (August and Tunca 2008, Cavusoglu et al. 2007, August and Tunca 2006, Kannan and Telang 2005). The most related is Cavusoglu et al. (2008), where a vendor and a firm play a Stackelberg game over patch management; they show social optimality cannot be decentralized without contracts and that cost-sharing can synchronize incentives. Luo and Choi (2022) examine when governments should penalize firms to spur e-commerce cybersecurity investment. Our study differs methodologically and substantively. Prior papers do not analyze incentive design under information asymmetry faced by the government. In our setting, security investment stochastically reduces risk, creating an ex-post information problem and requiring incentive-compatible mechanisms under noisy, costly verification. We develop and compare public economic incentives–subsidy, insurance, and hybrids–by their effectiveness at promoting socially optimal investment.

This paper also relates to the broader subsidy literature in Operations Management. Subsidies have been studied in agriculture (Akkaya et al. 2021, Alizamir et al. 2019, Gupta et al. 2017), energy and environmental policy (Alizamir et al. 2016, Cohen et al. 2016), and consumer welfare (Yu et al. 2018, 2020). Within operations management, our work connects to methods applied to information systems (Kumar et al. 2018). To our knowledge, we are among the first to analyze subsidy policy for security investment with hidden type (baseline security) and hidden action (security compliance effort), under explicit audit noise and cost.

Lastly, we contribute to the business insurance literature. Prior OM studies explore diverse insurance applications: business interruption and operations (Dong and Tomlin 2012), curbing free riding in multi-firm settings (Serpa and Krishnan 2016), inspection-insurance interplay under financing constraints (Chen et al. 2022), return-shipping insurance on platforms (Li et al. 2023), and recall insurance to induce supplier quality (Chen et al. 2023). Our work is closest to policy-oriented models of cyber risk insurance (Mukhopadhyay et al. 2013). For instance, Lakdawalla and Zanjani (2005) highlight government support in terrorism insurance, Öğüt et al. (2011) analyze correlated risks and unverifiable losses, and Yang et al. (2019) study interdependent security with hidden user risk. We extend this stream by jointly modeling moral hazard and adverse selection from a public-policy perspective: the firm's compliance is hidden and its baseline network security is private. Our framework quantifies the value of inspections and enables a tractable comparison of subsidy, insurance, and hybrid mechanisms.

3. Model Framework

3.1. Firm's Vulnerability and Security Investment

We model the problem as a strategic interaction between the government (hereinafter referred to as "she") and a firm (referred to as "he"). The firm owns a supply chain whose security and operational viability are of shared interest to both the firm and the government, the latter acting as a social planner. Let γ represent the exogenous probability of a security vulnerability and an attack on the firm's supply network (August and Tunca 2006). Such attacks might target vulnerabilities inherent in physical supply chain logistics or weaknesses within digital infrastructures of e-commerce supply chains. In either case, the likelihood of a successful attack depends primarily on two factors: (i) the overall security posture of the firm's supply network, and (ii) the firm's own internal investment in costly security measures.

To formally represent supply network security, we adopt the methodology developed by Nagurney and Shukla (2017), Nagurney and Nagurney (2015). Specifically, we consider a firm whose supply network comprises m suppliers (including sub-suppliers), each independently deciding whether or not to invest in security. Let $s_i \in \{0,1\}$ denote the security investment status of supplier i, where $s_i = 1$ indicates that supplier i has invested in security measures, and $s_i = 0$ otherwise, for $i = 1,\dots,m$. Consequently, we define the average security level across the entire network as $\bar{s} = \frac{\sum_{i=1}^{m} s_i}{m}$. To avoid trivial scenarios in which the entire network is fully secure, we assume that at least one supplier has not invested, implying $0 \le \bar{s} < 1$.

Due to the complexity of global supply chains and limited visibility from a regulatory perspective, the government faces an inherent adverse selection problem: the firm typically has superior knowledge of its supply network's security level compared to the government. To explicitly capture this information asymmetry, we classify firms into two discrete types based on their network security level, denoted as $\bar{s}_\theta$, where type $\theta \in \{h, \ell\}$ represents high- and low-security network conditions, respectively. By definition, these satisfy $0 \le \bar{s}_\ell < \bar{s}_h < 1$. Furthermore, regardless of its network type, a θ-type firm can enhance its security by undertaking an internal security investment decision, $e_\theta \in \{0,1\}$, incurring a fixed cost ψ if the investment is made (i.e., if $e_\theta = 1$). The internal security level resulting from the firm's investment decision is defined as

$s_\theta(e_\theta) = e_\theta\rho + (1-e_\theta)\varphi$, where parameters satisfy $0 \le \varphi < \rho < 1$. This specification indicates that the firm's security investment enhances its internal defense level by the increment $\rho - \varphi$. However, the firm's security investment decision, e_θ, is not directly observable by the government, introducing a *moral hazard* problem.

Integrating these components, we express the probability of a successful attack penetrating the θ-type firm's supply chain as follows:

$$p_\theta(e_\theta) = \gamma(1-\bar{s}_\theta)(1-s_\theta(e_\theta)), \quad \theta \in \{h, \ell\}. \tag{1}$$

This formulation captures the multiplicative relationship between network-wide security vulnerabilities and the firm's internal security choices. It explicitly demonstrates how the vulnerability of a firm's supply chain depends stochastically on both its inherent network type θ and its discretionary security investment decision e_θ. Table 1 summarizes this relationship clearly. Finally, recognizing that the firm's true network security type is private information, we assume the government holds a prior belief about the firm's type, formally represented as $\zeta \equiv \mathbb{P}\{\theta = h\}$ and $1-\zeta \equiv \mathbb{P}\{\theta = \ell\}$.

Table 1 Firm-θ vulnerability as a function of supply network type and level of security investment

		Firm's supply network type	
		$\theta = \ell$	$\theta = h$
Firm's	$e_\theta = 0$	$\gamma(1-\bar{s}_\ell)(1-\varphi)$	$\gamma(1-\bar{s}_h)(1-\varphi)$
security investment	$e_\theta = 1$	$\gamma(1-\bar{s}_\ell)(1-\rho)$	$\gamma(1-\bar{s}_h)(1-\rho)$

Notes. $0 \le \varphi < \rho < 1$ and $0 \le \bar{s}_\ell < \bar{s}_h < 1$.

3.2. Government's and Firm's Loss

In the event of a successful attack through the firm's supply chain, the firm and government face losses of varying nature and magnitude. Given the government's role as a social planner, losses incurred by the firm also constitute losses for the government, complemented by additional societal costs. These combined losses span both direct operational disruptions and broader indirect economic and social externalities.

From the firm's perspective, a successful attack leads to two distinct categories of losses: an *indirect network-level* disruption and a *direct operational* impact. The first category, denoted by L_n, reflects indirect losses resulting from intentional adversarial actions targeting the firm's suppliers or logistics partners, even if the firm itself is not directly compromised. Such incidents generate cascading externalities due to supply-chain interconnectedness, as modeled in previous literature (Nagurney and Shukla 2017, Nagurney and Nagurney 2015). Examples include cyberattacks or sabotage targeting critical infrastructure providers, logistics companies, or key suppliers within the supply chain. These disruptions typically entail increased costs associated with expedited shipping, emergency procurement, and internal production adjustments. Consistent with the model described earlier, the network-level disruption occurs with probability $\gamma(1-\bar{s}_\theta)$.

The second category, represented by L_f, captures direct operational losses incurred when the firm itself becomes the direct victim of an adversarial attack. Given a successful network-level breach, the direct compromise of the firm occurs with conditional probability $1-s_\theta(e_\theta)$, where $e_\theta \in \{0,1\}$ denotes firm-θ's binary decision to invest in internal security, and $s_\theta(e_\theta)$ represents the resulting internal protection level (see Table 1). Direct operational losses encompass data breaches, production shutdowns, failed deliveries, regulatory fines, and reputational damage. For example, following its 2013 data breach, Target Corporation faced \$18.5 million in settlement costs along with significant reputational damage and loss of consumer trust (Ramakrishnan and Bose 2019). Combining these two loss components, the expected total loss for a type-θ firm resulting from a successful supply-chain attack is $\gamma(1-\bar{s}_\theta)[L_n+(1-s_\theta(e_\theta))L_f]$.

From the government's broader societal viewpoint, a successful supply-chain attack imposes societal costs far beyond the affected firm. These broader societal costs, denoted by L_s, include economic disruptions (e.g., lost output, shortages, inflation), social impacts (e.g., unemployment, reduced consumer trust), and systemic risks to critical infrastructure. High-profile incidents like the 2013 Target breach (Jones 2021), which compromised the data of over 70 million consumers, or the Home Depot attack[3]–enabled through a third-party vendor–illustrate how adversarial actions can propagate through supply networks, triggering widespread externalities that justify government intervention. Accounting for these broader externalities, the government's total expected loss from a successful attack on a type-θ firm's supply chain is thus $\gamma(1-\bar{s}_\theta)[L_n+(1-s_\theta(e_\theta))(L_f+L_s)]$.

For clarity, we list the notation for all parameters and decisions in Table 2.

3.3. Contracts

In the presence of hidden information (adverse selection) and hidden actions (moral hazard), the government must design incentive-compatible contracts that induce the firm to make socially optimal security investments. To formalize the contracting environment under asymmetric information, we invoke the extended revelation principle (Myerson 1982), which allows us to restrict attention to direct mechanisms without loss of generality. We model each contract as comprising two components–a fixed transfer and a contingent payment–where the nature and timing of the contingent payment define two distinct incentive mechanisms: a subsidy contract (proactive mitigation) and an insurance contract (reactive contingency).

- *Subsidy contract*: Under this mechanism, the government offers the firm a fixed transfer, denoted by τ_θ, which acts as a subsidy provided upon acceptance of the contract. To ensure compliance, the contract also includes a contingent penalty, denoted by ω_θ, imposed on the firm if a costly audit conducted by the government reveals that the firm has failed to meet the required investment level E_θ. This setup incentivizes the firm to proactively invest in security before any attack occurs. Thus, the subsidy contract functions as

[3] https://ir.homedepot.com/news-releases/2014/11-06-2014-014517315

Table 2 List of Notations

Symbol	Definition
$\theta \in \{h, \ell\}$	Firm type: high-security (h) or low-security (ℓ) supply network
$\bar{s}_\theta$	Firm-θ network security level; $\bar{s}_\ell < \bar{s}_h < 1$
$e_\theta \in \{0, 1\}$	Binary decision to invest in internal security (1 = invest, 0 = do not invest)
ρ	Internal protection level when investing in security ($0 < \varphi < \rho < 1$)
φ	Internal protection level when not investing in security
γ	Probability or frequency of a disruptive incident (physical or digital)
ψ	Fixed cost incurred by a firm that invests in security
κ	Unit cost of conducting an audit or inspection
μ	False positive rate: probability of passing audit without investing
λ_θ	Probability that a type-θ firm is audited/inspected
η_θ	Probability that a type-θ firm invests in security
ζ	Government's prior belief that a firm is of high-security type ($\theta = h$)
τ_θ	Subsidy payment transferred to a type-θ firm under the subsidy contract
ω_θ	Penalty imposed on type-θ firm if caught shirking under audit
L_n	Indirect loss to the firm from network-level ripple effects (e.g., supplier disruptions)
L_f	Direct loss to the firm from being directly attacked (e.g., data breach, production halt)
L_s	Social loss to the government from a successful attack on the firm (e.g., GDP loss, shortages)
π_θ	Insurance premium paid by type-θ firm under the insurance contract
ϕ_θ	Insurance reimbursement received by firm-θ in case of direct disruption

an ex-ante mitigation tool, where the contingent clause is triggered prior to any realized disruption. For each firm type $\theta \in h, \ell$, the subsidy contract can be represented as: $\Omega^{\text{SC}} = \{E_\theta, \tau_\theta, \omega_\theta\}_{\theta=h,\ell}$.

- *Insurance contract*: This mechanism similarly includes a fixed and a contingent component, but with a key difference in timing. The fixed component is the insurance premium π_θ, paid upfront by the firm. The contingent component is the reimbursement amount ϕ_θ, which is paid by the government only if a disruption occurs and an indemnity claim is filed. Importantly, for the firm to qualify for the reimbursement, a post-incident audit must verify that the firm had indeed invested at least E_θ in security, as specified in the contract. The insurance contract therefore functions as an ex-post contingency plan. Unlike the subsidy contract, where compliance is monitored preemptively, the insurance mechanism provides relief retroactively and only upon verification. For each firm type $\theta \in h, \ell$, the insurance contract is denoted as: $\Omega_\theta^{\text{IC}} = \{E_\theta, \pi_\theta, \phi_\theta\}_{\theta=h,\ell}$.

Fig. 1 describes the timing of the events, decisions, and contract terms.

4. Socially Optimal Solution

We first derive the first-best (socially optimal) security decision in a centralized setting where the government, acting as an omniscient social planner, fully internalizes all losses borne by both the firm and society. This solution serves as a benchmark to evaluate the performance of decentralized incentive mechanisms (subsidy and insurance contracts).

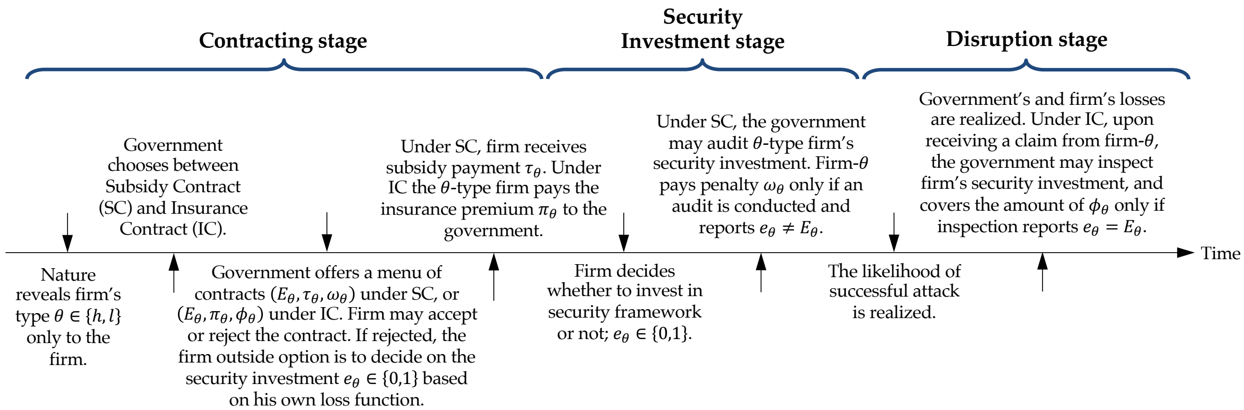


Figure 1 **Timing of events and decisions**

Let $e^{\text{SO}} \in \{0,1\}$ denote the socially optimal investment decision. The government chooses e^{SO} to minimize the total expected cost, which comprises (i) the expected loss from a successful supply-chain attack and (ii) the cost of the security investment:

$$\min_{e^{\text{SO}} \in \{0,1\}} \gamma(1-\bar{s}_\theta)[L_n + (1-s_\theta(e^{\text{SO}}))(L_f + L_s)] + e^{\text{SO}}\psi \tag{2}$$

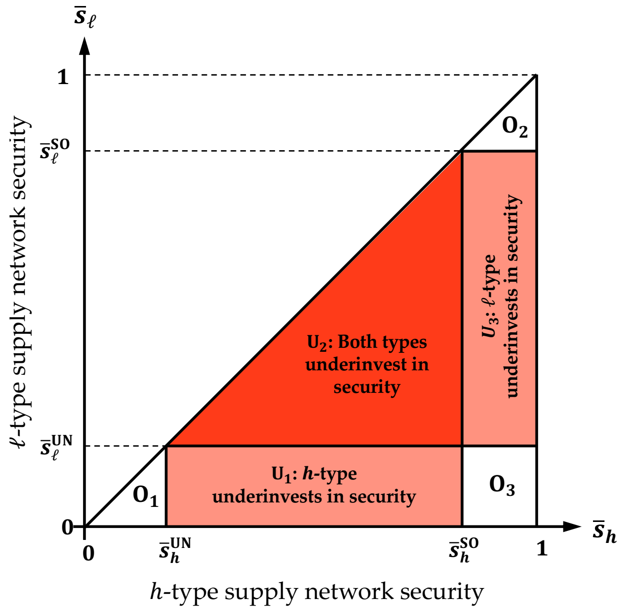
The term $\gamma(1-\bar{s}_\theta)$ is the probability that an attack reaches the focal supply chain. Conditional on that event, the social planner bears (i) a network-level loss L_n, and (ii) an additional loss $L_f + L_s$ if the firm itself is compromised with residual probability $1-s_\theta(e^{\text{SO}})$. Investing (setting $e^{\text{SO}} = 1$) improves the firm's internal defense from φ to ρ, reducing vulnerability by $\rho - \varphi$. Hence, the expected benefit of investing equals $\gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f + L_s)$, while the cost equals ψ. The social planner therefore selects

$$e^{\text{SO}} = \begin{cases} 1, & \text{if } \psi \leq \gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f+L_s), \\ 0, & \text{otherwise.} \end{cases}$$

In contrast, under an UNgoverned scenario (denoted by "UN" throughout the paper)–where the firm unilaterally decides on its security investment to minimize its own expected cost–the firm solves $\min_{e^{\text{UN}} \in \{0,1\}} \{\gamma(1-\bar{s}_\theta)[L_n + (1-s_\theta(e^{\text{UN}}))L_f] + e^{\text{UN}}\psi\}$. Here, the firm considers only its own direct and network-level losses but ignores the societal loss L_s. Consequently, the firm invests ($e^{\text{UN}} = 1$) if and only if $\psi \leq \gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$. Because the firm internalizes only L_f–not the additional societal externality L_s–the ungoverned investment threshold is strictly lower than the social planner's whenever $L_s > 0$. This reveals that the firm systematically under-invests in security, which we formalize in the following lemma (all proofs are provided in the Appendix):

LEMMA 1. *In the absence of government intervention, the firm may under-invest in security, leaving the supply chain more vulnerable than in the socially optimal outcome, as shown in Fig. 2.*

Figure 2 **Social loss due to underinvestment in security under ungoverned setting**



Notes. $\bar{s}_\theta^{SO} = \frac{\gamma(\rho-\phi)(L_f+L_s)-\psi}{\gamma(\rho-\phi)(L_f+L_s)}$ and $\bar{s}_\theta^{UN} = \frac{\gamma(\rho-\phi)L_f-\psi}{\gamma(\rho-\phi)L_f}$. The socially optimal solution is achievable under the ungoverned solution in regions O_1, O_2, and O_3.

Lemma 1 and Figure 2 answer our first research question by identifying when private security incentives fail to implement the socially optimal level of supply-chain protection. The result shows that underinvestment can arise even under perfect information because the firm internalizes only its private operational loss, L_f, whereas the government internalizes both firm-level and societal losses, $L_f + L_s$. Thus, the wedge is not caused only by informational frictions; it is already present because security investment creates positive spillovers that the firm does not fully capture.

This result contributes to the POM debate on cybersecurity and technology-enabled supply chains that call for research that helps organizations, supply chains, and governments develop robust strategies for reducing cyberattacks and their repercussions (Kumar and Mallipeddi 2022, Kumar et al. 2018). Lemma 1 provides a formal reason why such settings require policy attention: interconnected security investments may be privately unattractive even when they are socially valuable. The managerial implication is that policymakers should not view public intervention only as a response to hidden information. Even when type and effort are observable, decentralized investment may remain too low whenever the social spillover L_s is material. Once adverse selection over $\bar{s}_\theta$ and moral hazard over e_θ are added, the implementation problem becomes more severe. The remainder of the paper therefore evaluates how proactive subsidy and reactive insurance mechanisms can restore socially desirable security investment under asymmetric information.

5. Subsidy Contract

In this section we study the effectiveness of the Subsidy Contract indicated by "SC" in achieving socially optimal level of security investment. The analysis of the subsidy contract involves two stages. In the first stage, the government offers a menu of contracts that consist of three terms for each type $\Omega_\theta^{\text{SC}} = \{E_\theta, \tau_\theta, \omega_\theta\}_{\theta=h,\ell}$ where $E_\theta \in \{0,1\}$ indicates the required level of security investment by firm-θ. Once the contract is accepted by the firm, the government transfers the fixed payment τ_θ to the firm. In the second stage, the firm decides on the level of security investment $e_\theta \in \{0,1\}$ while government decides whether to conduct an audit $\mathcal{A}_S \in \{0,1\}$ at cost of κ. If an audit is conducted, the government imposes a penalty term ω_θ if and only if the outcome of the audit reveals that the firm does not comply with the contracted effort level, i.e., $e_\theta \neq E_\theta$. In reality, there is always a chance that an audit may not accurately reveal a firm's deviation in exerting effort. Therefore, we assume that the government receives a noisy signal from the audit. Specifically, if the firm does not exert the effort, the audit can result in a *false positive* detection with probability μ_{S}, incorrectly concluding that the firm exerted the effort.

The security investment effort is hidden from the government; therefore, the second stage can be analyzed as a simultaneous game between the government and the firm. Using the backward induction, given the contract terms, first, we characterize all the possible Nash equilibria of this second stage audit game. Second, we solve the optimal contract design problem that would induce each equilibrium in the audit game. Finally, by comparing the government's expected loss incurred under each contract, we characterize the optimal subsidy contract.

5.1. Analysis of the Audit Game

To characterize all pure and mixed Nash Equilibria (NE) of the audit game, we define λ_θ and η_θ to denote the probabilities of the government conducting an audit (i.e., audit frequency) and the θ-type firm investing in security compliance (i.e., compliance rate), respectively. Let $\mathcal{G}_\theta(\lambda_\theta, \eta_\theta|\Omega_\theta^{\text{SC}})$ and $\mathcal{F}_\theta(\lambda_\theta, \eta_\theta|\Omega_\theta^{\text{SC}})$ respectively denote the government's and firm-θ's expected cost functions under a given subsidy contract $\Omega_\theta^{\text{SC}}$. The strategic form of the audit game when the government wants to induce $E_\theta = 1$ is presented in Table 3, where the top expression in each cell is the firm's expected cost, and the bottom expression is the government's expected cost.

Table 3 The Firm's (Top expression) and Government's (Bottom expression) Expected Cost in the Subsidy-Audit Game when $E_\theta = 1$

Firm's decision	Audit decision	
	$\mathcal{A}_S = 1$	$\mathcal{A}_S = 0$
$e_\theta = 1$	$-\tau_\theta + \gamma(1-\bar{s}_\theta)[L_n + (1-\rho)L_f] + \psi$ $\tau_\theta + \gamma(1-\bar{s}_\theta)[L_n + (1-\rho)(L_f + L_s)] + \kappa$	$-\tau_\theta + \gamma(1-\bar{s}_\theta)[L_n + (1-\rho)L_f] + \psi$ $\tau_\theta + \gamma(1-\bar{s}_\theta)[L_n + (1-\rho)(L_f + L_s)]$
$e_\theta = 0$	$-\tau_\theta + \gamma(1-\bar{s}_\theta)[L_n + (1-\varphi)L_f] + (1-\mu_{\text{S}})\omega_\theta$ $\tau_\theta + \gamma(1-\bar{s}_\theta)[L_n + (1-\varphi)(L_f + L_s)] + \kappa - (1-\mu_{\text{S}})\omega_\theta$	$-\tau_\theta + \gamma(1-\bar{s}_\theta)[L_n + (1-\varphi)L_f]$ $\tau_\theta + \gamma(1-\bar{s}_\theta)[L_n + (1-\varphi)(L_f + L_s)]$

By multiplying the probability of each outcome, determined by the firm's effort decision η_θ and the government's audit decision λ_θ, with the corresponding cost entries in Table 3, we obtain:

$$\begin{aligned}\mathcal{G}_\theta(\lambda_\theta,\eta_\theta \mid E_\theta=1,\tau_\theta,\omega_\theta) &= \tau_\theta+\gamma(1-\bar{s}_\theta)\left[L_n+(1-\varphi)(L_f+L_s)-\eta_\theta(\rho-\varphi)(L_f+L_s)\right]\\ &\quad+\lambda_\theta\left[\kappa-(1-\eta_\theta)(1-\mu_{\mathrm{S}})\omega_\theta\right] \qquad (3)\\ \mathcal{F}_\theta(\lambda_\theta,\eta_\theta \mid E_\theta=1,\tau_\theta,\omega_\theta) &= -\tau_\theta+\gamma(1-\bar{s}_\theta)\left[L_n+(1-\varphi)L_f\right]+\lambda_\theta(1-\mu_{\mathrm{S}})\omega_\theta\\ &\quad+\eta_\theta\left[\psi-\gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f-\lambda_\theta(1-\mu_{\mathrm{S}})\omega_\theta\right] \qquad (4)\end{aligned}$$

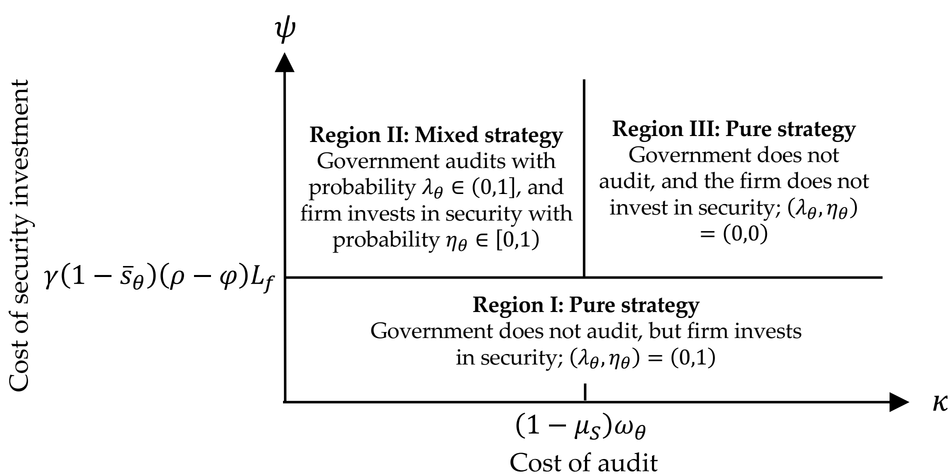
The following proposition fully characterizes the solution of the audit game under a specific subsidy contract $\Omega_\theta^{\mathrm{SC}}$.

PROPOSITION 1. *Given the subsidy contract $\Omega_\theta^{\mathrm{SC}}=\{E_\theta,\tau_\theta,\omega_\theta\}$ offered by the government, there exist three regions in Fig. 3 under which a unique NE exists and characterized as follows:*

- *Region I (Full Compliance, No Audit): There exists a pure strategy NE where $\lambda_\theta=0$ and $\eta_\theta=1$ if $\psi\le\gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$.*
- *Region II (Mixed Strategy): There exists a mixed strategy NE, $\lambda_\theta^*=\frac{\psi-\gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f}{(1-\mu_{\mathrm{S}})\omega_\theta}$, $\eta_\theta^*=1-\frac{\kappa}{(1-\mu_{\mathrm{S}})\omega_\theta}$ provided that $\psi>\gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$ and $\kappa<(1-\mu_{\mathrm{S}})\omega_\theta$.*
- *Region III (No Compliance, No Audit): There exists a pure strategy NE where $\lambda_\theta=0$ and $\eta_\theta=0$ if $\psi>\gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$ and $\kappa\ge(1-\mu_{\mathrm{S}})\omega_\theta$.*

Proposition 1 answers a basic implementation question: *when can a pre-incident audit and penalty system induce security compliance?* A type-θ firm obtains a private expected benefit $\gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$ from investing. If this exceeds the investment cost ψ, compliance is privately optimal and no audit is needed (Region I). If the private benefit is insufficient, the government can induce partial compliance only when audits are sufficiently

Figure 3 **The audit sub-game Nash equilibrium**



accurate, not too costly, and paired with a credible penalty (Region II). If audit costs are too high or penalties are too weak, enforcement loses credibility and the firm does not invest (Region III).

This result connects to OM research on inspection-based incentives and supply-chain security by clarifying when audit-based prevention is operationally viable. Prior work on supply-chain inspection and security programs emphasizes that monitoring can discipline hidden actions, but also that inspection is costly and imperfect (Babich and Tang 2012, Nikoofal and Gümüş 2020). Proposition 1 identifies the exact enforcement channel in our setting: verification is effective only when it creates a credible expected penalty for noncompliance. That credibility depends jointly on the firm's investment-benefit gap, audit accuracy, audit cost, and penalty strength. The mechanism is therefore not simply that *more auditing* induces more compliance. Audit frequency increases when compliance is privately less attractive, but falls when audits are more accurate or penalties are stronger. A useful managerial insight is that a more secure baseline network does not necessarily make enforcement easier; because higher $\bar{s}_\theta$ lowers the firm's private marginal benefit from additional effort, it may require stronger deterrence. Thus, policymakers should evaluate ex-ante subsidy programs by the productivity of their audit system—audit accuracy, audit cost, and credible penalty strength—rather than by transfer size alone.

5.2. The Optimal Subsidy Contract

Given the NE of the audit game, we can now characterize the subsidy contract that minimizes expected social loss. By the extended revelation principle (Myerson 1982), the government can–without loss of generality–restrict attention to direct, incentive-compatible contracts. Accordingly, it suffices to offer a menu of two contracts, one for each firm type: $\Omega_\theta^{\text{SC}} = \{E_\theta, \tau_\theta, \omega_\theta\}_{\theta\in\{h,\ell\}}$, where $E_\theta \in \{0,1\}$ denotes the required effort level, τ_θ is the upfront subsidy payment, and ω_θ is the penalty in case of detected noncompliance. We now formalize the government's contract design problem.

For the contract to be acceptable, the θ-type firm must prefer participating over rejecting and reverting to its ungoverned (outside option) scenario. This requires the following *individual rationality* constraint:

$$\mathcal{F}_\theta(\Omega_\theta^{\text{SC}} \mid \lambda_\theta, \eta_\theta) \le \min_{e_\theta^{\text{UN}}\in\{0,1\}} \left\{\gamma(1-\bar{s}_\theta)\left[L_n + (1-s_\theta(e_\theta^{\text{UN}}))L_f\right] + e_\theta^{\text{UN}}\psi\right\}. \tag{IR^θ}$$

Beyond participation, the contract must also deter misrepresentation. A type-θ firm might attempt to mimic the opposite type $\tilde{\theta} \neq \theta$ by selecting $\Omega^{\text{SC}}\tilde{\theta}$. In doing so, it would choose an effort level $\tilde{\eta}_\theta \in [0,1]$, while the government audits with probability $\lambda_{\tilde{\theta}}$. To prevent such deviations, the following *incentive-compatibility* conditions must hold:

$$\mathcal{F}_\theta(\Omega_\theta^{\text{SC}} \mid \lambda_\theta, \eta_\theta) \le \mathcal{F}_\theta(\Omega_{\tilde{\theta}}^{\text{SC}} \mid \lambda_{\tilde{\theta}}, \tilde{\eta}_\theta), \quad \tilde{\theta} \neq \theta. \tag{IC^θ-1}$$

where the mimicking effort level satisfies:

$$\tilde{\eta}_\theta = \arg\min_{\eta\in[0,1]} \mathcal{F}_\theta(\Omega_{\tilde{\theta}}^{\text{SC}} \mid \lambda_{\tilde{\theta}}, \eta). \tag{IC^θ-2}$$

The government's objective is to minimize expected social loss while ensuring both individual rationality and incentive compatibility. Formally, the optimization problem is:

$$\mathcal{G}^{\text{SC}} = \min_{\Omega \in \Omega^{\text{SC}}} \check{\mathcal{G}}(\Omega) = \zeta \cdot \mathcal{G}_h(\Omega_h \mid \lambda_h, \eta_h) + (1-\zeta) \cdot \mathcal{G}_\ell(\Omega_\ell \mid \lambda_\ell, \eta_\ell), \qquad (\mathcal{P}^{\text{SC}})$$
$$\text{s.t. } \Omega^{\text{SC}} = \left\{\tau_\theta, \omega_\theta : IR^\theta,\ IC^\theta\text{-}1,\ IC^\theta\text{-}2,\ \forall \theta \in \{h, \ell\}\right\}.$$

where $\check{\mathcal{G}}(\Omega)$ is the government's loss under contract Ω, and Ω^{SC} is the set of all feasible contract terms that respect individual rationality and incentive compatibility constraints.

To characterize the optimal subsidy contract, we first solve the government's contract design problem $\mathcal{P}^{\text{SC}}$ for each implementable NE identified in Proposition 1. We then determine, within each region U_1, U_2, and U_3, the contract that minimizes expected social inefficiency by comparing the total inefficiency associated with the corresponding implementable NE.

We measure *expected social inefficiency* as the gap between the expected social loss under the subsidy regime and the first-best (socially optimal) outcome. For a given firm type θ, this gap has two components. The first one is *prevention shortfall*. Relative to the socially optimal solution, the system may remain more vulnerable under the subsidy contract. Under the social optimum, the government effectively finances security investment ψ so that the θ-firm exerts effort ($e_\theta^{\text{SO}} = 1$). Under the subsidy regime, by contrast, the firm invests with probability $\eta_\theta \le 1$ at its own cost. Whenever $e_\theta^{\text{SO}} = 1$, this generates an expected loss of $(1-\eta_\theta)\gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f+L_s)-\psi$. The second component is the resulting *agency and administrative costs*. The government's expected agency cost includes the subsidy transfer and audit expenditures. Specifically, after disbursing τ_θ, the government audits with probability λ_θ at unit cost κ and, if the firm shirks (with probability $1-\eta_\theta$) and the audit detects it (with probability $1-\mu_{\text{S}}$), imposes the penalty ω_θ. Lastly, because both types may contribute to these inefficiencies, the government aggregates the expected terms using the *a-priori* type probabilities ζ (for h) and $1-\zeta$ (for ℓ). We delegate the algebraic details to the Appendix and state the resulting optimal subsidy contract in the following proposition.

PROPOSITION 2. *The optimal subsidy contract* $\{\omega_\theta, \tau_\theta\}_{\theta=h,\ell}$*, government's audit decision* λ_θ*, and firm's security compliance decision* η_θ *are characterized in Table 4. Furthermore, the total inefficiency* I^{SC} *in each region can be obtained from equation (5):*

$$I^{\text{SC}} = \underbrace{\sum_{\theta\in\{\ell,h\}} \zeta_\theta \cdot e_\theta^{\text{SO}} \left[(1-\eta_\theta)\gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f+L_s)-\psi\right]}_{\substack{\text{Expected loss due to} \\ \text{underinvestment in security}}} + \underbrace{\sum_{\theta\in\{\ell,h\}} \zeta_\theta \cdot \Big[\underbrace{\tau_\theta}_{\text{Subsidy}} + \underbrace{\lambda_\theta\left(\kappa-(1-\eta_\theta)(1-\mu_{\text{S}})\omega_\theta\right)}_{\text{Expected cost of audit}}\Big]}_{\text{Agency cost}} \qquad (5)$$

Proposition 2 answers the second research question from the perspective of a preventive policy: *when can an ex-ante audit-based subsidy restore socially desirable security investment, and when does it remain second-best?* The result shows that subsidies are a natural instrument for addressing underinvestment because they condition support on pre-incident verification of compliance. However, when firms differ in their privately

Table 4 Optimal subsidy contract and the equilibrium outcomes

Region	Optimal contract	Audit level	Security investment level	Information rent	Socially optimal solution
$U_1^{A\|S}, U_1^{C\|S}$	No contract	$\lambda_h=0,\ \lambda_\ell=0$	$\eta_h=0, \eta_\ell=1$	0	$e_h^{so}=1,\ e_\ell^{so}=1$
$U_1^{B\|S}$	$\tau_h=\tau_\ell=\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f$ $\omega_h=\omega_\ell=\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f$	$\lambda_h=1,\ \lambda_\ell=1$	$\eta_h=1-\dfrac{\kappa}{(1-\mu_S)(\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f)}$ $\eta_\ell=1$	$\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f$	$e_h^{so}=1,\ e_\ell^{so}=1$
$U_2^{B\|S}$				$\gamma(\bar{s}_h-\bar{s}_\ell)(\rho-\varphi)L_f$	
$U_2^{C\|S}, U_2^{D\|S}, U_2^{E\|S}$	No contract	$\lambda_h=0,\ \lambda_\ell=0$	$\eta_h=0,\ \eta_\ell=0$	0	$e_h^{so}=1,\ e_\ell^{so}=1$
$U_3^{B\|S}$	$\tau_h=\tau_\ell=\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f$ $\omega_h=\omega_\ell=\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f$	$\lambda_h=0,\ \lambda_\ell=1$	$\eta_h=0,$ $\eta_\ell=1-\dfrac{\kappa}{(1-\mu_S)(\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f)}$	0	$e_h^{so}=0,\ e_\ell^{so}=1$
$U_2^{A\|S}$					$e_h^{so}=1,\ e_\ell^{so}=1$
$U_3^{A\|S}, U_3^{C\|S}$	No contract	$\lambda_h=0,\ \lambda_\ell=0$	$\eta_h=0,\ \eta_\ell=0$	0	$e_h^{so}=0,\ e_\ell^{so}=1$

Figure (a): All regions

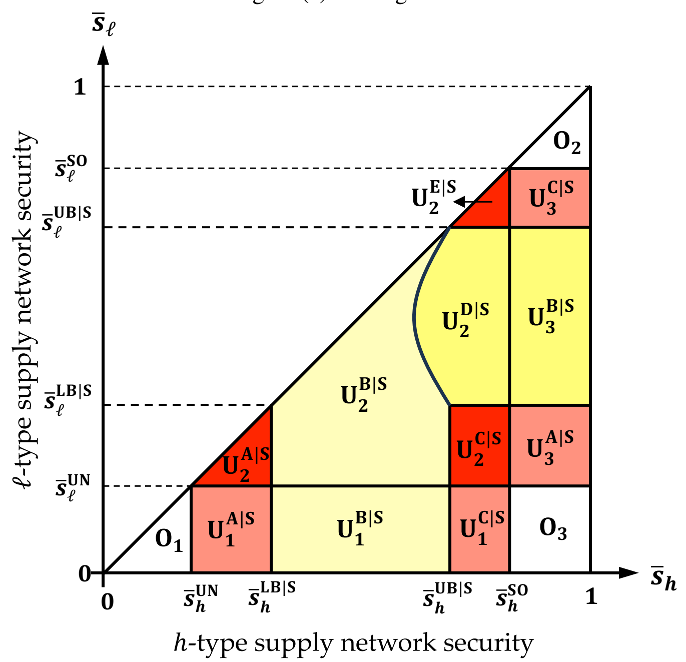
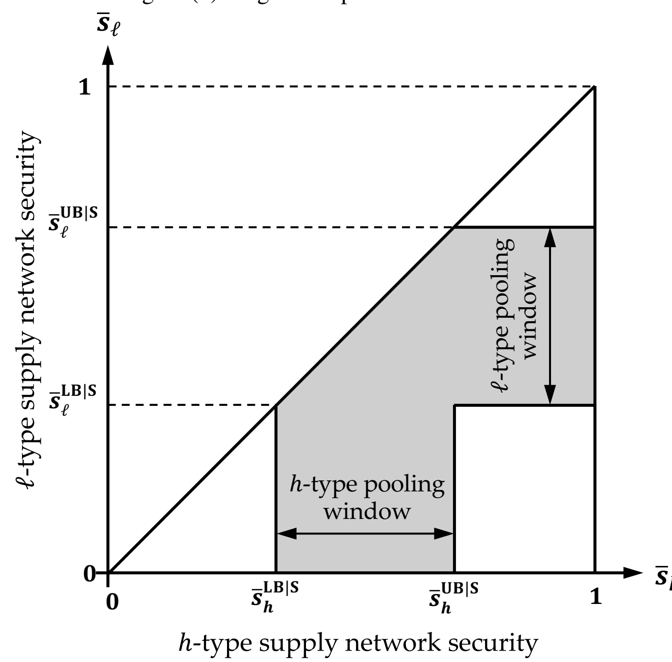


Figure (b): Regions of partial underinvestment



Notes: The information rent is payable to the ℓ-type firm.

$$\bar{s}_\ell^{LB}=\bar{s}_h^{LB}=1-\frac{\psi(3L_f+L_s)-\dfrac{\kappa(L_f+L_s)}{1-\mu_S}+\sqrt{\left[\psi(3L_f+L_s)-\dfrac{\kappa(L_f+L_s)}{1-\mu_S}\right]^2-4(2L_f+L_s)L_f\psi^2}}{2\gamma(\rho-\varphi)(2L_f+L_s)L_f},\quad \bar{s}_\ell^{UB}=\bar{s}_h^{UB}=1-\frac{\psi(3L_f+L_s)-\dfrac{\kappa(L_f+L_s)}{1-\mu_S}-\sqrt{\left[\psi(3L_f+L_s)-\dfrac{\kappa(L_f+L_s)}{1-\mu_S}\right]^2-4(2L_f+L_s)L_f\psi^2}}{2\gamma(\rho-\varphi)(2L_f+L_s)L_f}.$$

observed baseline network security and effort is hidden, the subsidy mechanism cannot generally implement full separation. Comparing the induced investment probabilities η_θ with the socially optimal benchmark e_θ^{SO} in Table 4 shows that the subsidy contract only partially closes the underinvestment gap, as highlighted by regions $U_1^{B|S}$, $U_2^{B|S}$, $U_2^{D|S}$, and $U_3^{B|S}$. This connects to the OM literature on supply-chain security, inspection, and certification-based programs: ex-ante verification can discipline hidden actions, but it also creates screening frictions when firms have private information about their underlying risk exposure. The contribution of Proposition 2 is to characterize exactly how this tension appears in a public security setting: the government can use subsidies to raise compliance, but asymmetric information forces pooling windows and, in some regions, information rents.

To see this more clearly, consider region U_1, where only the h-type underinvests under the ungoverned outcome (refer to Lemma 1). Any attempt to offer distinct menus for h- and ℓ-type firms creates a direct conflict between individual rationality (IR) and incentive compatibility (IC). To induce h-type compliance, the government must subsidize the full investment-benefit gap, $\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f$, which secures the h-type's participation. However, doing so violates the ℓ-type's IC constraint: since the ℓ-type already invests under his outside option (i.e., ungoverned solution), she could mimic the h-type's contract, exert effort as in her outside option, collect the subsidy, and avoid penalties if audited. Hence, no pair of transfers (τ_h, τ_ℓ) and penalties (ω_h, ω_ℓ) can jointly satisfy IR for h and IC for ℓ. Screening fails, and only a *pooling contract* remains feasible—at the cost of paying information rents whenever the non-target type (i.e., ℓ-type) mimics the intended one (i.e., h-type). Thus, the government adopts a second-best policy: one contract calibrated to induce compliance in a single type, while both types face the same terms. In general, two scenarios emerge:

– *High-type pooling window* ($U_1^{B|S}$ and $U_2^{B|S}$): The contract satisfies $\tau_h=\tau_\ell=\omega_h=\omega_\ell=\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f$, exactly bridging the h-type's investment-benefit gap. The audit game then admits a mixed-strategy equilibrium in which $\eta_h=\min\left\{1-\frac{\kappa}{(1-\mu_S)\,\omega_h},1\right\}$ and $\lambda_h=\min\left\{\frac{\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f}{(1-\mu_S)\,\omega_h},1\right\}$ so that the h-type complies with probability $\eta_h\in(0,1)$. The ℓ-type, facing identical terms, binds her IR and IC constraints and continues to invest. The outcome achieves partial compliance for the h-type and full compliance for the ℓ-type, at the cost of paying information rents to the latter.

– *Low-type pooling window* ($U_3^{B|S}$ and $U_2^{D|S}$): The contract instead targets the ℓ-type's compliance, setting $\tau_h=\tau_\ell=\omega_h=\omega_\ell=\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f$. The induced equilibrium yields $\eta_\ell=\min\left\{1-\frac{\kappa}{(1-\mu_S)\,\omega_\ell},1\right\}$ and $\lambda_\ell=\min\left\{\frac{\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f}{(1-\mu_S)\,\omega_\ell},1\right\}$ while h-type optimally abstains from compliance ($\eta_h=0$). Mimicking is unprofitable for h-type, since he would bear the investment cost ψ without offsetting benefit, and thus no information rent arises. Although formally pooled, the contract is *de facto* targeted to ℓ-type, ensuring efficient subsidies without overpayment.

The mechanism behind Proposition 2 is a trade-off between preventive enforcement and screening. A subsidy can raise compliance by pairing an ex-ante audit with a penalty for noncompliance, but the transfer that closes the target type's investment-benefit gap may also attract the non-target type and generate information rents. Audit cost κ and audit noise μ_S further weaken enforcement by shrinking the regions in which subsidies remain credible. The managerial implication is that subsidy programs should not be designed as uniform grants. They are most effective when pre-incident audits are credible and when firms can be segmented by baseline network risk. When screening becomes too rent-intensive or audits become too costly/noisy, the policymaker should consider instruments that rely less on ex-ante effort verification. This motivates the analysis of insurance contracts, which shift the verification gate from pre-incident compliance to post-incident claims inspection.

6. Business Insurance Contract

In this section, we develop and evaluate the effectiveness of a business insurance contract as an alternative policy instrument for the government. Unlike the subsidy contract, which provides ex-ante support to encourage preventive security investment, the insurance contract provides ex-post compensation following a verified disruption. The policy functions as a relief mechanism, allowing firms to offset recovery costs associated with adverse incidents—such as cyberattacks or supply chain breaches—after they occur.

Let IC indicate the Insurance Contract. Similar to the subsidy contract, the analysis of the regime IC also involves two stages. In the first stage, the government designs a menu of contracts $\Omega_\theta^{\mathrm{IC}} = \{E_\theta, \pi_\theta, \phi_\theta\}_{\theta=h,\ell}$, where $E_\theta \in \{0,1\}$ denotes the required level of security investment for a type-θ firm, π_θ is the *insurance premium* paid upfront by the firm, and ϕ_θ is the *reimbursement amount* paid to the firm if a disruption occurs and a valid indemnity claim is filed. As in the subsidy contract, the payment of the reimbursement is conditional on a government inspection. Specifically, the government reimburses the firm only if her post-incident inspection $\mathcal{A}_I \in \{0,1\}$ verifies that the firm complied with the contracted effort level $e_\theta = E_\theta$. Finally, the inspection is assumed to be costly, incurring a fixed cost κ, and is imperfect: with probability μ_I, the audit yields a false positive, incorrectly concluding that the firm invested when it did not.

6.1. Analysis of Post-Incident Inspection Game

We begin by analyzing the final stage of the insurance contract, namely the post-incident inspection game, under a given insurance contract $\Omega_\theta^{\mathrm{IC}}$. Unlike the subsidy contract, where the audit game is played before the disruption (ex-ante), the inspection game under the insurance regime takes place after the disruption occurs (ex-post), when the firm submits a claim. As a result, the firm decides whether to invest in security compliance before knowing whether a disruption will occur, and thus evaluates its strategy based on expected costs. In contrast, the government chooses whether to inspect after a disruption, and thus conditions its decision on the realization of an incident.

Table 5 presents the strategic form of the inspection game. In each cell, the top expression denotes the firm's expected cost (with expectation taken over the uncertainty of disruption), and the bottom expression denotes the government's realized cost of inspection after a disruption has occurred.

Table 5 **Firm's (Top) and Government's (Bottom) Costs in the Post-Incident Inspection Game when** $E_\theta = 1$

Firm's Effort	**Inspection Decision** $\mathcal{A}_I$	
	$\mathcal{A}_I = 1$	$\mathcal{A}_I = 0$
$e_\theta = 1$	$\pi_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\rho)(L_f - \phi_\theta)\right] + \psi$ $-\pi_\theta + L_n + L_f + L_s + \kappa + \phi_\theta$	$\pi_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\rho)(L_f - \phi_\theta)\right] + \psi$ $-\pi_\theta + L_n + L_f + L_s + \phi_\theta$
$e_\theta = 0$	$\pi_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\varphi)(L_f - \mu_1\phi_\theta)\right]$ $-\pi_\theta + L_n + L_f + L_s + \kappa + \mu_1\phi_\theta$	$\pi_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\varphi)(L_f - \phi_\theta)\right]$ $-\pi_\theta + L_n + L_f + L_s + \phi_\theta$

To characterize all equilibria of the inspection game, we define λ_θ and η_θ to denote the probabilities of the government conducting a post-incident inspection and the type-θ firm investing in security compliance, respectively. By weighting the outcomes in Table 5 by these probabilities, we derive the firm's ex-ante expected cost and the government's ex-post expected cost under contract $\Omega_\theta^{\mathrm{IC}} = \{E_\theta = 1, \pi_\theta, \phi_\theta\}$ as follows:

$$\mathcal{G}_\theta(\lambda_\theta, \eta_\theta \mid E_\theta = 1, \pi_\theta, \phi_\theta) = -\pi_\theta + L_n + L_f + L_s + \phi_\theta + \lambda_\theta\left[\kappa - (1-\eta_\theta)(1-\mu_1)\phi_\theta\right] \tag{6}$$

$$\begin{aligned}\mathcal{F}_\theta(\lambda_\theta, \eta_\theta \mid E_\theta = 1, \pi_\theta, \phi_\theta) = {} & \pi_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\varphi)(L_f - \phi_\theta)\right] + \lambda_\theta \cdot \gamma(1-\bar{s}_\theta)(1-\varphi)(1-\mu_1)\phi_\theta \\ & + \eta_\theta \cdot \left[\psi - \gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f - \phi_\theta) - \lambda_\theta \cdot \gamma(1-\bar{s}_\theta)(1-\varphi)(1-\mu_1)\phi_\theta\right]\end{aligned} \tag{7}$$

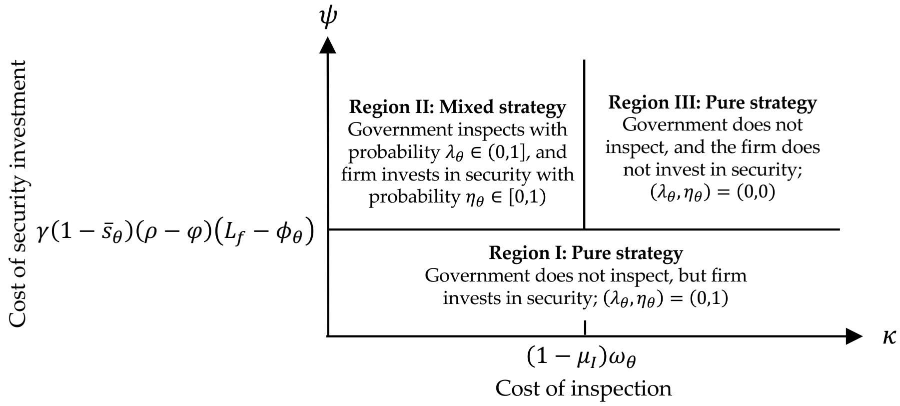
The following proposition 3 characterizes the equilibria of inspection game for all possible insurance contracts:

PROPOSITION 3. *Given the insurance contract $\Omega_\theta^{\mathrm{IC}}$ offered by the government, there exist three regions under which a unique NE arises in the inspection game:*

- *Region I (Full Compliance, No Inspection): There exists a pure strategy NE where $\lambda_\theta = 0$ and $\eta_\theta = 1$ if $\psi \le \gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f - \phi_\theta)$.*
- *Region II (Mixed Strategy): There exists a mixed strategy NE where $\lambda_\theta = \frac{\psi - \gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f-\phi_\theta)}{\gamma(1-\bar{s}_\theta)(1-\varphi)(1-\mu_1)\phi_\theta}$, $\eta_\theta = 1 - \frac{\kappa}{(1-\mu_1)\phi_\theta}$ provided that $\kappa < (1-\mu_1)\phi_\theta$, and $\psi > \gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f - \phi_\theta)$.*
- *Region III (No Compliance, No Inspection): There exists a pure strategy NE where $\lambda_\theta = 0$ and $\eta_\theta = 0$ if $\kappa \ge (1-\mu_1)\phi_\theta$, and $\psi > \gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f - \phi_\theta)$*

Similar to the audit sub-game analyzed under the SC contract (see Fig. 3), the government can influence the firm's return on investment (ROI) in security through the design of the insurance contract (IC). Specifically, the coverage amount ϕ_θ plays a pivotal role in shaping the firm's incentive to comply (see Figure 4). On one hand, because the firm decides whether to invest in security before any disruption occurs—knowing that reimbursement is conditional on compliance verified post-incident—the government can enhance the firm's incentive to invest by increasing ϕ_θ. A higher reimbursement amplifies the benefit of complying, thereby expanding Region II and reducing the set of parameters under which the firm shirks. In effect, this pushes the boundary of Region III (no compliance, no inspection) *to the right*, making noncompliance less prevalent. On the other hand, a larger ϕ_θ also increases the attractiveness of shirking. Due to the imperfection in post-incident inspection—captured by the false positive rate μ_I—a firm may still receive compensation even if it fails to comply. This moral hazard effect weakens deterrence and incentivizes noncompliance, thereby expanding Region III *downward*, especially in settings where inspection is costly or infrequent. As we will show in the next subsection, these competing forces—the incentive effect and the moral hazard distortion—play a critical role in determining the structure of the optimal insurance contract.

Figure 4 The inspection sub-game Nash equilibrium



6.2. The Optimal Insurance Contract

Similar to our approach in §5.2, and based on the equilibrium characterization in Proposition 3, the optimal insurance contract can be derived by formulating an optimization problem subject to individual rationality and incentive compatibility constraints of both types. To avoid repetition, we omit the full derivation of these constraints and refer the reader to the Appendix for details. The government's optimization problem under the insurance regime can be expressed as follows:

$$\mathcal{G}^{\text{IC}} = \min_{\Omega \in \Omega^{\text{IC}}} \check{\mathcal{G}}(\Omega), \tag{$\mathcal{P}^{\text{IC}}$}$$
$$\check{\mathcal{G}}(\Omega) = \zeta \cdot \mathcal{G}_h(\Omega_h \mid \lambda_h, \eta_h) + (1-\zeta) \cdot \mathcal{G}_\ell(\Omega_\ell \mid \lambda_\ell, \eta_\ell)$$
$$\Omega^{\text{IC}} = \{\pi_\theta, \phi_\theta : IR^\theta,\ IC^\theta\text{-}1,\ IC^\theta\text{-}2,\ \forall \theta \in \{h, \ell\}\}$$

where $\check{\mathcal{G}}(\Omega)$ is the government's loss under contract Ω, and Ω^{IC} is the set of all feasible contract terms that respect individual rationality and incentive compatibility constraints.

As with the subsidy contract, the total inefficiency under insurance consists of two main components. The first term captures the expected loss resulting from firm-θ's deviation from the socially optimal investment. Under the social optimum, the government would pay ψ to induce full compliance ($e_\theta^{\text{SO}} = 1$). Under the insurance mechanism, however, the firm invests with probability η_θ, leading to a residual vulnerability gap.

This inefficiency is weighted by the spillover-adjusted loss $\gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f+L_s)$ and scaled by the type probability ζ_θ. The second component is the agency cost, which reflects the expected administrative burden of operating the insurance mechanism. It consists of three parts. First, the premium π_θ is collected upfront by the government. Second, the expected coverage payout ϕ_θ is paid in the event of a successful disruption-occurring with probability $\gamma(1-\bar{s}_\theta)(1-s_\theta(e_\theta))$. Finally, government incurs the expected inspection cost, which includes: (i) An inspection triggered upon disruption, occurring with probability λ_θ and incurring a cost κ; and (ii) A coverage payout when a noncompliant firm raises a claim and the inspection fails to detect shirking, with failure probability $1-\mu_1$. A key determinant of both expected coverage and inspection cost is the firm's effective vulnerability: $1-s_\theta(e_\theta)=\eta_\theta(1-\rho)+(1-\eta_\theta)(1-\varphi)$, which is a convex combination of vulnerability levels conditional on compliance behavior. The following proposition formally characterizes the optimal insurance contract.

PROPOSITION 4. *The optimal insurance contract $\{\pi_\theta,\phi_\theta\}_{\theta=h,\ell}$, the government's inspection decision λ_θ, and the firm's security investment decision η_θ are characterized in Table 6. Furthermore, the total inefficiency incurred under the optimal insurance mechanism is given by:*

$$I^{\mathrm{IC}} = \underbrace{\sum_{\theta\in\{h,\ell\}} \zeta_\theta \cdot e_\theta^{\mathrm{SO}}\left[(1-\eta_\theta)\gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f+L_s)-\psi\right]}_{\substack{\text{Expected loss due to}\\ \text{underinvestment in security}}}$$
$$+\underbrace{\sum_{\theta\in\{h,\ell\}} \zeta_\theta \cdot \left[\underbrace{-\pi_\theta}_{\text{Premium}} + \underbrace{\gamma(1-\bar{s}_\theta)(1-s_\theta(e_\theta))\cdot\phi_\theta}_{\text{Expected coverage}} + \underbrace{\lambda_\theta\cdot(\gamma(1-\bar{s}_\theta)(1-s_\theta(e_\theta))\cdot\kappa-(1-\eta_\theta)\cdot\gamma(1-\bar{s}_\theta)(1-\varphi)(1-\mu_1)\phi_\theta)}_{\text{Expected cost of inspection}}\right]}_{\text{Agency cost}} \tag{8}$$

From Table 6, one can verify that the insurance contract also fails to fully rectify the underinvestment problem. The culprit is again information asymmetry, although it operates differently here than under the subsidy mechanism. Therefore, pooling persists for the same structural reason as in subsidies: simultaneous IC of ℓ-type and IR of h-type cannot be satisfied under joint adverse selection and moral hazard, so the government targets one type and accepts residual rents.

Consider region U_1, where, under the ungoverned outcome, the h-type underinvests while the ℓ-type invests (see Lemma 1). To induce h-type compliance, the government (i.e., insurer) must fully guarantee the direct loss from an attack, i.e., set coverage $\phi_h=L_f$. To preserve h-type incentives to comply, the premium is set equal to the *risk-investment gap* when shirking: $\pi_h=\gamma(1-\bar{s}_h)(1-\varphi)L_f-\psi$. This yields a mixed-strategy equilibrium in the h-type pooling window.

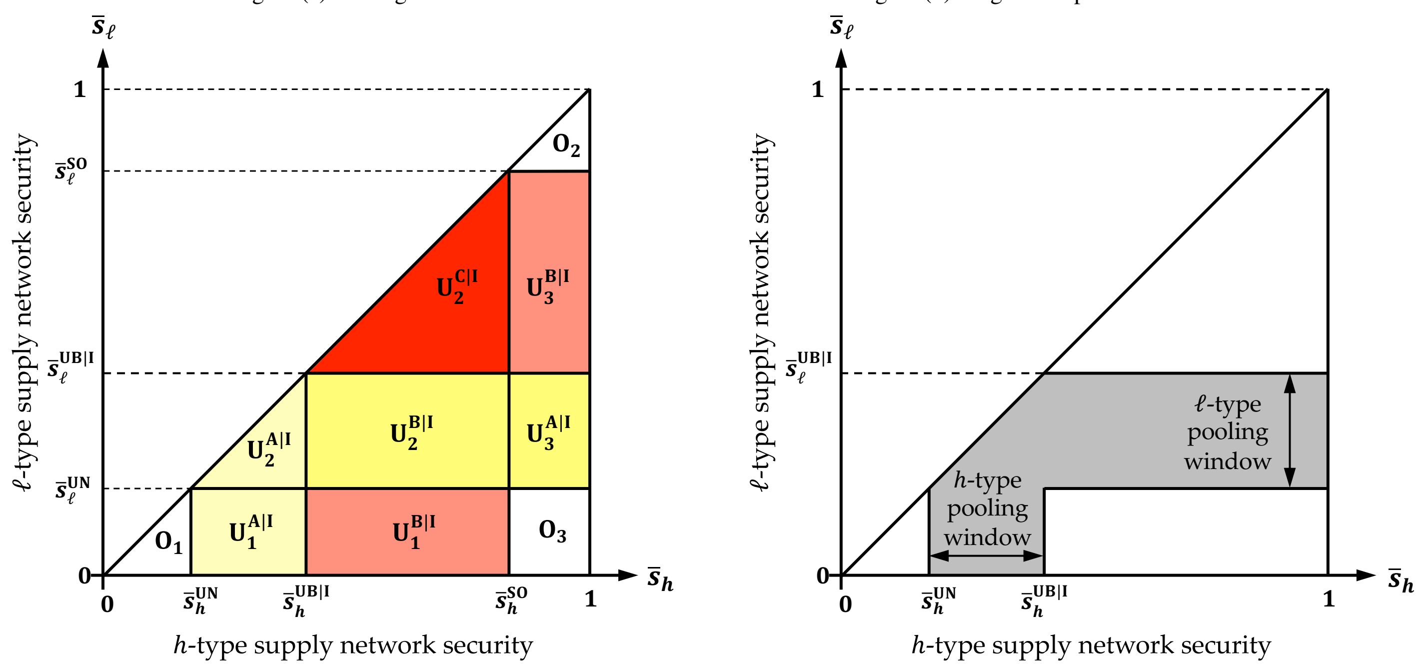
Unlike the subsidy contract–where the ℓ-type can mimic to collect a lump-sum transfer–under insurance the ℓ-type chooses between remaining at the outside option (so the ungoverned outcome prevails) or mimicking the h-type by purchasing insurance at cost π_h in exchange for coverage ϕ_h if attacked. Depending on the

Table 6 Contract terms and equilibrium decisions under $\mathcal{P}^{\mathrm{IC}}$ contract

Region	Optimal Contract	Inspection Level	Security Investment	Information Rent	Socially Optimal
$U_1^{B\|I}$	No contract	$\lambda_h=0,\ \lambda_\ell=0$	$\eta_h=0, \eta_\ell=1$	–	$e_h^{\mathrm{so}}=1,\ e_\ell^{\mathrm{so}}=1$
$U_1^{A\|I}$	$\pi_h=\pi_\ell=\gamma(1-\bar{s}_h)(1-\varphi)L_f-\psi$ $\phi_h=\phi_\ell=L_f$	$\lambda_h=\frac{\psi}{\gamma(1-\bar{s}_h)(1-\varphi)(1-\mu_{\mathrm{I}})L_f}$ $\lambda_\ell=\frac{\psi}{\gamma(1-\bar{s}_h)(1-\varphi)(1-\mu_{\mathrm{I}})L_f}$	$\eta_h=1-\frac{\kappa}{(1-\mu_{\mathrm{I}})L_f}$ $\eta_\ell=1$	$\mathrm{IR}_\ell=\psi-\gamma\Big((1-\bar{s}_h)(1-\varphi)-(1-\bar{s}_\ell)(1-\rho)\Big)L_f$	$e_h^{\mathrm{so}}=1,\ e_\ell^{\mathrm{so}}=1$
$U_2^{A\|I}$				$\mathrm{IR}_\ell=\gamma(\bar{s}_h-\bar{s}_\ell)(1-\varphi)L_f$	
$U_2^{C\|I}$	No contract	$\lambda_h=0,\ \lambda_\ell=0$	$\eta_h=0,\ \eta_\ell=0$	–	$e_h^{\mathrm{so}}=1,\ e_\ell^{\mathrm{so}}=1$
$U_3^{A\|I}$	$\pi_h=\pi_\ell=\gamma(1-\bar{s}_\ell)(1-\varphi)L_f-\psi$	$\lambda_h=0$	$\eta_h=0,$	–	$e_h^{\mathrm{so}}=0,\ e_\ell^{\mathrm{so}}=1$
$U_2^{B\|I}$	$\phi_h=\phi_\ell=L_f$	$\lambda_\ell=\frac{\psi}{\gamma(1-\bar{s}_\ell)(1-\varphi)(1-\mu_{\mathrm{I}})L_f}$	$\eta_\ell=1-\frac{\kappa}{(1-\mu_{\mathrm{I}})L_f}$		$e_h^{\mathrm{so}}=1,\ e_\ell^{\mathrm{so}}=1$
$U_3^{B\|I}$	No contract	$\lambda_h=0,\ \lambda_\ell=0$	$\eta_h=0,\ \eta_\ell=0$	–	$e_h^{\mathrm{so}}=0,\ e_\ell^{\mathrm{so}}=1$

Figure (a): All regions

Figure (b): Regions of partial underinvestment



Notes: $\bar{s}_\ell^{\mathrm{UB}}=\bar{s}_h^{\mathrm{UB}}=1-\frac{\psi}{\gamma(1-\varphi)L_f}$.

ℓ-type's ungoverned decision–$e_\ell^{\text{UN}} = 1$ in region U_1 and $e_\ell^{\text{UN}} = 0$ in region U_2–the information rent collected by the ℓ-type is

$$\text{IR}_\ell^{\text{IC}} = \quad -\underbrace{\pi_h}_{\substack{\text{Payable}\\\text{premium}}} \quad + \quad \underbrace{\gamma(1-\bar{s}_\ell)(1-s_\ell(e_\ell^{\text{UN}}))\phi_h}_{\substack{\ell\text{-type expected coverage}\\\text{under } h\text{-type contract}}} \quad - \quad \underbrace{(\eta_\ell - e_\ell^{\text{UN}})\psi}_{\substack{\text{Compliance cost}\\\text{deviation}}}. \tag{9}$$

Expression (9) captures the ℓ-type's mimicking behavior in the h-type pooling window: region $U_1^{A|I}$, where there is no compliance-cost deviation relative to the ungoverned solution ($\eta_\ell = e_\ell^{\text{UN}} = 1$), and region $U_2^{A|I}$, where the ℓ-type complies under the deviated insurance contract ($\eta_\ell = 1$) but would not comply under the ungoverned outcome ($e_\ell^{\text{UN}} = 0$). In the former, information rent equals expected coverage minus premium; in the latter, the incremental rent reflects the additional expected coverage upon attack, scaled by the network security differential $\bar{s}_h - \bar{s}_\ell$.

If the government does not wish to induce h-type compliance, it can instead target the ℓ-type (the ℓ-type pooling window, region U_3). Mimicking is unprofitable for the h-type—he would incur the compliance cost ψ without offsetting benefit—so no information rent arises. Although formally pooled, the contract is effectively targeted to the ℓ-type, with the premium calibrated to avoid over-coverage and unnecessary rents. Finally, the mixed equilibria in the h-type pooling window (region U_1) and the ℓ-type pooling window (region U_3) provide the only second-best instruments to partially address underinvestment in region U_2 (where both types comply under the social optimum). The rent-efficiency trade-off expands these windows into $U_2^{A|I}$ and $U_2^{B|I}$, respectively.

7. Ex-Ante Audits or Ex-Post Inspections? A Comparison of Subsidy and Insurance

Sections 5 and 6 characterized the optimal subsidy and insurance contracts, respectively. Each mechanism creates two pooling windows–an h-type window and an ℓ-type window–that partially correct underinvestment by the firm compared to the socially optimal solution. In this section, we aim to address two questions: which mechanism spans the wider window for a given type, and, where windows overlap, which mechanism induces a higher security investment (compliance probability η_θ). The first question speaks to complementarity across regions; can insurance help where subsidy fails, and vice versa? The second question indicates which instrument to implement when both are feasible.

Subsidy is a mitigation instrument: it ties incentives to pre-incident audits and aims to internalize the externality ex ante. In our pooling designs, the subsidy and penalty scale with the investment-benefit gap; $\Delta_\theta \equiv \psi - \gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$, which is the shortfall in the private benefit from compliance. Note $\partial\Delta_\theta/\partial\bar{s}_\theta > 0$: as the type-$\theta$ firm's supply network becomes more secure (larger $\bar{s}_\theta$), the firm's private incident risk falls and a larger inducement is required. That larger Δ_θ has two effects: (i) it increases audit leverage–because penalties ω_θ scale with Δ_θ, boosting η_θ for given κ and μ_s–and (ii) it raises information rents under pooling.

When audits are accurate and not too costly, the leverage effect dominates, which is why the subsidy windows expand in the upper-right portions (high network security, $\bar{s}_\theta \approx \bar{s}_\theta^{\mathrm{SO}}$) of the left-hand panel of Table 4.

By contrast, insurance is a contingency instrument: it ties incentives to post-incident inspections and enforces effort through claim–contingent verification. Its bite depends on the shirking incident probability, $p_\theta^0 = \gamma(1-\bar{s}_\theta)(1-\varphi)$. As $\bar{s}_\theta$ rises, p_θ^0 falls, reducing both the frequency and the deterrence value of inspections–even when inspections are accurate and premiums are risk-priced. This is why the insurance pooling windows in the left-hand panel of Table 6 are typically wider in neighborhoods closer to $\bar{s}_\theta^{\mathrm{UN}}$ and contract as one moves toward $\bar{s}_\theta^{\mathrm{SO}}$.

Comparing Tables 4 and 6 makes the *regional complementarity* of the two mechanisms explicit. Where subsidy fails–e.g., $U_1^{A|S}, U_2^{A|S}$ and $U_2^{C|S}, U_3^{A|S}$–the corresponding insurance regions $U_1^{A|I}, U_2^{A|I}$ and $U_2^{B|I}, U_3^{A|I}$ induce (partial) compliance: weak surrounding networks make pre-incident screening rent-intensive, but post-incident inspection remains enforceable because p_θ^0 is sizable. Conversely, near $\bar{s}_\theta^{\mathrm{SO}}$ the subsidy windows expand while insurance feasibility tightens: prevention can be induced with lighter audits despite a larger Δ_θ, and the subsidy better internalizes the spillover L_s before incidents occur. In short, closer to $\bar{s}_\theta^{UN}$ the insurance windows tend to be wider, whereas closer to $\bar{s}_\theta^{\mathrm{SO}}$ the subsidy windows dominate—so the contracts are complements across regions of $(\bar{s}_h, \bar{s}_\ell)$.

In parts of the $(\bar{s}_h, \bar{s}_\ell)$ space where the subsidy and insurance pooling windows both apply, the choice of instrument should be guided by which one delivers *more prevention per unit of agency cost*. Formally, for a firm of type $\theta \in \{h, \ell\}$, define the incremental Prevention Benefit (PB)–i.e., the expected reduction in social loss relative to the ungoverned outcome. In parts of the $(\bar{s}_h, \bar{s}_\ell)$ space where the subsidy and insurance pooling windows both apply, the choice of instrument should be guided by which one delivers *more prevention per unit of agency cost*. Formally, for a firm of type $\theta \in \{h, \ell\}$, define the incremental Prevention Benefit (PB)–i.e., the expected reduction in social loss relative to the ungoverned outcome–as

$$\mathrm{PB}_\theta^i = \gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f + L_s)\,(\eta_\theta^i - e_\theta^{\mathrm{UN}})^+, \qquad i \in \{\mathrm{SC}, \mathrm{IC}\},$$

where $\gamma(1-\bar{s}_\theta)(\rho-\varphi)$ is the network-scaled drop in incident probability when moving from shirking to compliance, $L_f + L_s$ internalizes the network externality, and $(\eta_\theta - e_\theta^{\mathrm{UN}})^+$ is the induced increase in compliance probability compared to the outside option (i.e., ungoverned solution). Moreover, for the subsidy the Agency Cost, consistent with Eq. (5), is

$$\mathrm{AC}_\theta^{\mathrm{SC}} = \underbrace{\tau_\theta}_{\text{Subsidy}} + \underbrace{\lambda_\theta\,(\kappa - (1-\eta_\theta)(1-\mu_{\mathrm{S}})\omega_\theta)}_{\text{Expected cost of audit}}, \tag{10}$$

and for insurance contract, consistent with Eq. (8), the Agency Cost is

$$\mathrm{AC}_\theta^{\mathrm{IC}} = \underbrace{-\pi_\theta}_{\text{Premium}} + \underbrace{\gamma(1-\bar{s}_\theta)(1-s_\theta(e_\theta))\cdot\phi_\theta}_{\text{Expected coverage}} + \underbrace{\lambda_\theta\cdot(\gamma(1-\bar{s}_\theta)(1-s_\theta(e_\theta))\cdot\kappa - (1-\eta_\theta)\cdot\gamma(1-\bar{s}_\theta)(1-\varphi)(1-\mu_{\mathrm{I}})\phi_\theta)}_{\text{Expected cost of inspection}} \tag{11}$$

We define *efficiency index* as prevention per unit of agency cost:

$$\mathcal{E}_\theta^i = \frac{\mathrm{PB}_\theta^i}{\mathrm{AC}_\theta^i}, \qquad i \in \{\mathrm{SC}, \mathrm{IC}\}, \tag{12}$$

which provides a direct, parameterized comparison: choose the instrument with the larger $\mathcal{E}$ at the overlap point. The following proposition formalizes the comparison:

PROPOSITION 5. *There exists a threshold $\bar{\bar{s}}_\theta$ such that:*

- *For all $\bar{s}_\theta \geq \bar{\bar{s}}_\theta$, subsidy mechanism efficiency dominates the insurance mechanism efficiency; $\mathcal{E}_\theta^{\mathrm{SC}} \geq \mathcal{E}_\theta^{\mathrm{IC}}$,*
- *For all $\bar{s}_\theta \leq \bar{\bar{s}}_\theta$, insurance mechanism efficiency dominates the subsidy mechanism efficiency $\mathcal{E}_\theta^{\mathrm{IC}} \geq \mathcal{E}_\theta^{\mathrm{SC}}$.*

Interpreted through the model's primitives, Proposition 5 shows that $\mathcal{E}^{\mathrm{SC}}$ tends to dominate at moderate to high network security (larger $\bar{s}_\theta$). In those neighborhoods, the subsidy investment-benefit gap Δ_θ is larger, which the audit-penalty lever transforms into stronger ex-ante inducement (higher η_θ) provided audit costs κ are not excessive and audit accuracy μ_{s} is reasonably high. At the same time, the contingency lever of insurance weakens because the shirking incident probability $p_\theta^0 = \gamma(1-\bar{s}_\theta)(1-\varphi)$ falls as $\bar{s}_\theta$ rises, reducing the deterrence value of post-incident inspections even with well-priced premiums. Conversely, nearer to the ungoverned frontier (smaller $\bar{s}_\theta$), p_θ^0 is sizable; incidents occur often enough that inspections are triggered with meaningful probability, and risk-priced premiums provide credible discipline against mimicking. In those regions, $\mathcal{E}^{\mathrm{IC}}$ typically exceeds $\mathcal{E}^{\mathrm{SC}}$, since ex-ante screening via subsidy becomes rent-intensive while the insurance inspection threat remains effective.

7.1. Equal-Error Comparison: Asymmetric Impact of Verification Noise

In this section, we isolate the impact of timing of incentives from verification accuracy. We therefore set the pre-incident audit error and the post-incident inspection error to be equal, i.e., $\mu_{\mathrm{s}} = \mu_{\mathrm{I}} = \mu \in [0,1)$. In the mixed pooling window–corresponding to Region II where the government randomizes verifications (audit under subsidy and inspection under insurance) and the firm mixes on effort–the equilibrium compliance probabilities are $\eta_\theta^{\mathrm{SC}} = 1 - \frac{\kappa}{(1-\mu)\omega_\theta}$ (where $\omega_\theta = \psi - \gamma\big(1-\bar{s}_\theta\big)(\rho-\varphi)L_f$) and $\eta_\theta^{\mathrm{IC}} = 1 - \frac{\kappa}{(1-\mu)\,\phi_\theta}$ (where $\phi_\theta = L_f$), with interiority conditions $\kappa < (1-\mu)\omega_\theta$ (under subsidy in Proposition 1) and $\kappa < (1-\mu)\phi$ (under insurance in Proposition 3). The main takeaways are as follows. *First*, subsidy is type-sensitive because its deterrence lever ω_θ depends on baseline network security $\bar{s}_\theta$. By differentiating compliance probabilities with respect to $\bar{s}_\theta$, we have $\frac{\partial \eta_\theta^{\mathrm{SC}}}{\partial \bar{s}_\theta} = \frac{\kappa\,\gamma(\rho-\varphi)\,L_f}{(1-\mu)\,\omega_\theta^2} > 0$ and $\frac{\partial \eta_\theta^{\mathrm{IC}}}{\partial \bar{s}_\theta} = 0$. Thus for $\bar{s}_h > \bar{s}_\ell$ we obtain $\eta_h^{\mathrm{SC}} > \eta_\ell^{\mathrm{SC}}$ but $\eta_h^{\mathrm{IC}} = \eta_\ell^{\mathrm{IC}}$. This means insurance *standardizes* compliance across types (claim-triggered lever capped at L_f), whereas subsidy *customizes* deterrence via the investment-benefit gap ω_θ. *Second*, raising μ reduces compliance in both mechanisms, but not equally. We have $\frac{\partial \eta_\theta^{\mathrm{SC}}}{\partial \mu} = -\frac{\kappa}{(1-\mu)^2\omega_\theta} < 0$ and $\frac{\partial \eta_\theta^{\mathrm{IC}}}{\partial \mu} = -\frac{\kappa}{(1-\mu)^2\,L_f} < 0$. The noise-sensitivity ratio is

$$\frac{\big|\partial \eta_\theta^{\mathrm{SC}}/\partial \mu\big|}{\big|\partial \eta_\theta^{\mathrm{IC}}/\partial \mu\big|} = \frac{\phi}{\omega_\theta}.$$

When the investment-benefit gap is large (high ψ and/or higher $\bar{s}_\theta$ raising ω_θ), subsidy is less fragile to noise than insurance. When the gap is small (unsafe networks or low ψ), insurance can be less fragile than subsidy because its lever L_f is comparatively stronger. *Third*, one can verify which contract delivers higher compliance in the pooling windows. From compliance probabilities, we have:

$$\eta_\theta^{\mathrm{SC}} \geq \eta_\theta^{\mathrm{IC}} \iff \omega_\theta \geq \phi \iff \psi \geq L_f\Big[1+\gamma(1-\bar{s}_\theta)(\rho-\varphi)\Big].$$

This threshold is easier to meet for higher-security types (larger $\bar{s}_\theta$ increases ω_θ) and when investment cost ψ is large–favoring subsidy. Conversely, for low-security types (small $\bar{s}_\theta$) and frequent incidents, insurance often dominates because its enforcement is triggered more often by claims. In sum, equal error rates do not equalize the regimes. With the verification gate ex-ante, subsidy retains a type-sensitive, scalable deterrence lever (ω_θ) that can partially offset noise; with the gate ex-post, insurance's lever is capped (ϕ) and claim-triggered, so deterrence fades as incidents become rarer. This asymmetry underlies the regional complementarity in our maps and motivates hybrids that splice an ex-ante effort gate with an ex-post coverage gate when checks are noisy or costly.

8. The Value of a Hybrid Mechanism

In Sections 5 and 6, we characterized the optimal subsidy and insurance contracts, respectively. Our analysis showed that neither mechanism fully eliminates the underinvestment (noncompliance) problem; at best, each can partially mitigate it. One natural concern is whether this limitation stems from the *insufficient strength of incentives* provided by a single contract. To test this possibility, we now consider whether combining an ex-ante subsidy with an ex-post insurance payout–what we term a *hybrid contract*–can induce strictly higher compliance than either a pure subsidy or a pure insurance scheme on its own.

Formally, let τ_θ denote the up-front subsidy payment (as in the subsidy contract) and ϕ_θ the insurance coverage level (as in the insurance contract). Under a pure subsidy, the government commits to pay τ_θ ex ante, after which the firm decides whether to invest. Under a pure insurance scheme, the government pays nothing up front but reimburses the firm up to coverage ϕ_θ in the event of a successful attack. The hybrid approach layers these two instruments and embeds them within an *audit protocol*. In what follows, we consider two distinct variants.

8.1. Hybrid Mechanism with Delayed Inspection

Under this contract the government pays the subsidy τ_θ up front and inspects ex post only if an attack occurs; insurance coverage ϕ_θ is paid upon a realized loss only if the firm is found compliant. Let $\mu_{\mathrm{I}} \in [0,1]$ denote the probability that an ex-post inspection fails to detect noncompliance (as in the insurance section). As in the pure mechanisms, we first solve the inspection sub-game (inspection decision contingent on a realized incident), which yields three distinct regions, and then optimize $(\tau_\theta, \phi_\theta)$ in each region. To avoid repetition, we relegate derivations to the Appendix and present the optimal compliance levels and comparisons below.

PROPOSITION 6. *The optimal delayed-inspection hybrid contract results in the following compliance probabilities:*

– *In the h-type pooling window, we have* $\eta_\ell^{DH} = 1$ *and* $\eta_h^{DH} = 1 - \sqrt{\frac{\kappa(1-\rho)}{\gamma(1-\bar{s}_h)(1-\varphi)(\rho-\varphi)(1-\mu_I)(L_f+L_s)}}$,

– *In the* ℓ*-type pooling window, we have* $\eta_h^{DH} = 0$ *and* $\eta_\ell^{DH} = 1 - \frac{\kappa(1-\rho)}{(1-\varphi)(1-\mu_I)\left[\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f\right]}$.

Moreover, Table 7 summarizes the parameter conditions under which the delayed-inspection hybrid strictly induces higher compliance than either the pure subsidy or the pure insurance mechanism.

In the h-type pooling window, the hybrid mechanism strictly outperforms both pure instruments when the audit cost κ is sufficiently large. This is because hybrid contracts better balance audit cost against compliance leverage: by deferring inspection to post-incident, the mechanism economizes on audit spending while retaining enforcement bite through the insurance lever. When subsidy alone becomes too audit-costly and insurance alone lacks sufficient ex-ante bite, the hybrid design delivers higher compliance. This can be also observed by comparing the compliance levels. For the h-type pooling window, the hybrid delivers square-root sensitivity in the audit cost κ. In contrast, under pure subsidy, $\eta_h^{\text{SC}} = 1-\kappa/((1-\mu_{\text{S}})\Delta_h)$, and under pure insurance, $\eta_h^{\text{IC}} = 1-\kappa/((1-\mu_{\text{I}})L_f)$, the compliance levels are both linear in κ. Consequently, when κ is sufficiently high, the hybrid's $\sqrt{\kappa}$ decay dominates the linear decay of η_h^{SC} and η_h^{IC}. In the ℓ-type pooling window, the hybrid contract yields $\eta_\ell^{\text{DH}} = 1-\frac{\kappa}{(1-\mu_{\text{I}})}\cdot\frac{(1-\rho)}{(1-\varphi)\Delta_\ell}$ where $\Delta_\ell \equiv \psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f$. Since $\rho > \varphi$ implies $\frac{1-\rho}{1-\varphi} < 1$, the hybrid always improves on the pure subsidy compliance $\eta_\ell^{\text{SC}} = 1-\frac{\kappa}{(1-\mu_{\text{S}})\Delta_\ell}$ for comparable inspection quality, and strictly improves whenever $(1-\mu_{\text{I}})$ is not worse than $(1-\mu_{\text{S}})$. Relative to pure insurance, the hybrid dominates when the investment-benefit gap Δ_ℓ is sufficiently large: the up-front subsidy raises the stake of compliance, while the ex-post gating of coverage eliminates payouts to shirkers with probability μ_{I}, allowing higher η_ℓ^{DH} at a given κ.

8.2. Hybrid Mechanism with Early Audit

In this section, we examine a variant of the hybrid mechanism in which the government audits compliance immediately after the firm's effort decision and before any disruption occurs. Under this early-audit hybrid contract, the firm first chooses whether to invest in security. The government then decides on conducting an audit: if the audit verifies that the firm invested, the subsidy τ_θ is paid and coverage ϕ_θ is activated; otherwise, no subsidy or insurance is offered. The following proposition presents the optimal compliance levels and comparisons.

Table 7 When the Delayed-Inspection Hybrid Contract Beats Pure Subsidy and Pure Insurance

Firm's type	Hybrid outperforms subsidy	Hybrid outperforms insurance
$\theta = h$	$\kappa \geq \dfrac{(1-\rho)(1-\mu_I)\left[\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f\right]^2}{\gamma(1-\bar{s}_h)(1-\varphi)(\rho-\varphi)(L_f+L_s)}$	$\kappa \geq \dfrac{(1-\rho)(1-\mu_I)L_f^2}{\gamma(1-\bar{s}_h)(1-\varphi)(\rho-\varphi)(L_f+L_s)}$
$\theta = \ell$	$\rho \geq \varphi$	$\psi \geq \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f + \dfrac{1-\rho}{1-\varphi}L_f$

PROPOSITION 7. *The optimal delayed-inspection hybrid contract results in the following compliance probabilities:*

– *In the h-type pooling window, we have* $\eta_\ell^{EH} = 1$ *and* $\eta_h^{EH} = 1 - \sqrt{\frac{\kappa}{\gamma(1-\bar{s}_h)(\rho-\varphi)(1-\mu_S)(L_f+L_s)}}$,

– *In the* ℓ*-type pooling window, we have* $\eta_h^{EH} = 0$ *and* $\eta_\ell^{EH} = 1 - \frac{\kappa}{(1-\mu_S)\left[\psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f\right]}$.

Moreover, Table 8 summarizes the parameter conditions under which the early-audit hybrid strictly induces higher compliance than either the pure subsidy or the pure insurance mechanism.

Table 8 When the Early-Audit Hybrid Contract Beats Subsidy and Insurance

Firm's type	Hybrid outperforms subsidy	Hybrid outperforms insurance
$\theta = h$	$\kappa \geq \frac{(1-\mu)\left[\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f\right]^2}{\gamma(1-\bar{s}_h)(\rho-\varphi)(L_f+L_s)}$	$\kappa \geq \frac{(1-\mu)L_f^2}{\gamma(1-\bar{s}_h)(\rho-\varphi)(L_f+L_s)}$
$\theta = \ell$	$\rho \geq \varphi$	$\psi \geq \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f + \frac{1-\rho}{1-\varphi}L_f$

The formulas for η^{EH} mirror those for the delayed-audit hybrid η^{DH}: in the h-type pooling window, both exhibit the square-root dependence on κ, whereas under pure subsidy η_h^{SC} falls linearly with κ. Consequently, as audits/inspections become costly, hybrid compliance declines more slowly than under pure subsidy. In the ℓ-type pooling window, the early and delayed hybrids both strengthen the deterrence faced by shirkers relative to subsidy-only (a shirker faces higher residual vulnerability $(1-\varphi)$ and, crucially, can be denied coverage), which guarantees hybrid dominates subsidy. Relative to pure insurance, the hybrid's ex-ante gate (the subsidy tied to verified effort) amplifies incentives when the investment-benefit gap $\Delta_\ell = \psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f$ is large.

To summarize, both hybrid variants splice the two levers: an ex-ante transfer that raises the private return to effort (as in subsidy), and an ex-post gate that withholds coverage from shirkers when verification succeeds (as in insurance). This combination produces the square-root compliance response in κ and delivers the dominance regions summarized in Tables 7 and 8: in the h-type window, hybrids can outperform both pure mechanisms when κ is sufficiently high; in the ℓ-type window, hybrids always dominate subsidy and often beat insurance when Δ_ℓ is large.

9. Conclusion

Supply chains today face a dual exposure: physical shocks (from pandemics, conflict, and extreme weather) and cyber intrusions that exploit digital interdependence. Governments increasingly treat supply chain security as both an economic and national-security priority, yet most assets are privately owned and firms underinvest because they do not capture the full spillover benefits of their security and because effort and baseline conditions are hard to observe.

We study three instruments that reflect how governments actually govern risk: a subsidy tied to pre-incident audits (mitigation), an insurance contract tied to post-incident inspections (contingency), and hybrids that splice the two. With noisy, costly checks and asymmetric information, both the subsidy and insurance mechanisms admit only pooling equilibria. Depending on baseline network security, the system falls into a high-type pooling window (calibrated to induce the high-security firms) or a low-type pooling window (calibrated to induce the low-security firms); full separation is infeasible once adverse selection and moral hazard interact.

Two primitives drive the comparison between subsidy and insurance: the cost and accuracy of compliance checks, and baseline network security. When network security is low and incidents remain likely if firms shirk, insurance dominates: post-incident inspections occur often enough to make denied coverage credible, and risk-priced premiums help screen mimicking. When network security is moderate to high and incidents are infrequent, subsidies dominate: light but credible pre-incident audits can raise effort while internalizing spillovers before attacks occur. Monitoring costs push in predictable directions: expensive or noisy pre-incident audits weaken subsidies; expensive or noisy post-incident inspections weaken insurance. In regions where both are feasible, the choice should be made by "prevention per unit of agency cost": pick the mechanism that delivers the larger reduction in expected losses for each dollar of transfers and enforcement. The upshot is regional *complementarity*–where one instrument struggles, the other tends to cover the gap.

Hybrid designs matter because they combine mitigation and contingency without stacking two full programs on the same firm. We analyze two variants. In the delayed-audit hybrid (pay subsidy up front; condition coverage on a later inspection), and the early-audit hybrid (verify first; activate both subsidy and coverage only upon verification), compliance is more resilient to rising monitoring costs than under a pure subsidy, producing a square-root-style decline rather than a linear drop. In the high-type pooling window, hybrids can outperform both pure instruments when audits or inspections are sufficiently costly: they preserve deterrence while economizing on checks. In the low-type pooling window, hybrids always outperform subsidies (because shirkers face higher residual risk and can be denied coverage) and can outperform insurance when the firm's investment-benefit gap is large; the up-front transfer helps close that gap while the coverage gate keeps incentives sharp.

Figure 5 illustrates the optimal contractual strategy as a function of inspection/audit cost and baseline supply network security. The figure provides a practical roadmap: deploy mitigation, contingency, or hybrid instruments as region-specific tools–chosen according to the cost of verification and the inherent security of the surrounding network–to achieve the greatest prevention for each dollar spent. Policy guidance follows. First, invest in the accuracy of audits and inspections; precision can matter more than the size of transfers. Second, segment by baseline network security: deploy insurance in low-security segments where incidents under shirking are common, and subsidies in moderate-to-high-security segments where ex-ante verification

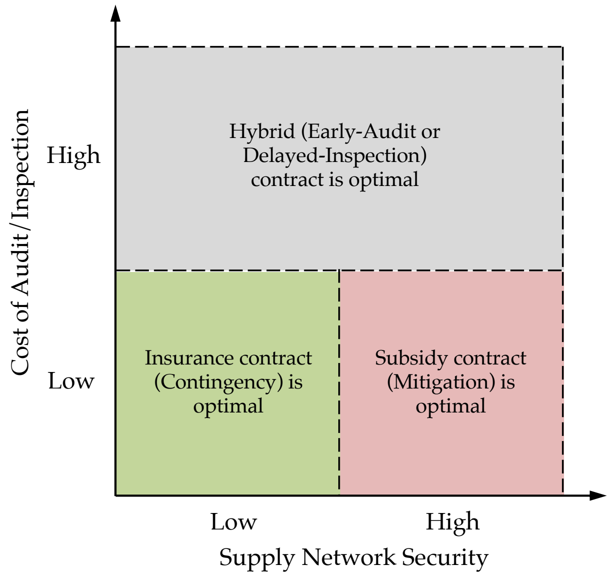


Figure 5 Optimal Contractual Strategy

is credible and spillovers are material. Third, use hybrids when monitoring is expensive or when firms face large investment gaps; hybrids reduce rents and sustain deterrence.

References

Akkaya D, Bimpikis K, Lee H (2021) Government interventions to promote agricultural innovation. *Manufacturing & Service Operations Management* 23(2):437–452.

Alizamir S, de Véricourt F, Sun P (2016) Efficient feed-in-tariff policies for renewable energy technologies. *Operations Research* 64(1):52–66.

Alizamir S, Iravani F, Mamani H (2019) An analysis of price vs. revenue protection: Government subsidies in the agriculture industry. *Management Science* 65(1):32–49.

August T, Tunca TI (2006) Network software security and user incentives. *Management Science* 52(11):1703–1720.

August T, Tunca TI (2008) Let the pirates patch? an economic analysis of software security patch restrictions. *Information Systems Research* 19(1):48–70.

August T, Tunca TI (2011) Who should be responsible for software security? a comparative analysis of liability policies in network environments. *Management Science* 57(5):934–959.

Babich V, Tang CS (2012) Managing opportunistic supplier product adulteration: Deferred payments, inspection, and combined mechanisms. *Manufacturing & Service Operations Management* 14(2):301–314.

Bagchi A, Paul JA (2017) Espionage and the optimal standard of the customs-trade partnership against terrorism (c-tpat) program in maritime security. *European journal of operational research* 262(1):89–107.

Bakshi N, Flynn SE, Gans N (2011) Estimating the operational impact of container inspections at international ports. *Management Science* 57(1):1–20.

Bakshi N, Gans N (2010) Securing the containerized supply chain: Analysis of government incentives for private investment. *Management Science* 56(2):219–233.

Baron O, Berman O, Gavious A (2018) A game between a terrorist and a passive defender. *Production and Operations Management* 27(3):433–457.

Cavusoglu H, Cavusoglu H, Raghunathan S (2007) Efficiency of vulnerability disclosure mechanisms to disseminate vulnerability knowledge. *IEEE Transactions on Software Engineering* 33(3):171–185.

Cavusoglu H, Cavusoglu H, Zhang J (2008) Security patch management: Share the burden or share the damage? *Management Science* 54(4):657–670.

Chen J, Wei H, Xie L (2022) Mitigating product quality risk under external financial pressure: Inspection, insurance, and cash/collateralized loan. *Production and Operations Management* 31(1):304–317.

Chen J, Wei H, Xie L, Zheng C (2023) Express: Managing quality risk in a decentralized supply chain: Contractual incentives and product recall insurance. *Production and Operations Management* 10591478251365310.

Cheung KF, Bell MG (2021) Improving connectivity of compromised digital networks via algebraic connectivity maximisation. *European Journal of Operational Research* 294(1):353–364.

Choi TM, Kumar S, Yue X, Chan HL (2022) Disruptive technologies and operations management in the industry 4.0 era and beyond. *Production and Operations Management* 31(1):9–31.

City-News-Service (2023) Nearly $400,000 worth of counterfeit apple products seized from seaport, ontario airport. Technical report, NBC Los Angeles.

Cohen MC, Lobel R, Perakis G (2016) The impact of demand uncertainty on consumer subsidies for green technology adoption. *Management Science* 62(5):1235–1258.

Dong L, Tomlin B (2012) Managing disruption risk: The interplay between operations and insurance. *Management Science* 58(10):1898–1915.

Golany B, Kaplan EH, Marmur A, Rothblum UG (2009) Nature plays with dice–terrorists do not: Allocating resources to counter strategic versus probabilistic risks. *European Journal of Operational Research* 192(1):198–208.

Gupta S, Dawande M, Janakiraman G, Sarkar A (2017) Distressed selling by farmers: Model, analysis, and use in policy-making. *Production and Operations Management* 26(10):1803–1818.

Jenkins DJ, Mahdavi Pajouh F, Kirshen PH, Eftekhar M (2024) Which is more rewarding in managing sea-level rise and hurricane storm surge flooding: Mitigation or response? *Production and Operations Management* 33(1):364–382.

Jones C (2021) Warnings (& lessons) of the 2013 target data breach. Technical report, Red River, URL `https://redriver.com/security/target-data-breach`.

Kannan K, Telang R (2005) Market for software vulnerabilities? think again. *Management science* 51(5):726–740.

Kumar S, Mallipeddi RR (2022) Impact of cybersecurity on operations and supply chain management: Emerging trends and future research directions. *Production and Operations Management* 31(12):4488–4500.

Kumar S, Mookerjee V, Shubham A (2018) Research in operations management and information systems interface. *Production and Operations Management* 27(11):1893–1905.

Laffont JJ, Martimort D (2009) The theory of incentives: the principal-agent model. *The theory of incentives* (Princeton university press).

Lakdawalla D, Zanjani G (2005) Insurance, self-protection, and the economics of terrorism. *Journal of Public Economics* 89(9-10):1891–1905.

Li Y, Li G, Pan XA (2023) Optimal return shipping insurance policy with consumers' anticipated regret. *Production and Operations Management* 32(10):3209–3226.

Luo S, Choi TM (2022) E-commerce supply chains with considerations of cyber-security: Should governments play a role? *Production and Operations Management* 31(5):2107–2126.

Mukhopadhyay A, Chatterjee S, Saha D, Mahanti A, Sadhukhan SK (2013) Cyber-risk decision models: To insure it or not? *Decision Support Systems* 56:11–26.

Myerson RB (1982) Optimal coordination mechanisms in generalized principal-agent problems. *Journal of mathematical economics* 10(1):67–81.

Nagurney A, Nagurney LS (2015) A game theory model of cybersecurity investments with information asymmetry. *NETNOMICS: Economic Research and Electronic Networking* 16:127–148.

Nagurney A, Nagurney LS, Shukla S (2015) A supply chain game theory framework for cybersecurity investments under network vulnerability. *Computation, cryptography, and network security*, 381–398 (Springer).

Nagurney A, Shukla S (2017) Multifirm models of cybersecurity investment competition vs. cooperation and network vulnerability. *European Journal of Operational Research* 260(2):588–600.

Nikoofal ME, Gümüş M (2020) Value of audit for supply chains with hidden action and information. *European Journal of Operational Research* 285(3):902–915.

Nikoofal ME, Pourakbar M, Gumus M (2023) Securing containerized supply chain through public and private partnership. *Production and Operations Management* 32(7):2341–2361.

Öğüt H, Raghunathan S, Menon N (2011) Cyber security risk management: Public policy implications of correlated risk, imperfect ability to prove loss, and observability of self-protection. *Risk Analysis: An International Journal* 31(3):497–512.

Olsen TL, Tomlin B (2020) Industry 4.0: Opportunities and challenges for operations management. *Manufacturing & Service Operations Management* 22(1):113–122.

Panel FE (2023) 19 common cyberthreats to retailers (and how to defend against them). Technical report, Forbes, URL `https://www.forbes.com/councils/forbestechcouncil/2023/08/15/19-common-cyberthreats-to-retailers-and-how-to-defend-against-them/`.

PWC (2022) Shrink the large blind spot hiding the risks in your business relationships. Technical report, PWC, URL `https://www.pwc.com/ca/en/services/consulting/cybersecurity-privacy/digital-trust-insights/risks-posed-third-parties-and-supply-chain.html`.

Ramakrishnan S, Bose N (2019) Target in $18.5 million multi-state settlement over data breach. Technical report, Reuters, URL `https://www.reuters.com/article/us-target-cyber-settlement/target-in-18-5-million-multi-state-settlement-over-data-breach-idUSKBN18J2GH`.

Serpa JC, Krishnan H (2016) The strategic role of business insurance. *Management Science* 63(2):384–404.

Shan X, Zhuang J (2013) Hybrid defensive resource allocations in the face of partially strategic attackers in a sequential defender–attacker game. *European Journal of Operational Research* 228(1):262–272.

Tang CS (2006) Robust strategies for mitigating supply chain disruptions. *International Journal of Logistics: Research and Applications* 9(1):33–45.

The-White-House (2023) Executive order on america's supply chains: A year of action and progress. Technical report, The White House, URL `https://bidenwhitehouse.archives.gov/wp-content/uploads/2022/02/Capstone-Report-Biden.pdf`.

Yang Y, Yang Q, Yang Z, Xue S (2019) Optimal model design for the cyber-insurance contract with asymmetric information. *2019 International Conference on Internet of Things (iThings) and IEEE Green Computing and Communications (GreenCom) and IEEE Cyber, Physical and Social Computing (CPSCom) and IEEE Smart Data (SmartData)*, 513–518 (IEEE).

Yu JJ, Tang CS, Shen ZJM (2018) Improving consumer welfare and manufacturer profit via government subsidy programs: Subsidizing consumers or manufacturers? *Manufacturing & Service Operations Management* 20(4):752–766.

Yu JJ, Tang CS, Sodhi MS, Knuckles J (2020) Optimal subsidies for development supply chains. *Manufacturing & service operations management* 22(6):1131–1147.

Zhuang J, Bier VM (2007) Balancing terrorism and natural disasters?defensive strategy with endogenous attacker effort. *Operations Research* 55(5):976–991.

Appendix A: Proof of Propositions

Proof of Lemma 1: Under the socially optimal setting, the government invests in security if the cost of investment ψ is less than the expected reduction in total societal loss due to improved protection. This expected benefit equals $\gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f+L_s)$. Therefore, the government prefers investment in security if $\psi \leq \gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f+L_s)$, which implies the following threshold condition for the network security level: $\bar{s}_\theta \leq 1-\frac{\psi}{\gamma(\rho-\varphi)(L_f+L_s)}$.

In contrast, in the ungoverned setting, the firm only internalizes its private loss and invests in security if $\psi \leq \gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$, which leads to the condition $\bar{s}_\theta \leq 1-\frac{\psi}{\gamma(\rho-\varphi)L_f}$.

Because $L_f < L_f+L_s$, we conclude that the government's threshold for justifying investment is higher than the firm's. Hence, there exists an interval where the government prefers security investment but the firm does not. Specifically, the θ-type firm underinvests in security in the ungoverned setting when

$$1-\frac{\psi}{\gamma(\rho-\varphi)L_f} < \bar{s}_\theta < 1-\frac{\psi}{\gamma(\rho-\varphi)(L_f+L_s)}.$$

Finally, because there are two firm types, one can characterize six distinct regions, as illustrated in Figure 2. In particular, in regions O_1, O_2, and O_3, the firm's incentives are aligned with those of the social planner; thus, the socially optimal solution is achieved even without government intervention. ■

Proof of Proposition 1.

Region I: From the firm's cost function (4), if $\psi \leq \gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$, then the marginal benefit of security investment outweighs its cost, regardless of audit decisions. Therefore, the firm always invests (i.e., $\eta_\theta = 1$), which eliminates the government's incentive to audit ($\lambda_\theta = 0$).

Region III: From the government's cost function (3), if $\kappa \geq (1-\mu_{\mathrm{S}})\omega_\theta$, auditing is not cost-effective for the government regardless of the firm's behavior, so $\lambda_\theta = 0$. In this case, and according to the firm's cost function, if $\psi > \gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$, the firm finds it too costly to invest and chooses not to comply (i.e., $\eta_\theta = 0$).

Region II: When $\kappa < (1-\mu_{\mathrm{S}})\omega_\theta$ and $\psi > \gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$, the players' incentives are not aligned for a pure strategy equilibrium. The firm is indifferent when $\lambda^*_\theta = \frac{\psi-\gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f}{(1-\mu_{\mathrm{S}})\omega_\theta}$, and the government is indifferent when $\eta^*_\theta = 1-\frac{\kappa}{(1-\mu_{\mathrm{S}})\omega_\theta}$. Hence, these values constitute a mixed-strategy Nash equilibrium. ■

Proof of Proposition 2. In what follows, we characterize the optimal menu of subsidy contracts $\Omega^{\mathrm{SC}}_\theta = \{E_\theta = 1, \tau_\theta, \omega_\theta\}$ in the regions where the firm's privately optimal security decision deviates from the socially optimal benchmark, i.e., Regions U_1, U_2, and U_3, as illustrated in Figure 2.

Optimal Subsidy Contract in Region U_1:

In Region U_1, the socially optimal outcome requires both firm types to invest in security, i.e., $e^{\mathrm{SO}}_h = 1$ and $e^{\mathrm{SO}}_\ell = 1$. However, the h-type firm lacks sufficient private incentive to invest and shirks in the absence of government intervention. In contrast, the ℓ-type firm finds it privately optimal to invest even without contractual support. Given this outside decisions, the government does not need to intervene for the ℓ-type and offers no contract. Instead, it focuses solely on designing an incentive mechanism for the h-type firm to induce compliance in equilibrium.

Nevertheless, inducing a pure-strategy equilibrium with $\eta_h = 1$ is not implementable in U_1. As established in Region I of Proposition 1, full compliance is only feasible if the investment cost satisfies: $\psi \le \gamma(1-\bar{s}_h)(\rho-\varphi)L_f$, or equivalently, $\bar{s}_h \le 1-\frac{\psi}{\gamma(\rho-\varphi)L_f}$. By definition, Region U_1 lies outside this threshold. Therefore, the government must select between two second-best strategies to regulate the h-type firm:

(i) **No contract:** Induce a pure-strategy equilibrium with $\eta_h = 0$ by offering no contract. This corresponds to Region III in Proposition 1. In this case, the h-type shirks, while the ℓ-type invests voluntarily based on its private incentives. The resulting expected government loss, under otion (i), is:

$$\mathcal{G}^{\text{SC}}_{U_1}(\eta_h = 0, \eta_\ell = 1) = \zeta \cdot \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)(L_f + L_s)\right] + (1-\zeta)\cdot\gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)(L_f + L_s)\right].$$

(ii) **Mixed-strategy contract:** Induce a mixed-strategy equilibrium with $\eta_h \in (0,1)$ using a positive audit probability $\lambda_h > 0$ and a penalty $\omega_h \ge \frac{\kappa}{1-\mu_S}$. This corresponds to Region II in Proposition 1.

In the second option, the equilibrium audit and effort levels are: $\lambda_h = \frac{\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f}{(1-\mu_S)\omega_h}$, $\eta_h = 1-\frac{\kappa}{(1-\mu_S)\omega_h}$, $\lambda_\ell = 0$, and $\eta_\ell = 1$. Substituting these into the expected cost functions, we obtain:

$$\mathcal{G}_h(\Omega^{\text{SC}}_h \mid \lambda_h > 0, \eta_h > 0) = \tau_h + \gamma(1-\bar{s}_h)\Big[L_n + (1-\rho)(L_f + L_s) + \frac{\kappa}{(1-\mu_S)\omega_h}(\rho-\varphi)(L_f + L_s)\Big], \tag{A. 1}$$

$$\mathcal{G}_\ell(\Omega^{\text{SC}}_\ell \mid \lambda_\ell = 0, \eta_\ell = 1) = \tau_\ell + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)(L_f + L_s)\right], \tag{A. 2}$$

$$\mathcal{F}_h(\Omega^{\text{SC}}_h \mid \lambda_h > 0, \eta_h > 0) = -\tau_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)L_f\right] + \psi, \tag{A. 3}$$

$$\mathcal{F}_\ell(\Omega^{\text{SC}}_\ell \mid \lambda_\ell = 0, \eta_\ell = 1) = -\tau_\ell + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi. \tag{A. 4}$$

Let us first try to design an screening and incentive compatible contract and obtain the θ-type firm's expected cost under the deviated contract. If the ℓ-type firm mimics the h-type by selecting the h-type's contract, then he exerts effort with probability $\tilde{\eta}_\ell$, while the government treats him as a h-type and audits with probability $\lambda_h = \frac{\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f}{(1-\mu_S)\omega_h}$. The ℓ- type firms' expected cost under the deviated contracts are given by:

$$\mathcal{F}_\ell(\Omega^{\text{SC}}_h \mid \lambda_h, \tilde{\eta}_\ell) = -\tau_h + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)L_f\right] + \psi - \gamma(1-\bar{s}_h)(\rho-\varphi)L_f + \tilde{\eta}_\ell\cdot\gamma(\bar{s}_\ell - \bar{s}_h)(\rho-\varphi)L_f. \tag{A. 5}$$

Since $\bar{s}_\ell < \bar{s}_h$ and $\varphi < \rho$, the coefficient of $\tilde{\eta}_\ell$ is negative. Hence, the mimicking ℓ-type firm lowers its expected loss by choosing $\tilde{\eta}_\ell = 1$. Therefore, its loss while mimicking h-type will be:

$$\mathcal{F}_\ell(\Omega^{\text{SC}}_h) = -\tau_h + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi. \tag{A. 6}$$

Similarly, If the h-type firm mimics the ℓ-type, then he exerts effort with probability $\tilde{\eta}_h$, while the government treats him as a ℓ-type and audits with probability $\lambda_\ell = 0$. The h-type firms' expected cost under the deviated contracts are given by:

$$\mathcal{F}_h(\Omega^{\text{SC}}_\ell \mid \lambda_\ell, \tilde{\eta}_h) = -\tau_\ell + \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right] + \tilde{\eta}_h[\psi - \gamma(1-\bar{s}_h)(\rho-\varphi)L_f] \tag{A. 7}$$

Since in region U_1, ψ is greater than $\gamma(1-\bar{s}_h)(\rho-\varphi)L_f$, the coefficient of $\tilde{\eta}_h$ is positive. Therefore, the optimal deviation strategy is $\tilde{\eta}_h = 0$, and the expected costs under these deviations simplify to:

$$\mathcal{F}_h(\Omega_\ell^{\text{SC}} \mid \tilde{\eta}_h = 0) = -\tau_\ell + \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right] \tag{A. 8}$$

Accordingly, the incentive compatibility constraints become:

$$-\tau_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)L_f\right] + \psi \le -\tau_\ell + \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right] \tag{IC^h}$$

$$-\tau_\ell + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi \le -\tau_h + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi \tag{IC$^\ell$}$$

Simplifying, we get:

$$\tau_h - \tau_\ell \ge \psi - \gamma(1-\bar{s}_h)(\rho-\varphi)L_f \tag{IC^h-simplified}$$

$$\tau_h - \tau_\ell \le 0 \tag{IC$^\ell$-simplified}$$

Since in region U_1 we have $\psi > \gamma(1-\bar{s}_h)(\rho-\varphi)L_f$, the right-hand side of IC^h is strictly positive. Hence, IC^h requires $\tau_h > \tau_\ell$, while IC$^\ell$ requires $\tau_h \le \tau_\ell$, creating a contradiction. Therefore, there exists no feasible screening contract that satisfies both incentive compatibility constraints simultaneously.

Next, we try to find a pooling contract where the government only offers a contract to h-type, while examining the situation that the ℓ-type firm may mimic the h-type and pick this contract as well. According to the definition of region U_1, the h-type firm does not exert effort in the absence of a contract, and its outside option is: $\mathcal{F}_h^{\text{UN}} = \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right]$. Accordingly, the individual rationality (IR) constraint for the h-type becomes:

$$-\tau_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)L_f\right] + \psi \le \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right]$$

Therefore, the resulting optimization problem is:

$$\begin{aligned}
\mathcal{P}_{U_1}^{\text{SC}} := \min_{\tau_h,\omega_h} \quad & \zeta \cdot \left\{\tau_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)(L_f + L_s) + \frac{\kappa}{(1-\mu_\text{s})\omega_h}(\rho-\varphi)(L_f + L_s)\right]\right\} \\
& + (1-\zeta)\cdot\left\{\gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)(L_f + L_s)\right]\right\} \\
\text{s.t.} \quad & -\tau_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)L_f\right] + \psi \le \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right] \quad (IR^h) \\
& \tau_h \ge 0, \quad \omega_h \ge \frac{\kappa}{1-\mu_\text{s}} \quad \text{(Feasibility)}
\end{aligned}$$

To solve this optimization problem, we observe that the government's objective function is increasing in the subsidy level τ_h. Therefore, in order to minimize the government's expected loss, we need to reduce τ_h as much as possible. From the individual rationality constraint of the h-type firm, we know that $\tau_h \ge \psi - \gamma(1-\bar{s}_h)(\rho-\varphi)L_f$. Hence, in the optimal solution, τ_h will be set at its lower bound, i.e., $\psi - \gamma(1-\bar{s}_h)(\rho-\varphi)L_f$. On the other hand, the government's expected loss is a decreasing function of the penalty level ω_h. Thus, to further reduce the cost, ω_h should be increased as much as possible. However, the penalty cannot exceed the subsidy, i.e., $\omega_h \leq \tau_h$. Therefore, at the optimum, ω_h also reaches its upper bound and satisfies $\omega_h = \tau_h$. Putting these together, we conclude that in the optimal solution, the values of the penalty and subsidy coincide and are given by: $\omega_h^* = \tau_h^* = \psi - \gamma(1-\bar{s}_h)(\rho-\varphi)L_f$.

Now, To find the condition under which it is preferable for the government to offer a contract to the h-type firm in Region U_1, we compare the government's expected cost under two alternatives: (i) offering no contract at all, and (ii) offering a mixed-strategy subsidy contract to h-type. By substituting the optimal values of τ_h and ω_h into the government's objective function under the contract, and comparing it to the loss incurred when no contract is provided, we can see that the government prefers to offer a contract if the h-type firm's supply chain security level $\bar{s}_h$ lies in the interval: $\bar{s}_h \in \left(\bar{s}_h^{\mathrm{LB}},\ \bar{s}_h^{\mathrm{UB}}\right)$ where:

$$\bar{s}_h^{\mathrm{LB}} = 1 - \frac{\psi(3L_f+L_s) - \dfrac{\kappa(L_f+L_s)}{1-\mu_{\mathrm{S}}} + \sqrt{\left[\psi(3L_f+L_s) - \dfrac{\kappa(L_f+L_s)}{1-\mu_{\mathrm{S}}}\right]^2 - 4(2L_f+L_s)L_f\psi^2}}{2\gamma(\rho-\varphi)(2L_f+L_s)L_f}$$

$$\bar{s}_h^{\mathrm{UB}} = 1 - \frac{\psi(3L_f+L_s) - \dfrac{\kappa(L_f+L_s)}{1-\mu_{\mathrm{S}}} - \sqrt{\left[\psi(3L_f+L_s) - \dfrac{\kappa(L_f+L_s)}{1-\mu_{\mathrm{S}}}\right]^2 - 4(2L_f+L_s)L_f\psi^2}}{2\gamma(\rho-\varphi)(2L_f+L_s)L_f}$$

Finally if the ℓ-type mimics the h-type, it incurs a loss of $-\tau_h + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi$, rather than its outside option $\gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi$. The difference between these two expressions is exactly τ_h, which serves as an *information rent*-an additional cost borne by the government due to hidden firm types. Under the optimal contract design, this rent equals $\psi - \gamma(1-\bar{s}_h)(\rho-\varphi)L_f$. As a result, the contract designed for the h-type is not incentive compatible, since the ℓ-type firm has a strict incentive to mimic the h-type. Consequently we can consider this mechanism as a pooling contract for both types, because both h- and ℓ-type firms come and pick this contract.

Optimal Subsidy Contract in Region U_3:

In Region U_3, the socially optimal solution requires only the ℓ-type firm to invest in security, i.e., $e_\ell^{\mathrm{so}} = 1$ and $e_h^{\mathrm{so}} = 0$. However, under the ungoverned scenario, neither firm type finds it privately optimal to invest. That is, the cost of investment exceeds the private benefit for both types: $\psi > \gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$, or equivalently: $\bar{s}_\theta > 1 - \frac{\psi}{\gamma(\rho-\varphi)L_f}$, for each $\theta \in \{h, \ell\}$. Therefore, the government's challenge in Region U_3 is to induce effort only from the ℓ-type, while allowing the h-type to remain noncompliant.

A pure-strategy NE for the h-type firm is implementable according to Region III of Proposition 1, which permits $\eta_h = 0$ (no effort) and $\lambda_h = 0$ (no audit), consistent with the condition $\psi > \gamma(1-\bar{s}_h)(\rho-\varphi)L_f$. On the other hand, a pure-strategy NE with $\eta_\ell = 1$ for the ℓ-type is not implementable in U_3, since it requires the Region I conditions of Proposition 1, i.e.,$\psi \leq \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f$, which does not hold in U_3. Thus, the government faces two options for the ℓ-type:

(i) **No contract:** This corresponds to a Region III NE in which the ℓ-type firm chooses not to invest ($\eta_\ell = 0$), and the government refrains from auditing ($\lambda_\ell = 0$). Under strategy the government provides no contract to either type and allows both firms to follow their ungoverned strategies. The resulting expected government loss is:

$$\mathcal{G}^{\mathrm{SC}}_{U_3}(\eta_h = 0, \eta_\ell = 0) = \zeta \cdot \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)(L_f + L_s)\right] + (1-\zeta)\cdot\gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)(L_f + L_s)\right].$$

(ii) **Mixed-strategy contract:** The government offers a contract to the ℓ-type firm to induce partial compliance using audit-based enforcement ($\eta_\ell \in (0,1), \lambda_\ell > 0$). This corresponds to Region II of Proposition 1.

This strategy requires a contract $\Omega^{\mathrm{SC}}_\ell$ for the ℓ-type satisfying $\omega_\ell \geq \frac{\kappa}{1-\mu_{\mathrm{S}}}$. Under this contract, the equilibrium audit probability and effort level for the ℓ-type are given by $\lambda_\ell = \frac{\psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f}{(1-\mu_{\mathrm{S}})\omega_\ell}$ and $\eta_\ell = 1 - \frac{\kappa}{(1-\mu_{\mathrm{S}})\omega_\ell}$, respectively. Substituting these expressions into the expected cost functions, we obtain the following:

$$\mathcal{G}_h(\Omega^{\mathrm{SC}}_h \mid \lambda_h = 0, \eta_h = 0) = \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)(L_f + L_s)\right] \tag{$\mathrm{G}^{\mathrm{SC}}_h$}$$

$$\mathcal{G}_\ell(\Omega^{\mathrm{SC}}_\ell \mid \lambda_\ell > 0, \eta_\ell > 0) = \tau_\ell + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)(L_f + L_s) + \frac{\kappa}{(1-\mu_{\mathrm{S}})\omega_\ell}(\rho-\varphi)(L_f + L_s)\right] \tag{$\mathrm{G}^{\mathrm{SC}}_\ell$}$$

$$\mathcal{F}_h(\Omega^{\mathrm{SC}}_h \mid \lambda_h = 0, \eta_h = 0) = \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right] \tag{$\mathrm{F}^{\mathrm{SC}}_h$}$$

$$\mathcal{F}_\ell(\Omega^{\mathrm{SC}}_\ell \mid \lambda_\ell > 0, \eta_\ell > 0) = -\tau_\ell + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi \tag{$\mathrm{F}^{\mathrm{SC}}_\ell$}$$

Under the ungoverned scenario, the ℓ-type firm exerts *no effort*, and its outside option is: $\mathcal{F}^{\mathrm{UN}}_\ell = \gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)L_f\right]$. Given this, the individual rationality (IR) constraint for the ℓ-type under the offered subsidy contract $\Omega^{\mathrm{SC}}_\ell$ becomes:

$$-\tau_\ell + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi \leq \gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)L_f\right]. \tag{$\mathrm{IR}^{\mathrm{SC}}_\ell$}$$

Therefore, the government's optimization problem can be written as follows:

$$\begin{aligned}\min_{\tau_\ell, \omega_\ell} \quad \mathcal{G}^{\mathrm{SC}}_{U_3}(\eta_h = 0, \eta_\ell > 0) = {} & \zeta\left[\gamma(1-\bar{s}_h)\left(L_n + (1-\varphi)(L_f + L_s)\right)\right] \\ & + (1-\zeta)\left[\tau_\ell + \gamma(1-\bar{s}_\ell)\left(L_n + (1-\rho)(L_f + L_s) + \frac{\kappa}{(1-\mu_{\mathrm{S}})\omega_\ell}(\rho-\varphi)(L_f + L_s)\right)\right]\end{aligned}$$

Subject to the following constraints:

$$-\tau_\ell + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi \leq \gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)L_f\right] \tag{IR^ℓ}$$

$$\omega_\ell \geq \frac{\kappa}{1-\mu_{\mathrm{S}}} \tag{Feasibility}$$

Note that the government's objective function is increasing in τ_ℓ. According to the individual rationality constraint IR^ℓ, which requires $\tau_\ell \geq \psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f$, the optimal subsidy is set at its lower bound, i.e., $\tau^*_\ell = \psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f$. Moreover, since the objective function is decreasing in the penalty ω_ℓ, the government minimizes its cost by setting the penalty as high as feasible. However, the penalty cannot exceed the subsidy; that is, $\omega_\ell \leq \tau_\ell$. Therefore, at optimality, we have $\omega^*_\ell = \tau^*_\ell = \psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f$.

Now, If the h-type firm mimics the ℓ-type and selects contract $\Omega_\ell^{\mathrm{SC}}$, then he exerts effort with probability $\tilde{\eta}_h$, and is audited with probability $\lambda_\ell = \frac{\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f}{(1-\mu_{\mathrm{S}})\omega_\ell}$, because the government believes the firm is of ℓ-type. The expected loss is:

$$\begin{aligned}\mathcal{F}_h(\Omega_\ell^{\mathrm{SC}} \mid \tilde{\eta}_h) = & -\tau_\ell + \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right] + \psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f \\ & + \tilde{\eta}_h \cdot \gamma(\bar{s}_h - \bar{s}_\ell)(\rho-\varphi)L_f \end{aligned} \tag{A. 9}$$

Since $\bar{s}_h > \bar{s}_\ell$ and $\rho > \varphi$, the coefficient of $\tilde{\eta}_h$ in (A. 9) is strictly positive. This implies that the h-type firm, when mimicking the ℓ-type, increases his loss by exerting effort. Therefore, the optimal deviation strategy is $\tilde{\eta}_h = 0$, and the expected loss simplifies to:

$$\mathcal{F}_h(\Omega_\ell^{\mathrm{SC}} \mid \tilde{\eta}_h = 0) = -\tau_\ell + \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right] + \psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f \tag{A. 10}$$

Therefore, if the h-type firm mimics the ℓ-type, its expected cost becomes $-\tau_\ell + \gamma(1-\bar{s}_h)(L_n + (1-\varphi)L_f) + \psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f$, instead of its outside option, which is $\gamma(1-\bar{s}_h)(L_n + (1-\varphi)L_f)$. The difference between these two expressions represents the h-type firm's information rent, given by $\tau_\ell + \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f - \psi$. However, under the optimal contract design, this expression evaluates to zero. Thus, the h-type receives no information rent and has no incentive to mimic the ℓ-type. Consequently, the contract remains incentive compatible.

Now that we have derived the government's expected loss under the mixed-strategy contract (Option (ii)), we compare this to the case where no contract is offered (Option (i)).

Under the no-contract strategy, the expected government loss, is:

$$\mathcal{G}_{U_3}^{\mathrm{SC}}(\eta_h = 0, \eta_\ell = 0) = \zeta \cdot \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)(L_f + L_s)\right] + (1-\zeta) \cdot \gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)(L_f + L_s)\right].$$

Let us denote the government's expected loss under the mixed-strategy contract as $\mathcal{G}_{\mathrm{MIX}}^{\mathrm{SC}}$. To determine whether the government prefers to offer the contract, we evaluate the condition under which $\mathcal{G}_{\mathrm{MIX}}^{\mathrm{SC}} < \mathcal{G}_{\mathrm{NO}}^{\mathrm{SC}}$, that is:

$$\begin{aligned}(1-\zeta) \cdot \Bigg[\psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f + \gamma(1-\bar{s}_\ell)\Big(L_n + (1-\rho)(L_f + L_s) \\ + \frac{\kappa}{(1-\mu_{\mathrm{S}})(\psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f)}(\rho-\varphi)(L_f + L_s)\Big)\Bigg] < (1-\zeta) \cdot \gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)(L_f + L_s)\right]\end{aligned}$$

Simplifying the inequality, the government prefers to offer the contract if:

$$\psi < \gamma(1-\bar{s}_\ell)(\rho-\varphi)\left[(2L_f + L_s) - \frac{\kappa}{(1-\mu_{\mathrm{S}})(\psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f)}(L_f + L_s)\right].$$

To derive this inequality with respect to $\bar{s}_\ell$, we first simplify the expression by defining:

$$A := \gamma(\rho-\varphi), \quad B := 2L_f + L_s, \quad C := \frac{\kappa(L_f + L_s)}{1-\mu_{\mathrm{S}}}, \quad x := 1 - \bar{s}_\ell.$$

Substituting into the inequality yields:

$$\psi < Ax\left[B - \frac{C}{\psi - AL_f x}\right].$$

Multiplying both sides by the denominator and simplifying, we obtain the quadratic inequality:

$$A^2BL_f x^2 - A[\psi(B+L_f) - C]x + \psi^2 < 0.$$

This is a standard quadratic inequality in x, whose solution lies between the roots:

$$x \in \left(x_1 = \frac{-b-\sqrt{b^2-4ac}}{2a},\ x_2 = \frac{-b+\sqrt{b^2-4ac}}{2a}\right),$$

where:

$$a = A^2BL_f, \quad b = -A[\psi(B+L_f) - C], \quad c = \psi^2.$$

Therefore, converting back to $\bar{s}_\ell = 1-x$, the feasible region becomes: $\bar{s}_\ell \in \left(\bar{s}_\ell^{\mathrm{LB}},\ \bar{s}_\ell^{\mathrm{UB}}\right)$:

$$\bar{s}_\ell^{\mathrm{LB}} = 1 - \frac{\psi(3L_f+L_s) - \frac{\kappa(L_f+L_s)}{1-\mu_{\mathrm{S}}} + \sqrt{\left[\psi(3L_f+L_s) - \frac{\kappa(L_f+L_s)}{1-\mu_{\mathrm{S}}}\right]^2 - 4(2L_f+L_s)L_f\psi^2}}{2\gamma(\rho-\varphi)(2L_f+L_s)L_f}$$

$$\bar{s}_\ell^{\mathrm{UB}} = 1 - \frac{\psi(3L_f+L_s) - \frac{\kappa(L_f+L_s)}{1-\mu_{\mathrm{S}}} - \sqrt{\left[\psi(3L_f+L_s) - \frac{\kappa(L_f+L_s)}{1-\mu_{\mathrm{S}}}\right]^2 - 4(2L_f+L_s)L_f\psi^2}}{2\gamma(\rho-\varphi)(2L_f+L_s)L_f}$$

Optimal Subsidy Contract in Region U_2:

In Region U_2, the socially optimal outcome requires both firm types to invest in security, i.e., $e_h^{\mathrm{so}} = 1$ and $e_\ell^{\mathrm{so}} = 1$. However, under the parameter conditions that define Region U_2, the cost of investment exceeds each firm's private benefit: $\psi > \gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$, for both $\theta \in \{h, \ell\}$. As a result, inducing a pure-strategy NE with full compliance ($\eta_\theta = 1$) is not feasible for either type under Region I of Proposition 1. The government must therefore consider second-best instruments that induce partial compliance. Specifically, the government faces four candidate policies:

(i) **No contract for either type** (Region III equilibrium with $\eta_h = \eta_\ell = 0$):

Under this option, the government offers no contract, and both firm types choose not to invest. The government also refrains from auditing, i.e., $\lambda_h = \lambda_\ell = 0$. The resulting expected government loss is:

$$\mathcal{G}_{U_2}^{\mathrm{SC}}(\eta_h = 0, \eta_\ell = 0) = \zeta \cdot \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)(L_f+L_s)\right] + (1-\zeta)\cdot\gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)(L_f+L_s)\right].$$

(ii) **Contract only for the ℓ-type** (Region II for the ℓ-type, Region III for the h-type):

The government induces partial compliance from the ℓ-type via a mixed-strategy mechanism ($\eta_\ell \in (0,1)$, $\lambda_\ell > 0$), while allowing the h-type to shirk under no contract ($\eta_h = 0$, $\lambda_h = 0$). This setup is structurally identical to Region U_3, and thus the associated government loss is: $\mathcal{G}_{U_2}^{\mathrm{SC}}(\eta_\ell > 0, \eta_h = 0) = \mathcal{G}_{U_3}^{\mathrm{SC}}(\eta_\ell > 0, \eta_h = 0)$.

(iii) **Contract only for the h-type** (Region II for the h-type, Region III for the ℓ-type):

In this case, the government attempts to induce partial compliance from the h-type firm through a mixed-strategy mechanism ($\eta_h \in (0,1)$, $\lambda_h > 0$), while offering no contract to the ℓ-type firm, who then exerts no effort ($\eta_\ell = 0$) and is not audited ($\lambda_\ell = 0$).

Therefore, The government designs a contract $\Omega_h^{\text{SC}} = \{E_h = 1, \tau_h, \omega_h\}$ for the h-type firm such that: $\lambda_h = \frac{\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f}{(1-\mu_S)\omega_h}$, $\eta_h = 1 - \frac{\kappa}{(1-\mu_S)\omega_h}$. Using these expressions, the expected loss functions from each type is:

$$\mathcal{G}_h(\Omega_h^{\text{SC}} \mid \lambda_h > 0, \eta_h > 0) = \tau_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)(L_f + L_s) + \frac{\kappa}{(1-\mu_S)\omega_h}(\rho-\varphi)(L_f+L_s)\right] \tag{G$_h^{\text{SC}}$}$$

$$\mathcal{G}_\ell(\Omega_\ell^{\text{SC}} \mid \lambda_\ell = 0, \eta_\ell = 0) = \gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)(L_f + L_s)\right] \tag{G$_\ell^{\text{SC}}$}$$

$$\mathcal{F}_h(\Omega_h^{\text{SC}} \mid \lambda_h > 0, \eta_h > 0) = -\tau_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)L_f\right] + \psi \tag{F$_h^{\text{SC}}$}$$

$$\mathcal{F}_\ell(\Omega_\ell^{\text{SC}} \mid \lambda_\ell = 0, \eta_\ell = 0) = \gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)L_f\right] \tag{F$_\ell^{\text{SC}}$}$$

Since the h-type firm does not exert effort in the absence of a contract, its outside option is: $\mathcal{F}_h^{\text{UN}} = \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right]$. Accordingly, the individual rationality (IR) constraint for the h-type firm under the offered contract Ω_h^{SC} is:

$$-\tau_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)L_f\right] + \psi \leq \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right]. \tag{IR$_h^{\text{SC}}$}$$

Hence, the resulting optimization problem will be:

$$\begin{aligned}
\mathcal{P}_{U_2}^{\text{SC}} := \min_{\tau_h,\omega_h} \quad & \zeta \cdot \left\{\tau_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)(L_f+L_s) + \frac{\kappa}{(1-\mu_S)\omega_h}(\rho-\varphi)(L_f+L_s)\right]\right\} \\
& + (1-\zeta)\cdot\left\{\gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)(L_f+L_s)\right]\right\} \\
\text{s.t.} \quad & -\tau_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)L_f\right] + \psi \leq \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right] \quad (IR^h) \\
& \tau_h \geq 0, \quad \omega_h \geq \frac{\kappa}{1-\mu_S} \quad \text{(Feasibility)}
\end{aligned}$$

To solve this optimization problem, we observe that the government's objective function is increasing in the subsidy level τ_h . Therefore, in order to minimize the government's expected loss, τ_h must be minimized. From the individual rationality constraint of the h-type firm, we deduce that the minimum feasible value of τ_h is given by $\tau_h \geq \psi - \gamma(1-\bar{s}_h)(\rho-\varphi)L_f$. Thus, in the optimal solution, τ_h is set at its lower bound: $\psi - \gamma(1-\bar{s}_h)(\rho-\varphi)L_f$. At the same time, the government's objective function is decreasing in the penalty level ω_h, since a higher penalty reduces the expected audit burden. To reduce total cost, the penalty ω_h should be increased as much as feasibility allows. However, the condition $\omega_h \leq \tau_h$ limits this increase. Therefore, at the optimum, the penalty also reaches its upper bound and satisfies $\omega_h = \tau_h$. Putting everything together, we conclude that the optimal values of subsidy and penalty coincide, and are given by: $\omega_h^* = \tau_h^* = \psi - \gamma(1-\bar{s}_h)(\rho-\varphi)L_f$.

Now, if the ℓ-type firm mimics the h-type and selects contract Ω_h^{SC}, then it exerts effort with probability $\tilde{\eta}_\ell$ and is audited with probability $\lambda_h = \frac{\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f}{(1-\mu_{\mathrm{S}})\omega_h}$. The expected loss is:

$$\mathcal{F}_\ell(\Omega_h^{\mathrm{SC}} \mid \lambda_h, \tilde{\eta}_\ell) = -\tau_h + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)L_f\right] + \psi - \gamma(1-\bar{s}_h)(\rho-\varphi)L_f + \tilde{\eta}_\ell \cdot \gamma(\bar{s}_\ell - \bar{s}_h)(\rho-\varphi)L_f. \tag{A. 11}$$

Since $\bar{s}_\ell < \bar{s}_h$ and $\rho > \varphi$, the coefficient of $\tilde{\eta}_\ell$ is negative. Therefore, the optimal deviation strategy is $\tilde{\eta}_\ell = 1$, and the expected loss simplifies to:

$$\mathcal{F}_\ell(\Omega_h^{\mathrm{SC}} \mid \tilde{\eta}_\ell = 1) = -\tau_h + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi. \tag{A. 12}$$

Therefore, if the ℓ-type firm mimics the h-type and selects contract Ω_h^{SC}, it incurs a loss of $-\tau_h + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi$, instead of its outside option $\gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)L_f\right]$. The difference between these two expressions is $\tau_h + \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f - \psi$, which represents the *information rent* that the government effectively pays due to asymmetric information-because it cannot prevent the ℓ-type from imitating the h-type's contract. Finally, if we substitute the optimal contract values, this information rent becomes $\gamma(\bar{s}_h - \bar{s}_\ell)(\rho-\varphi)L_f$. This confirms that the contract designed for the h-type is not incentive compatible, as the ℓ-type firm has a strict incentive to mimic.

Now, to find the condition under which it is preferable for the government to offer a contract to the h-type firm, we compare the government's expected cost under two alternatives: (i) offering no contract at all, and (ii) offering a mixed-strategy subsidy contract to h-type. By substituting the optimal values of τ_h and ω_h into the government's objective function under the contract, and comparing it to the loss incurred when no contract is provided, we can see that: the government prefers to offer a contract if the h-type firm's supply chain security level $\bar{s}_h$ lies in the interval: $\bar{s}_h \in \left(\bar{s}_h^{\mathrm{LB}},\ \bar{s}_h^{\mathrm{UB}}\right)$, where:

$$\bar{s}_h^{\mathrm{LB}} = 1 - \frac{\psi(3L_f + L_s) - \dfrac{\kappa(L_f + L_s)}{1-\mu_{\mathrm{S}}} + \sqrt{\left[\psi(3L_f + L_s) - \dfrac{\kappa(L_f + L_s)}{1-\mu_{\mathrm{S}}}\right]^2 - 4(2L_f + L_s)L_f\psi^2}}{2\gamma(\rho-\varphi)(2L_f + L_s)L_f}$$

$$\bar{s}_h^{\mathrm{UB}} = 1 - \frac{\psi(3L_f + L_s) - \dfrac{\kappa(L_f + L_s)}{1-\mu_{\mathrm{S}}} - \sqrt{\left[\psi(3L_f + L_s) - \dfrac{\kappa(L_f + L_s)}{1-\mu_{\mathrm{S}}}\right]^2 - 4(2L_f + L_s)L_f\psi^2}}{2\gamma(\rho-\varphi)(2L_f + L_s)L_f}$$

(iv) **Contracts for both types** (Region II for both types):

The government offers contracts to both h- and ℓ-type firms, inducing partial compliance from each via audit-based enforcement. This corresponds to Region II of Proposition 1 for both types. A mixed-strategy equilibrium is sustained when the penalty level satisfies: $\omega_\theta \geq \frac{\kappa}{1-\mu_{\mathrm{S}}}$, for each $\theta \in \{h, \ell\}$. Under this contract, the equilibrium audit probability and effort level for type θ are given by: $\lambda_\theta = \frac{\psi-\gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f}{(1-\mu_{\mathrm{S}})\omega_\theta}$, $\eta_\theta = 1 - \frac{\kappa}{(1-\mu_{\mathrm{S}})\omega_\theta}$. Substituting these into the expected cost functions, the government's expected loss from a type-θ firm is:

$$\mathcal{G}_\theta(\Omega_\theta^{\mathrm{SC}}) = \tau_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\rho)(L_f + L_s) + \frac{\kappa}{(1-\mu_{\mathrm{S}})\omega_\theta}(\rho-\varphi)(L_f + L_s)\right] \tag{G$_\theta^{\mathrm{SC}}$}$$

Similarly, the firm's expected cost under the same contract is:

$$\mathcal{F}_\theta(\Omega_\theta^{\mathrm{SC}}) = -\tau_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\rho)L_f\right] + \psi \tag{$\mathrm{F}_\theta^{\mathrm{SC}}$}$$

Let us obtain the θ-type firm's expected cost under the deviated contract. If the ℓ-type (resp. h-type) firm mimics the h-type (resp. ℓ-type) by selecting the other type's contract, then he exerts effort with probability $\tilde{\eta}_\ell$ (resp. $\tilde{\eta}_h$), while the government treats him as a h-type (resp. ℓ-type) and audits with probability $\lambda_h = \frac{\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f}{(1-\mu_S)\omega_h}$ (resp. $\lambda_\ell = \frac{\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f}{(1-\mu_S)\omega_\ell}$). The ℓ- and h-type firms' expected costs under the deviated contracts are given by:

$$\mathcal{F}_\ell(\Omega_h^{\mathrm{SC}} \mid \lambda_h, \tilde{\eta}_\ell) = -\tau_h + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)L_f\right] + \psi - \gamma(1-\bar{s}_h)(\rho-\varphi)L_f + \tilde{\eta}_\ell \cdot \gamma(\bar{s}_\ell - \bar{s}_h)(\rho-\varphi)L_f \tag{A. 13}$$

$$\mathcal{F}_h(\Omega_\ell^{\mathrm{SC}} \mid \lambda_\ell, \tilde{\eta}_h) = -\tau_\ell + \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right] + \psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f + \tilde{\eta}_h \cdot \gamma(\bar{s}_h - \bar{s}_\ell)(\rho-\varphi)L_f \tag{A. 14}$$

By definition $\bar{s}_h > \bar{s}_\ell$, and since $\rho > \varphi$, the coefficient of $\tilde{\eta}_\ell$ is negative and that of $\tilde{\eta}_h$ is positive. Therefore, the optimal deviation strategy is $\tilde{\eta}_\ell = 1$ and $\tilde{\eta}_h = 0$. The expected costs under these deviations simplify to:

$$\mathcal{F}_\ell(\Omega_h^{\mathrm{SC}} \mid \tilde{\eta}_\ell = 1) = -\tau_h + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi \tag{A. 15}$$

$$\mathcal{F}_h(\Omega_\ell^{\mathrm{SC}} \mid \tilde{\eta}_h = 0) = -\tau_\ell + \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right] + \psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f \tag{A. 16}$$

Accordingly, the incentive compatibility constraints become:

$$-\tau_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)L_f\right] + \psi \le -\tau_\ell + \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right] + \psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f \tag{IC^h}$$

$$-\tau_\ell + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi \le -\tau_h + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi \tag{IC^ℓ}$$

Simplifying, we get:

$$\tau_h - \tau_\ell \ge \gamma(\bar{s}_h - \bar{s}_\ell)(\rho-\varphi)L_f \tag{IC^h-simplified}$$

$$\tau_h - \tau_\ell \le 0 \tag{IC^ℓ-simplified}$$

Since $\bar{s}_h > \bar{s}_\ell$ and $\rho > \varphi$, the right-hand side of IC^h is strictly positive. Hence, IC^h requires $\tau_h > \tau_\ell$, while IC^ℓ requires $\tau_h \le \tau_\ell$, creating a contradiction. Therefore, there exists no feasible contract that satisfies both constraints simultaneously.

Finally, the optimal contract in Region U_2 can be determined by comparing the government's expected loss across the feasible second-best alternatives. First, the pure-strategy outcome with no investment from either firm type, i.e., $\eta_h = \eta_\ell = 0$. Second, the government may induce a mixed-strategy equilibrium only for the ℓ-type, i.e., $\eta_\ell > 0$, $\eta_h = 0$. This setup is structurally identical to Region U_3. Third, the government may instead offer a mixed-strategy contract only to the h-type, i.e., $\eta_h > 0$, $\eta_\ell = 0$, which is structurally identical to Region U_1.

By comparing these three expected losses, the government can determine the most cost-effective strategy and partition Region U_2 into subregions where it is optimal to: (i) provide no contract at all, (ii) offer a contract only to the ℓ-type, or (iii) offer a contract only to the h-type. ■

Proof of Proposition 3.

Region I: From the firm's cost function, if $\psi \le \gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f-\phi_\theta)$, then the marginal benefit of security investment outweighs its cost, regardless of the government's inspection decision. Therefore, the firm always invests (i.e., $\eta_\theta = 1$), and since no enforcement is needed, the government chooses not to inspect (i.e., $\lambda_\theta = 0$).

Region III: From the government's cost function, if $\kappa \ge (1-\mu_1)\phi_\theta$, then post-incident inspection is not cost-effective for the government. In this case, and according to the firm's cost function, if $\psi > \gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f-\phi_\theta)$, the firm finds investment too costly and chooses not to invest (i.e., $\eta_\theta = 0$). Hence, $(\lambda_\theta = 0, \eta_\theta = 0)$ constitutes the pure strategy NE.

Region II: When $\kappa < (1-\mu_1)\phi_\theta$ and $\psi > \gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f-\phi_\theta)$, the players' incentives are misaligned and do not support a pure strategy equilibrium. The firm is indifferent when $\lambda^*_\theta = \frac{\psi-\gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f-\phi_\theta)}{\gamma(1-\bar{s}_\theta)(1-\varphi)(1-\mu_1)\phi_\theta}$, and the government is indifferent when $\eta^*_\theta = 1-\frac{\kappa}{(1-\mu_1)\phi_\theta}$. Hence, these values form the unique mixed-strategy Nash equilibrium of the inspection game. ■

Proof of proposition 4. The government designs the contract at the ex-ante stage, therefore, $\check{\mathcal{G}}(\Omega)$ in the optimization model $\mathcal{P}^{\text{IC}}$ corresponds to government's expected loss given in following table 9:

Table 9 Government's Expected Cost in the Inspection Game

Firm Effort	**Inspection Decision $\mathcal{A}_I$**	
	$\mathcal{A}_I = 1$ (w.p. λ_θ)	$\mathcal{A}_I = 0$ (w.p. $1-\lambda_\theta$)
$e_\theta = 1$ (w.p. η_θ)	$-\pi_\theta+\gamma(1-\bar{s}_\theta)\left[L_n+(1-\rho)(L_f+L_s+\phi_\theta+\kappa)\right]$	$-\pi_\theta+\gamma(1-\bar{s}_\theta)\left[L_n+(1-\rho)(L_f+L_s+\phi_\theta)\right]$
$e_\theta = 0$ (w.p. $1-\eta_\theta$)	$-\pi_\theta+\gamma(1-\bar{s}_\theta)\left[L_n+(1-\varphi)(L_f+L_s+\mu_1\phi_\theta+\kappa)\right]$	$-\pi_\theta+\gamma(1-\bar{s}_\theta)\left[L_n+(1-\varphi)(L_f+L_s+\phi_\theta)\right]$

Accordingly, the government's expected cost expression can be written as follows:

$$\begin{aligned}\mathcal{G}_\theta(\lambda_\theta,\eta_\theta \mid \pi_\theta,\phi_\theta) = -\pi_\theta+\gamma(1-\bar{s}_\theta)\Big[&L_n+\left(\eta_\theta(1-\rho)+(1-\eta_\theta)(1-\varphi)\right)(L_f+L_s+\phi_\theta)\\ &+\lambda_\theta\left(\left(\eta_\theta(1-\rho)+(1-\eta_\theta)(1-\varphi)\right)\kappa-(1-\eta_\theta)(1-\varphi)(1-\mu_1)\phi_\theta\right)\Big]\end{aligned} \tag{A. 17}$$

Now, by comparing the government's expected loss under the insurance regime in Equation (A. 17) with the benchmark loss under the socially optimal solution—given by $\gamma(1-\bar{s}_\theta)\left[e^{\text{SO}}_\theta(1-\rho)+(1-e^{\text{SO}}_\theta)(1-\varphi)\right](L_f+L_s)+e^{\text{SO}}_\theta\cdot\psi$, we can characterize the total inefficiency I^{IC} induced by the second-best insurance contract. This inefficiency reflects two main components: (i) the expected loss due to underinvestment in security, and (ii) the agency cost from premium transfers, coverage distortions, and inspection activities.

In what follows, similar to the proof of Proposition **??**, we characterize the menu of insurance contracts $\Omega_\theta^{\mathrm{IC}} = \{E_\theta = 1, \pi_\theta, \phi_\theta\}$ in the regions where the firm's security decision deviates from the socially optimal benchmark-that is, in Regions U_1, U_2, and U_3 of Figure 2.

- *Optimal Insurance Contract in Region U_1*:

In this region, the socially optimal solution requires both firm types to invest in security, i.e., $e_\ell = 1$ and $e_h = 1$. However, under the outside option, only ℓ-type firm already invests in the absence of government intervention. Thus, the government does not offer any contract to the ℓ-type, and focuses solely on incentivizing the h-type. If the government seeks to implement a pure-strategy NE for the h-type firm-corresponding to Region I of Proposition 3 (i.e., $\lambda_h = 0$ and $\eta_h = 1$)-it requires: $\psi \le \gamma(1-\bar{s}_h)(\rho-\varphi)(L_f-\phi_h)$. However, U_1 is defined by the violation of this condition (i.e., $\psi > \gamma(1-\bar{s}_h)(\rho-\varphi)L_f$), so the pure-strategy NE with full compliance cannot be implemented. Therefore, the government must choose between two alternatives, whichever yields a lower expected cost:

- **No contract (Region III):** This leads to $\eta_h = 0$, resulting in the following expected government loss:

$$\mathcal{G}_{U_1}^{\mathrm{IC}}(\eta_h = 0,\, \eta_\ell = 1) = \zeta\cdot\gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)(L_f+L_s)\right] + (1-\zeta)\cdot\gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)(L_f+L_s)\right].$$

- **Mixed-strategy contract (Region II):** The government designs a contract $\Omega_h^{\mathrm{IC}} = \{\pi_h, \phi_h\}$ to induce $\eta_h \in (0,1)$, supported by inspection with probability $\lambda_h > 0$. The feasibility conditions require: $\phi_h \ge \frac{\kappa}{1-\mu_1}$.

Substituting equilibrium values of $\lambda_h = \frac{\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)(L_f-\phi_h)}{\gamma(1-\bar{s}_h)(1-\varphi)(1-\mu_1)\phi_h}$ and $\eta_h = 1-\frac{\kappa}{(1-\mu_1)\phi_h}$, the cost expressions become:

$$\mathcal{G}_\ell(\Omega_\ell^{\mathrm{IC}} \mid \lambda_\ell = 0, \eta_\ell = 1) = \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)(L_f+L_s)\right], \tag{A. 18}$$

$$\begin{aligned}\mathcal{G}_h(\Omega_h^{\mathrm{IC}} \mid \lambda_h > 0, \eta_h > 0) = -\pi_h + \gamma(1-\bar{s}_h)\cdot\Bigg(&L_n + (1-\rho)(L_f+L_s+\phi_h) + \frac{\kappa(\rho-\varphi)}{(1-\mu_1)\phi_h}(L_f+L_s+\phi_h)\\ &-\frac{(\rho-\varphi)\kappa\left[\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)(L_f-\phi_h)\right]\left[(1-\mu_1)\phi_h-\kappa\right]}{\gamma(1-\bar{s}_h)(1-\varphi)(1-\mu_1)^2\phi_h^2}\Bigg),\end{aligned} \tag{A. 19}$$

$$\mathcal{F}_\ell(\Omega_\ell^{\mathrm{IC}} \mid \lambda_\ell = 0, \eta_\ell = 1) = \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi, \tag{A. 20}$$

$$\mathcal{F}_h(\Omega_h^{\mathrm{IC}} \mid \lambda_h > 0, \eta_h > 0) = \pi_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)(L_f-\phi_h)\right] + \psi. \tag{A. 21}$$

Because, in the *ungoverned decision*, the h-type firm does not exert effort, its outside option loss will be: $\mathcal{F}_h^{\mathrm{UN}} = \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right]$. Thus, the individual rationality (IR) constraint for the h-type firm in this situation can be written as:

$$\pi_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)(L_f-\phi_h)\right] + \psi \le \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right] \tag{A. 22}$$

Hence, for the h-type firm we have $\Omega_h^{\mathrm{IC}} \in \left\{\phi_h \geq \dfrac{\kappa}{1-\mu_{\mathrm{I}}},\ \phi_h < L_f\right\}$. The complete optimization problem in Region U_1 can be then written as follows:

$$\begin{aligned}\min_{\pi_h,\phi_h} \quad \mathcal{G}_{U_1}^{\mathrm{IC}} = {} & (1-\zeta)\cdot\gamma(1-\bar{s}_\ell)\left[L_n+(1-\rho)(L_f+L_s)\right] \\ & + \zeta\cdot\Bigg[-\pi_h+\gamma(1-\bar{s}_h)\cdot\Bigg(L_n+(1-\rho)(L_f+L_s+\phi_h)+\frac{\kappa(\rho-\varphi)}{(1-\mu_{\mathrm{I}})\phi_h}(L_f+L_s+\phi_h) \\ & \qquad - \frac{(\rho-\varphi)\kappa\left[\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)(L_f-\phi_h)\right]\left[(1-\mu_{\mathrm{I}})\phi_h-\kappa\right]}{\gamma(1-\bar{s}_h)(1-\varphi)(1-\mu_{\mathrm{I}})^2\phi_h^2}\Bigg)\Bigg]\end{aligned} \tag{A. 23}$$

Subject to:

$$\pi_h+\gamma(1-\bar{s}_h)\left[L_n+(1-\rho)(L_f-\phi_h)\right]+\psi \leq \gamma(1-\bar{s}_h)\left[L_n+(1-\varphi)L_f\right] \tag{IR^h}$$

$$\frac{\kappa}{1-\mu_{\mathrm{I}}} \leq \phi_h \leq L_f \tag{Feasibility}$$

Note that the coefficient of π_h in the objective function (A. 38) is –1, indicating that the objective function is strictly decreasing in π_h. Therefore, to minimize the government's expected cost, the optimal value of π_h must lie at its upper bound, given by: $\gamma(1-\bar{s}_h)\left[(1-\varphi)L_f-(1-\rho)(L_f-\phi_h)\right]-\psi$, based on the *IR*^{h}. This implies that the government prefers to set the insurance premium as high as possible within the admissible range. Furthermore, this upper bound also achieves its highest value when $\phi_h \in \left(\frac{\kappa}{1-\mu_{\mathrm{I}}}, L_f\right)$ takes its maximum level, i.e., L_f. Therefore, the optimal value of decision variables under this contract are $\pi_h = \Big[\gamma(1-\bar{s}_h)(1-\varphi)L_f-\psi\Big]^+$, and $\phi_h = L_f$. However, in order to have feasible contract terms, we must ensure $\pi_h = \gamma(1-\bar{s}_h)(1-\varphi)L_f-\psi \geq 0$, which implies that $\bar{s}_h \leq 1-\frac{\psi}{\gamma(1-\varphi)L_f}$ for the contract to be practical.

Next, the optimal insurance contract in Region U_1 is determined by comparing the government's expected cost under two options. Specifically, the government prefers to induce security investment from the h-type if the expected cost under a mixed-strategy contract, i.e., $\mathcal{G}_{U_1}^{\mathrm{IC}}(\eta_h>0,\eta_\ell=1)$, is less than or equal to the expected cost under no contract, i.e., $\mathcal{G}_{U_1}^{\mathrm{IC}}(\eta_h=0,\eta_\ell=1)$. This condition holds when the network-level security of the h-type firm satisfies $\bar{s}_h \leq 1-\frac{\psi-\frac{(\rho-\varphi)\kappa\cdot\psi\cdot\left[(1-\mu_{\mathrm{I}})L_f-\kappa\right]}{(1-\varphi)(1-\mu_{\mathrm{I}})^2L_f^2}}{\gamma(\rho-\varphi)\left(1-\frac{\kappa}{(1-\mu_{\mathrm{I}})L_f}\right)(2L_f+L_s)}$, which always holds when $\bar{s}_h \leq 1-\frac{\psi}{\gamma(1-\varphi)L_f}$.

Finally, if the ℓ-type firm mimics the h-type by selecting the contract $\Omega_h^{\mathrm{IC}}=\{\pi_h,\phi_h\}$, he invests in security with probability $\tilde{\eta}_\ell$, and the government inspects with probability: $\lambda_h = \frac{\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)(L_f-\phi_h)}{\gamma(1-\bar{s}_h)(1-\varphi)(1-\mu_{\mathrm{I}})\phi_h}$. The firm's expected cost under the deviated contract is:

$$\mathcal{F}_{\ell|h}(\Omega_h^{\mathrm{IC}}) = \pi_h+\gamma(1-\bar{s}_\ell)\left[L_n+(1-\rho)(L_f-\phi_h)\right]+\tilde{\eta}_\ell\cdot\left(1-\frac{1-\bar{s}_\ell}{1-\bar{s}_h}\right)\psi+\left(\frac{1-\bar{s}_\ell}{1-\bar{s}_h}\right)\psi. \tag{A. 24}$$

Since by definition we have $\bar{s}_h > \bar{s}_\ell$, it follows that $1-\frac{1-\bar{s}_\ell}{1-\bar{s}_h} < 0$. This implies that the coefficient of $\tilde{\eta}_\ell$ in Equation (A. 39), is strictly negative. Consequently, the ℓ-type firm can reduce its total cost when mimicking the h-type contract by choosing to *invest in security*, that is, by setting $\tilde{\eta}_\ell = 1$.

Therefore, if the ℓ-type firm mimics the h-type, it incurs a loss of: $\pi_h + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)(L_f - \phi_h)\right] + \psi$, instead of its outside option: $\gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi$. The difference between these two expressions is exactly: $\gamma(1-\bar{s}_\ell)(1-\rho)\phi_h - \pi_h$, which represents the *information rent* that the government bears due to hidden firm types. Under the optimal contract design, this rent equals: $\psi - \gamma\Big((1-\bar{s}_h)(1-\varphi) - (1-\bar{s}_\ell)(1-\rho)\Big)L_f$. As a result, because this amount is positive, the contract designed for the h-type is not incentive compatible, since the ℓ-type firm has a strict incentive to mimic the h-type. As, result, we have pooling contract, as both h- and ℓ- type firms will pick the same contract.

Optimal Insurance Contract in Region U_3:

In this region, the socially optimal policy requires only the ℓ-type firm to invest in security, i.e., $e_\ell^{\mathrm{so}} = 1$ and $e_h^{\mathrm{so}} = 0$. Under the ungoverned setting, however, both firm types prefer not to invest. Therefore, the government aims to induce compliance only from the ℓ-type, while allowing the h-type to shirk.

For the h-type, a pure-strategy NE with no investment and no inspection ($\eta_h = 0, \lambda_h = 0$), consistent with Region III of Proposition 3, is both feasible and optimal. This is because the Region III condition $\psi > \gamma(1-\bar{s}_h)(\rho-\varphi)(L_f - \phi_h)$ is always satisfied in U_3, where the inequality $\psi > \gamma(1-\bar{s}_h)(\rho-\varphi)L_f$ holds by definition. However, for the ℓ-type, implementing a pure-strategy NE with full compliance ($\eta_\ell = 1$), which corresponds to Region I of Proposition 3, is not feasible. Region I requires the condition $\psi \le \gamma(1-\bar{s}_\ell)(\rho-\varphi)(L_f - \phi_\ell)$, which lies outside the bounds of U_3, where we have $\psi > \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f$. Therefore, for the ℓ-type, the government faces two options:

- No contract (Region III): This leads to $\eta_\ell = 0$, resulting in the following expected government loss:

$$\mathcal{G}^{\mathrm{IC}}_{U_3}(\eta_h = 0, \eta_\ell = 0) = \zeta \cdot \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)(L_f + L_s)\right] + (1-\zeta)\cdot\gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)(L_f + L_s)\right]. \tag{A. 25}$$

- Mixed-strategy contract (Region II): This induces $\eta_\ell \in (0,1)$, enforced via inspection with probability $\lambda_\ell > 0$. The insurance contract $\Omega_\ell^{\mathrm{IC}} = \{E_\ell = 1, \pi_\ell, \phi_\ell\}$ must satisfy the feasibility conditions: $\phi_\ell \ge \frac{\kappa}{1-\mu_1}$, and $\phi_\ell \le L_f$. The equilibrium inspection and investment levels are: $\lambda_\ell = \frac{\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)(L_f-\phi_\ell)}{\gamma(1-\bar{s}_\ell)(1-\varphi)(1-\mu_1)\phi_\ell}$, $\eta_\ell = 1 - \frac{\kappa}{(1-\mu_1)\phi_\ell}$.

Substituting these into the cost functions, we obtain:

$$\mathcal{G}_h(\Omega_h^{\mathrm{IC}} \mid \lambda_h = 0, \eta_h = 0) = \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)(L_f + L_s)\right], \tag{A. 26}$$

$$\begin{aligned}\mathcal{G}_\ell(\Omega_\ell^{\mathrm{IC}} \mid \lambda_\ell > 0, \eta_\ell > 0) = -\pi_\ell + \gamma(1-\bar{s}_\ell)\cdot\Bigg(&L_n + (1-\rho)(L_f + L_s + \phi_\ell) + \frac{\kappa(\rho-\varphi)}{(1-\mu_1)\phi_\ell}(L_f + L_s + \phi_\ell)\\ &- \frac{(\rho-\varphi)\kappa\left[\psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)(L_f-\phi_\ell)\right]\left[(1-\mu_1)\phi_\ell - \kappa\right]}{\gamma(1-\bar{s}_\ell)(1-\varphi)(1-\mu_1)^2\phi_\ell^2}\Bigg).\end{aligned} \tag{A. 27}$$

$$\mathcal{F}_h(\Omega_h^{\mathrm{IC}} \mid \lambda_h = 0, \eta_h = 0) = \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right], \tag{A. 28}$$

$$\mathcal{F}_\ell(\Omega_\ell^{\mathrm{IC}} \mid \lambda_\ell > 0, \eta_\ell > 0) = \pi_\ell + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)(L_f - \phi_\ell)\right] + \psi. \tag{A. 29}$$

The outside option in the individual rationality (IR) constraints for the ℓ-type equals $\gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)L_f\right]$, and we can define the IR^ℓ constraint as:

$$\pi_\ell + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)(L_f - \phi_\ell)\right] + \psi \le \gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)L_f\right]. \tag{IR$^\ell$}$$

Thus, the complete optimization problem in Region U_3 can be then written as follows:

$$\begin{aligned}\min_{\pi_\ell,\phi_\ell}\quad \mathcal{G}^{\mathrm{IC}}_{U_3} &= \zeta\cdot\gamma(1-\bar{s}_h)\left[L_n+(1-\varphi)(L_f+L_s)\right]\\ &+(1-\zeta)\cdot\Bigg[-\pi_\ell+\gamma(1-\bar{s}_\ell)\Big(L_n+(1-\rho)(L_f+L_s+\phi_\ell)+\frac{\kappa(\rho-\varphi)}{(1-\mu_1)\phi_\ell}(L_f+L_s+\phi_\ell)\\ &\qquad-\frac{(\rho-\varphi)\kappa\left[\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)(L_f-\phi_\ell)\right]\left[(1-\mu_1)\phi_\ell-\kappa\right]}{\gamma(1-\bar{s}_\ell)(1-\varphi)(1-\mu_1)^2\phi_\ell^2}\Big)\Bigg]\end{aligned} \tag{A. 30}$$

Subject to:

$$\pi_\ell+\gamma(1-\bar{s}_\ell)\left[L_n+(1-\rho)(L_f-\phi_\ell)\right]+\psi\le\gamma(1-\bar{s}_\ell)\left[L_n+(1-\varphi)L_f\right] \tag{IR$^\ell$}$$

$$\phi_\ell\ge\frac{\kappa}{1-\mu_1},\qquad \phi_\ell<L_f \tag{Feasibility}$$

Note that the coefficient of π_ℓ in the objective function (A. 30) is –1, indicating that the objective function is strictly decreasing in π_ℓ. Therefore, to minimize the government's expected cost, the optimal value of π_ℓ must lie at its upper bound, given by: $\gamma(1-\bar{s}_\ell)\left[(1-\varphi)L_f-(1-\rho)(L_f-\phi_\ell)\right]-\psi$, based on IR^ℓ. This implies that the government prefers to set the insurance premium as high as possible within the admissible range. Furthermore, this upper bound also achieves its highest value when $\phi_\ell\in\left(\frac{\kappa}{1-\mu_1},L_f\right)$ takes its maximum level, i.e., L_f. Therefore the optimal value of decision variables under this contract are $\pi_\ell=\left[\gamma(1-\bar{s}_\ell)(1-\varphi)L_f-\psi\right]^+$, and $\phi_\ell=L_f$. However, in order to have feasible contract terms, we must ensure $\pi_\ell=\gamma(1-\bar{s}_\ell)(1-\varphi)L_f-\psi\ge0$, which implies that $\bar{s}_\ell\le1-\frac{\psi}{\gamma(1-\varphi)L_f}$ for the contract to be practical.

Next, the optimal insurance contract in Region U_3 is determined by comparing the government's expected cost under two scenarios. Specifically, the government prefers to induce security investment from the ℓ-type if $\mathcal{G}^{\mathrm{IC}}_{U_3}(\eta_h=0,\,\eta_\ell>0)\le\mathcal{G}^{\mathrm{IC}}_{U_3}(\eta_h=0,\,\eta_\ell=0)$, which holds when the internal security level satisfies $\bar{s}_\ell\le1-\frac{\psi-\frac{(\rho-\varphi)\kappa\cdot\psi\cdot\left[(1-\mu_1)L_f-\kappa\right]}{(1-\varphi)(1-\mu_1)^2L_f^2}}{\gamma(\rho-\varphi)\left(1-\frac{\kappa}{(1-\mu_1)L_f}\right)(2L_f+L_s)}$, which always holds when $\bar{s}_\ell\le1-\frac{\psi}{\gamma(1-\varphi)L_f}$.

Finally, if the h-type firm mimics the ℓ-type by selecting the contract $\Omega^{\mathrm{IC}}_\ell$, he would invest in security with probability $\tilde{\eta}_h$. The government, treating him as an ℓ-type, audits with probability $\lambda_\ell=\frac{\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)(L_f-\phi_\ell)}{\gamma(1-\bar{s}_\ell)(1-\varphi)(1-\mu_1)\phi_\ell}$. The h-type's expected cost under the deviated contract becomes:

$$\mathcal{F}_{h|\ell}(\Omega^{\mathrm{IC}}_\ell)=\pi_\ell+\tilde{\eta}_h\cdot\psi\left(1-\frac{1-\bar{s}_h}{1-\bar{s}_\ell}\right)+\psi\cdot\left(\frac{1-\bar{s}_h}{1-\bar{s}_\ell}\right)+\gamma(1-\bar{s}_h)\left[L_n+(1-\rho)(L_f-\phi_\ell)\right] \tag{A. 31}$$

By definition, we have $\bar{s}_h>\bar{s}_\ell$. Consequently, the coefficient of $\tilde{\eta}_h$ in Equation (A. 31), given by $\psi\left(1-\frac{1-\bar{s}_h}{1-\bar{s}_\ell}\right)$, is strictly positive. Hence, the h-type's optimal deviation strategy is $\tilde{\eta}_h=0$.

Therefore, if the h-type firm picks the contract designed for the ℓ-type, his loss will be $\pi_\ell+\psi\cdot\left(\frac{1-\bar{s}_h}{1-\bar{s}_\ell}\right)+\gamma(1-\bar{s}_h)\left[L_n+(1-\rho)(L_f-\phi_\ell)\right]$, instead of his outside option, which is $\gamma(1-\bar{s}_h)\left[L_n+(1-\varphi)L_f\right]$. The difference between these two, in optimality, equals $\frac{\bar{s}_h-\bar{s}_\ell}{1-\bar{s}_\ell}\left(\psi-\gamma(1-\bar{s}_\ell)(1-\varphi)L_f\right)$, which cannot be positive, as this would imply that the premium should be negative, which is impossible. Therefore, the h-type firm cannot gain any benefit by mimicking the ℓ-type, and it has no incentive to do so.

Optimal Insurance Contract in Region U_2:

In this region, the socially optimal solution requires both firm types to invest in security, i.e., $e_h^{\mathrm{SO}} = 1$ and $e_\ell^{\mathrm{SO}} = 1$. However, due to incentive limitations, a pure-strategy equilibrium with full compliance ($\eta_h = \eta_\ell = 1$) is not implementable under Region I of Proposition 3. Therefore, the government must choose among four possible contract options:

- Option 1: No Contract. The government does not offer any insurance contract, resulting in no investment by either firm type ($\eta_h = \eta_\ell = 0$). The government's expected cost in this case is:

$$\mathcal{G}_{U_2}^{\mathrm{IC}}(\eta_h = 0, \eta_\ell = 0) = \zeta \cdot \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)(L_f + L_s)\right] + (1-\zeta)\cdot\gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)(L_f + L_s)\right]. \tag{A. 32}$$

- Option 2: Contract for ℓ-type only. The government offers an insurance contract to the ℓ-type and not to the h-type. The ℓ-type firm invests under a mixed strategy (Region II), while the h-type shirks (Region III). The structure and cost of this option are identical to those in Region U_3, that is: $\mathcal{G}_{U_2}^{\mathrm{IC}}(\eta_h = 0, \eta_\ell > 0) = \mathcal{G}_{U_3}^{\mathrm{IC}}(\eta_h = 0, \eta_\ell > 0)$.
- Option 3: Contract for h-type only. The government designs a contract $\Omega_h^{\mathrm{IC}} = \{\pi_h, \phi_h\}$ to induce $\eta_h \in (0,1)$, supported by inspection with probability $\lambda_h > 0$. The feasibility conditions require: $\phi_h \geq \frac{\kappa}{1-\mu_1}$. Substituting equilibrium values of $\lambda_h = \frac{\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)(L_f-\phi_h)}{\gamma(1-\bar{s}_h)(1-\varphi)(1-\mu_1)\phi_h}$ and $\eta_h = 1 - \frac{\kappa}{(1-\mu_1)\phi_h}$, the cost expressions become:

$$\mathcal{G}_\ell(\Omega_\ell^{\mathrm{IC}} \mid \lambda_\ell = 0, \eta_\ell = 0) = \gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)(L_f + L_s)\right], \tag{A. 33}$$

$$\begin{aligned}\mathcal{G}_h(\Omega_h^{\mathrm{IC}} \mid \lambda_h > 0, \eta_h > 0) = -\pi_h + \gamma(1-\bar{s}_h)\cdot\Bigg(&L_n + (1-\rho)(L_f + L_s + \phi_h) + \frac{\kappa(\rho-\varphi)}{(1-\mu_1)\phi_h}(L_f + L_s + \phi_h)\\ &- \frac{(\rho-\varphi)\kappa\left[\psi - \gamma(1-\bar{s}_h)(\rho-\varphi)(L_f-\phi_h)\right]\left[(1-\mu_1)\phi_h - \kappa\right]}{\gamma(1-\bar{s}_h)(1-\varphi)(1-\mu_1)^2\phi_h^2}\Bigg),\end{aligned} \tag{A. 34}$$

$$\mathcal{F}_\ell(\Omega_\ell^{\mathrm{IC}} \mid \lambda_\ell = 0, \eta_\ell = 0) = \gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)L_f\right], \tag{A. 35}$$

$$\mathcal{F}_h(\Omega_h^{\mathrm{IC}} \mid \lambda_h > 0, \eta_h > 0) = \pi_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)(L_f - \phi_h)\right] + \psi. \tag{A. 36}$$

Because, in the *ungoverned decision*, the h-type firm does not exert effort, its outside option loss will be: $\mathcal{F}_h^{\mathrm{UN}} = \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right]$. Thus, the individual rationality (IR) constraint for the h-type firm in this situation can be written as:

$$\pi_h + \gamma(1-\bar{s}_h)\left[L_n + (1-\rho)(L_f - \phi_h)\right] + \psi \leq \gamma(1-\bar{s}_h)\left[L_n + (1-\varphi)L_f\right] \tag{A. 37}$$

Hence, for the h-type firm we have $\Omega_h^{\mathrm{IC}} \in \left\{\phi_h \geq \dfrac{\kappa}{1-\mu_1},\ \phi_h < L_f\right\}$. The complete optimization problem in Region U_1 can be then written as follows:

$$\min_{\pi_h, \phi_h} \quad \mathcal{G}_{U_1}^{\mathrm{IC}} = (1-\zeta)\cdot\gamma(1-\bar{s}_\ell)\left[L_n + (1-\varphi)(L_f + L_s)\right]$$

$$+\zeta\cdot\Bigg[-\pi_h+\gamma(1-\bar{s}_h)\cdot\Bigg(L_n+(1-\rho)(L_f+L_s+\phi_h)+\frac{\kappa(\rho-\varphi)}{(1-\mu_1)\phi_h}(L_f+L_s+\phi_h) - \frac{(\rho-\varphi)\kappa\left[\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)(L_f-\phi_h)\right]\left[(1-\mu_1)\phi_h-\kappa\right]}{\gamma(1-\bar{s}_h)(1-\varphi)(1-\mu_1)^2\phi_h^2}\Bigg)\Bigg] \tag{A. 38}$$

Subject to:

$$\pi_h+\gamma(1-\bar{s}_h)\left[L_n+(1-\rho)(L_f-\phi_h)\right]+\psi\leq\gamma(1-\bar{s}_h)\left[L_n+(1-\varphi)L_f\right] \tag{IR^h}$$

$$\frac{\kappa}{1-\mu_1}\leq\phi_h\leq L_f \tag{Feasibility}$$

Note that the coefficient of π_h in the objective function (A. 38) is –1, indicating that the objective function is strictly decreasing in π_h. Therefore, to minimize the government's expected cost, the optimal value of π_h must lie at its upper bound, given by: $\gamma(1-\bar{s}_h)\left[(1-\varphi)L_f-(1-\rho)(L_f-\phi_h)\right]-\psi$, based on the *IR*^{h}. This implies that the government prefers to set the insurance premium as high as possible within the admissible range. Furthermore, this upper bound also achieves its highest value when $\phi_h\in\left(\frac{\kappa}{1-\mu_1},L_f\right)$ takes its maximum level, i.e., L_f. Therefore, the optimal value of decision variables under this contract are $\pi_h=\left[\gamma(1-\bar{s}_h)(1-\varphi)L_f-\psi\right]^+$, and $\phi_h=L_f$. However, in order to have feasible contract terms, we must ensure $\pi_h=\gamma(1-\bar{s}_h)(1-\varphi)L_f-\psi\geq0$, which implies that $\bar{s}_h\leq1-\frac{\psi}{\gamma(1-\varphi)L_f}$ for the contract to be practical.

Finally, if the ℓ-type firm mimics the h-type by selecting the contract $\Omega_h^{\mathrm{IC}}=\{\pi_h,\phi_h\}$, he invests in security with probability $\tilde{\eta}_\ell$, and the government inspects with probability: $\lambda_h=\frac{\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)(L_f-\phi_h)}{\gamma(1-\bar{s}_h)(1-\varphi)(1-\mu_1)\phi_h}$. The firm's expected cost under the deviated contract is:

$$\mathcal{F}_{\ell\backslash h}(\Omega_h^{\mathrm{IC}})=\pi_h+\gamma(1-\bar{s}_\ell)\left[L_n+(1-\rho)(L_f-\phi_h)\right]+\tilde{\eta}_\ell\cdot\left(1-\frac{1-\bar{s}_\ell}{1-\bar{s}_h}\right)\psi+\left(\frac{1-\bar{s}_\ell}{1-\bar{s}_h}\right)\psi. \tag{A. 39}$$

Since by definition we have $\bar{s}_h>\bar{s}_\ell$, it follows that $1-\frac{1-\bar{s}_\ell}{1-\bar{s}_h}<0$. This implies that the coefficient of $\tilde{\eta}_\ell$ in Equation (A. 39), is strictly negative. Consequently, the ℓ-type firm can reduce its total cost when mimicking the h-type contract by choosing to *invest in security*, that is, by setting $\tilde{\eta}_\ell=1$.

Therefore, if the ℓ-type firm mimics the h-type, it incurs a loss of: $\pi_h+\gamma(1-\bar{s}_\ell)\left[L_n+(1-\rho)(L_f-\phi_h)\right]+\psi$, instead of its outside option: $\gamma(1-\bar{s}_\ell)\left[L_n+(1-\varphi)L_f\right]$. The difference between these two expressions in optimality is: $\gamma(\bar{s}_h-\bar{s}_\ell)(1-\varphi)L_f$, which represents the *information rent* that the government bears due to hidden firm types. As a result, because this amount is positive, the contract designed for the h-type is not incentive compatible, since the ℓ-type firm has a strict incentive to mimic the h-type. As, result, we have pooling contract, as both h- and ℓ- type firms will pick the same contract.

- Option 4: Contract for both types. The government offers contracts to both types, inducing a mixed-strategy equilibrium for each firm type (Region II of Proposition 3). This requires: $\Omega_\theta^{\mathrm{IC}}\in\left\{\phi_\theta\geq\frac{\kappa}{1-\mu_1},\ \phi_\theta<L_f\right\}$, $\theta\in\{h,\ell\}$ Under this setting, the mixed-strategy equilibrium conditions give:

$\lambda_\theta = \frac{\psi-\gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f-\phi_\theta)}{\gamma(1-\bar{s}_\theta)(1-\varphi)(1-\mu_1)\phi_\theta}$, $\eta_\theta = 1-\frac{\kappa}{(1-\mu_1)\phi_\theta}$ Substituting these into the government and firm cost functions (Eq. (A. 17) and Eq. (A. 29)), we obtain for each type $\theta \in \{h,\ell\}$:

$$\mathcal{G}_\theta(\Omega_\theta^{\mathrm{IC}} \mid \lambda_\theta,\eta_\theta) = -\pi_\theta + \gamma(1-\bar{s}_\theta)\Bigg(L_n + (1-\rho)(L_f+L_s+\phi_\theta) + \frac{\kappa(\rho-\varphi)}{(1-\mu_1)\phi_\theta}(L_f+L_s+\phi_\theta) - \frac{(\rho-\varphi)\kappa\cdot\left[\psi-\gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f-\phi_\theta)\right]\cdot\left[(1-\mu_1)\phi_\theta-\kappa\right]}{\gamma(1-\bar{s}_\theta)(1-\varphi)(1-\mu_1)^2\phi_\theta^2}\Bigg), \tag{A. 40}$$

$$\mathcal{F}_\theta(\Omega_\theta^{\mathrm{IC}} \mid \lambda_\theta,\eta_\theta) = \pi_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\rho)(L_f-\phi_\theta)\right] + \psi. \tag{A. 41}$$

If the ℓ-type firm mimics the h-type by selecting the contract intended for the h-type, he invests in security with probability $\tilde{\eta}_\ell$. Since the government believes the firm is of type h, it audits with probability $\lambda_h = \frac{\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)(L_f-\phi_h)}{\gamma(1-\bar{s}_h)(1-\varphi)(1-\mu_1)\phi_h}$. The ℓ-type's expected cost under the deviated contract Ω_h^{IC} is then given by:

$$\mathcal{F}_{\ell|h}(\Omega_h^{\mathrm{IC}} \mid \lambda_h,\tilde{\eta}_\ell) = \pi_h + \tilde{\eta}_\ell\cdot\psi\left(1-\frac{1-\bar{s}_\ell}{1-\bar{s}_h}\right) + \psi\cdot\left(\frac{1-\bar{s}_\ell}{1-\bar{s}_h}\right) + \gamma(1-\bar{s}_\ell)\left[L_n+(1-\rho)(L_f-\phi_h)\right]. \tag{A. 42}$$

Since by definition $\bar{s}_h > \bar{s}_\ell$, the coefficient $\left(1-\frac{1-\bar{s}_\ell}{1-\bar{s}_h}\right)$ is negative. Therefore, the ℓ-type prefers to exert effort (i.e., $\tilde{\eta}_\ell = 1$) when mimicking the h-type. Accordingly, Equation (A. 42) simplifies to:

$$\mathcal{F}_{\ell|h}(\Omega_h^{\mathrm{IC}}) = \pi_h + \psi + \gamma(1-\bar{s}_\ell)\left[L_n+(1-\rho)(L_f-\phi_h)\right] \tag{A. 43}$$

Similarly, if the h-type firm mimics the ℓ-type by selecting the contract intended for the ℓ-type, he invests in security with probability $\tilde{\eta}_h$. Since the government believes the firm is of type ℓ, it audits with probability $\lambda_\ell = \frac{\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)(L_f-\phi_\ell)}{\gamma(1-\bar{s}_\ell)(1-\varphi)(1-\mu_1)\phi_\ell}$. The h-type's expected cost under the deviated contract $\Omega_\ell^{\mathrm{IC}}$ is then given by:

$$\mathcal{F}_{h|\ell}(\Omega_\ell^{\mathrm{IC}} \mid \lambda_\ell,\tilde{\eta}_h) = \pi_\ell + \tilde{\eta}_h\cdot\psi\left(1-\frac{1-\bar{s}_h}{1-\bar{s}_\ell}\right) + \psi\cdot\left(\frac{1-\bar{s}_h}{1-\bar{s}_\ell}\right) + \gamma(1-\bar{s}_h)\left[L_n+(1-\rho)(L_f-\phi_\ell)\right]. \tag{A. 44}$$

Since $\bar{s}_h > \bar{s}_\ell$, we have $\frac{1-\bar{s}_h}{1-\bar{s}_\ell} < 1$, and therefore the coefficient $\left(1-\frac{1-\bar{s}_h}{1-\bar{s}_\ell}\right)$ is positive. As a result, the h-type firm strictly prefers not to exert effort (i.e., $\tilde{\eta}_h = 0$) when mimicking the ℓ-type. Substituting this into Equation (A. 44), the expression simplifies to:

$$\mathcal{F}_{h|\ell}(\Omega_\ell^{\mathrm{IC}}) = \pi_\ell + \psi\cdot\left(\frac{1-\bar{s}_h}{1-\bar{s}_\ell}\right) + \gamma(1-\bar{s}_h)\left[L_n+(1-\rho)(L_f-\phi_\ell)\right]. \tag{A. 45}$$

Finally, since in Region U_2 we have $\psi > \gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$ for both firm types $\theta \in \{\ell,h\}$, neither type finds it optimal to invest in security in the absence of a contract. Therefore, the outside option in the individual rationality (IR) constraints corresponds to zero investment. In this case, the firm's expected cost equals $\gamma(1-\bar{s}_\theta)\left[L_n+(1-\varphi)L_f\right]$, which defines the right-hand side of the IR constraint. Therefore, the governemrnt's optimization problem in Region U_2 (mixed strategy for both types) can be writen as follows:

$$\min_{\pi_h,\pi_\ell\,\phi_h,\phi_\ell} \quad \mathcal{G}_{U_2}^{\mathrm{IC}} = \zeta\cdot\Bigg[-\pi_h + \gamma(1-\bar{s}_h)\Bigg(L_n + (1-\rho)(L_f+L_s+\phi_h) + \frac{\kappa(\rho-\varphi)}{(1-\mu_1)\phi_h}(L_f+L_s+\phi_h)$$

$$
\begin{aligned}
&- \frac{(\rho-\varphi)\kappa\left[\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)(L_f-\phi_h)\right]\left[(1-\mu_1)\phi_h-\kappa\right]}{\gamma(1-\bar{s}_h)(1-\varphi)(1-\mu_1)^2\phi_h^2}\Bigg)\Bigg] \\
&+(1-\zeta)\cdot\Bigg[-\pi_\ell+\gamma(1-\bar{s}_\ell)\Bigg(L_n+(1-\rho)(L_f+L_s+\phi_\ell)+\frac{\kappa(\rho-\varphi)}{(1-\mu_1)\phi_\ell}(L_f+L_s+\phi_\ell) \\
&- \frac{(\rho-\varphi)\kappa\left[\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)(L_f-\phi_\ell)\right]\left[(1-\mu_1)\phi_\ell-\kappa\right]}{\gamma(1-\bar{s}_\ell)(1-\varphi)(1-\mu_1)^2\phi_\ell^2}\Bigg)\Bigg]
\end{aligned} \tag{A. 46}
$$

Subject to:

$$\pi_h+\gamma(1-\bar{s}_h)\left[L_n+(1-\rho)(L_f-\phi_h)\right]+\psi\leq\gamma(1-\bar{s}_h)\left[L_n+(1-\varphi)L_f\right] \tag{IR^h}$$

$$\pi_\ell+\gamma(1-\bar{s}_\ell)\left[L_n+(1-\rho)(L_f-\phi_\ell)\right]+\psi\leq\gamma(1-\bar{s}_\ell)\left[L_n+(1-\varphi)L_f\right] \tag{IR$^\ell$}$$

$$\pi_h+\gamma(1-\bar{s}_h)\left[L_n+(1-\rho)(L_f-\phi_h)\right]+\psi\leq\pi_\ell+\gamma(1-\bar{s}_h)\left[L_n+(1-\rho)(L_f-\phi_\ell)\right]+\left(\frac{1-\bar{s}_h}{1-\bar{s}_\ell}\right)\cdot\psi \tag{IC^h}$$

$$\pi_\ell+\gamma(1-\bar{s}_\ell)\left[L_n+(1-\rho)(L_f-\phi_\ell)\right]+\psi\leq\pi_h+\gamma(1-\bar{s}_\ell)\left[L_n+(1-\rho)(L_f-\phi_h)\right]+\psi \tag{IC$^\ell$}$$

$$\frac{\kappa}{1-\mu_1}\leq\phi_\theta\leq L_\theta,\quad \pi_\theta\leq\gamma(1-\bar{s}_\theta)\left[L_n+(1-\varphi)L_f\right]\quad \text{for all } \theta\in\{\ell,h\} \tag{Feasibility}$$

We now claim that, at the optimum, the *incentive compatibility constraint of the h-type* (IC^h) and the *individual rationality constraint of the ℓ-type* (IR$^\ell$) are binding. To see this, observe the following chain of inequalities:

$$
\begin{aligned}
\mathcal{F}_h(\Omega_h^{\mathrm{IC}}) &= \pi_h+\gamma(1-\bar{s}_h)\left[L_n+(1-\rho)(L_f-\phi_h)\right]+\psi \\
&\leq \pi_\ell+\gamma(1-\bar{s}_h)\left[L_n+(1-\rho)(L_f-\phi_\ell)\right]+\left(\frac{1-\bar{s}_h}{1-\bar{s}_\ell}\right)\cdot\psi && \text{(by IC^h)} \\
&\leq \pi_\ell+\gamma(1-\bar{s}_\ell)\left[L_n+(1-\rho)(L_f-\phi_\ell)\right]+\psi=\mathcal{F}_\ell(\Omega_\ell^{\mathrm{IC}}) && \text{(since $\bar{s}_h>\bar{s}_\ell$)} \\
&\leq \gamma(1-\bar{s}_\ell)\left[L_n+(1-\varphi)L_f\right] && \text{(by IR$^\ell$)}
\end{aligned}
$$

The last term represents the outside option cost of the ℓ-type in the absence of any contract. At the optimum, IR$^\ell$ must be binding-otherwise, the government could reduce its cost by increasing π_ℓ or decreasing ϕ_ℓ without violating incentive compatibility. Similarly, if IC^h were slack,then the government could construct a new contract by increasing π_h and decreasing ϕ_h, while still satisfying the IC^h constraint. The new contract would yield a strictly lower expected cost for the government, contradicting the optimality of the original contract. Hence, IC^h must bind at the optimum:

$$\pi_\ell=\gamma(1-\bar{s}_\ell)(1-\varphi)L_f-\gamma(1-\bar{s}_\ell)(1-\rho)(L_f-\phi_\ell)-\psi, \tag{A. 47}$$

$$\pi_h=\gamma(1-\bar{s}_\ell)(1-\varphi)L_f-\gamma(1-\bar{s}_\ell)(1-\rho)(L_f-\phi_\ell)+\gamma(1-\bar{s}_h)(1-\rho)(\phi_h-\phi_\ell)-\left(1+\frac{\bar{s}_h-\bar{s}_\ell}{1-\bar{s}_\ell}\right)\psi. \tag{A. 48}$$

Now, by Substituting (A. 47) and (A. 48) into the IR^h constraint, we obtain an upper bound for ϕ_ℓ:

$$\phi_\ell\leq\frac{\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f}{\gamma(1-\bar{s}_\ell)(1-\rho)}.$$

Similarly, substituting (A. 47) and (A. 48) into the IC$^{\ell}$ constraint and simplifying gives a lower bound for ϕ_ℓ:

$$\phi_\ell \geq \frac{\psi + \gamma(1-\bar{s}_\ell)(1-\rho)\phi_h}{\gamma(1-\bar{s}_\ell)(1-\rho)}.$$

For the problem to be feasible, we must have the lower bound (A. 49) less than or equal to the upper bound (A. 49), i.e.,

$$\frac{\psi - \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f}{\gamma(1-\bar{s}_\ell)(1-\rho)} \geq \frac{\psi + \gamma(1-\bar{s}_\ell)(1-\rho)\phi_h}{\gamma(1-\bar{s}_\ell)(1-\rho)}.$$

This simplifies to:

$$\phi_h \leq \frac{-(\rho-\varphi)L_f}{1-\rho}.$$

which contradicts the feasibility condition $\phi_h \geq \frac{\kappa}{1-\mu_1} > 0$. Therefore, there exists no feasible ϕ_h that satisfies the constraints, and this optimization problem in Region U_2 is infeasible.

Finally, the optimal contract in Region U_2 can be determined by comparing the government's expected loss across the feasible second-best alternatives. First, the pure-strategy outcome with no investment from either firm type, i.e., $\eta_h = \eta_\ell = 0$. Second, the government may induce a mixed-strategy equilibrium only for the ℓ-type, i.e., $\eta_\ell > 0$, $\eta_h = 0$. This setup is structurally identical to Region U_3. Third, the government may instead offer a mixed-strategy contract only to the h-type, i.e., $\eta_h > 0$, $\eta_\ell = 0$, which is structurally identical to Region U_1.

By comparing these three expected losses, the government can determine the most cost-effective strategy and partition Region U_2 into subregions where it is optimal to: (i) provide no contract at all, (ii) offer a contract only to the ℓ-type, or (iii) offer a contract only to the h-type. ■

Proof of Proposition 5. Let $\mathcal{O}_\theta \subset (0,1)$ be the set of $\bar{s}_\theta$ such that the *subsidy pooling* and *insurance pooling* contracts are both implementable (the overlap of their windows in left-hand panels in Tables 4–6). For each contractual mechanism $i \in \{\mathrm{SC}, \mathrm{IC}\}$, consider the definitions in Eqs. (10), (11), and (12). Using each contractual equilibrium in Propositions 2 and 4, we have:

Definitions.

(A1) **Subsidy pooling rules.** $\omega_\theta = \tau_\theta = \Delta_\theta$ with $\Delta_\theta = \psi - \gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$, and the mixed audit equilibrium

$$\eta_\theta^{\mathrm{SC}} = 1 - \frac{\kappa}{(1-\mu_{\mathrm{S}})\,\Delta_\theta}, \qquad \lambda_\theta^{\mathrm{SC}} = \min\left\{\frac{\Delta_\theta}{(1-\mu_{\mathrm{S}})\,\omega_\theta} = \frac{1}{1-\mu_{\mathrm{S}}}\right\} = 1.$$

Under definition (A1), the audit margin is budget balanced:

$$(1-\eta_\theta^{\mathrm{SC}})\lambda_\theta^{\mathrm{SC}}(1-\mu_{\mathrm{S}})\omega_\theta = \frac{\kappa}{(1-\mu_{\mathrm{S}})\Delta_\theta} \cdot 1 \cdot (1-\mu_{\mathrm{S}})\Delta_\theta = \kappa,$$

so $AC_\theta^{\mathrm{SC}} = \tau_\theta + \lambda_\theta^{\mathrm{SC}}(\kappa-\kappa) = \tau_\theta = \Delta_\theta$. Hence

$$\mathcal{E}_\theta^{\mathrm{SC}} = \frac{\gamma(1-\bar{s}_\theta)(\rho-\varphi)(L_f+L_s)\,(\eta_\theta^{\mathrm{SC}} - e_\theta^{\mathrm{UN}})_+}{\Delta_\theta}, \qquad \eta_\theta^{\mathrm{SC}} = 1 - \frac{\kappa}{(1-\mu_{\mathrm{S}})\Delta_\theta},$$

with $\frac{\partial \Delta_\theta}{\partial \bar{s}_\theta} = +\gamma(\rho-\varphi)L_f > 0$ and $\frac{\partial \eta_\theta^{\mathrm{SC}}}{\partial \bar{s}_\theta} > 0$. Thus as $\bar{s}_\theta$ increases, the numerator trades off a shrinking hazard factor $\gamma(1-\bar{s}_\theta)$ against a rising compliance $\eta_\theta^{\mathrm{SC}}$, while the denominator grows linearly in Δ_θ.

(A2) **Insurance pooling rules.** Recall the shirking incident probability as $p_\theta^0 = \gamma(1-\bar{s}_\theta)(1-\varphi)$. In the mixed inspection equilibrium, one can verify that the firm's IC takes the deterrence form in which prevention benefit plus expected claim denial (if shirking) must cover the investment cost:

$$\psi = \gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f + \lambda_\theta^{\mathrm{IC}}\,(1-\mu_1)\,p_\theta^0\,\phi_\theta,$$

or, since $\Delta_\theta = \psi - \gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f$, equivalently,

$$\lambda_\theta^{\mathrm{IC}} = \frac{\Delta_\theta}{(1-\mu_1)\,p_\theta^0\,\phi_\theta} = \frac{\psi-\gamma(1-\bar{s}_\theta)(\rho-\varphi)L_f}{(1-\mu_1)\,\gamma(1-\bar{s}_\theta)(1-\varphi)\,\phi_\theta}.$$

Therefore either (i) $\eta_\theta^{\mathrm{IC}}$ falls if $\lambda_\theta^{\mathrm{IC}}$ and ϕ_θ do not keep pace, depressing $\mathrm{PB}_\theta^{\mathrm{IC}}$, or (ii) inspection intensity and/or coverage scale up, which keeps $\mathrm{PB}_\theta^{\mathrm{IC}}$ from falling but pushes up $\mathrm{AC}_\theta^{\mathrm{IC}}$ via the inspection and coverage terms. In both cases, as $\bar{s}_\theta$ increases inside $\mathcal{O}_\theta$, we have that $\mathcal{E}_\theta^{\mathrm{IC}}$ is non-increasing: its numerator tends to decline with the shrinking hazard and weaker inducement, while its denominator cannot drop proportionally because the deterrence product $\lambda_\theta^{\mathrm{IC}} p_\theta^0 \phi_\theta$ must track the *increasing* Δ_θ.

Now compare

$$\frac{\mathcal{E}_\theta^{\mathrm{SC}}}{\mathcal{E}_\theta^{\mathrm{IC}}} = \frac{\mathrm{PB}_\theta^{\mathrm{SC}}}{\mathrm{PB}_\theta^{\mathrm{IC}}}\cdot\frac{\mathrm{AC}_\theta^{\mathrm{IC}}}{\mathrm{AC}_\theta^{\mathrm{SC}}} \quad = \quad \frac{\mathrm{PB}_\theta^{\mathrm{SC}}}{\mathrm{PB}_\theta^{\mathrm{IC}}}\cdot\frac{\mathrm{AC}_\theta^{\mathrm{IC}}}{\Delta_\theta}.$$

As $\bar{s}_\theta$ rises within $\mathcal{O}_\theta$, $\mathrm{PB}_\theta^{\mathrm{SC}}/\mathrm{PB}_\theta^{\mathrm{IC}}$ increases because $\eta_\theta^{\mathrm{SC}}$ rises while $\eta_\theta^{\mathrm{IC}}$ weakly falls; meanwhile $\mathrm{AC}_\theta^{\mathrm{IC}}/\Delta_\theta$ does not decline sufficiently (deterrence requires $\lambda_\theta^{\mathrm{IC}} p_\theta^0 \phi_\theta = \Delta_\theta$ as $p_\theta^0\downarrow$). Hence the ratio increases with $\bar{s}_\theta$, yielding a single crossing at $\bar{\bar{s}}_\theta$. This indicates that there exists $\bar{\bar{s}}_\theta \in \mathcal{O}_\theta$ such that:

$$\begin{aligned} &\text{if } \bar{s}_\theta \geq \bar{\bar{s}}_\theta, \quad \mathcal{E}_\theta^{\mathrm{SC}} \;\geq\; \mathcal{E}_\theta^{\mathrm{IC}},\\ &\text{if } \bar{s}_\theta \leq \bar{\bar{s}}_\theta, \quad \mathcal{E}_\theta^{\mathrm{IC}} \;\geq\; \mathcal{E}_\theta^{\mathrm{SC}}. \end{aligned}$$

Everything together, these yield $\mathcal{E}_\theta^{\mathrm{SC}} > \mathcal{E}_\theta^{\mathrm{IC}}$ at moderate-high $\bar{s}_\theta$ inside the overlap, even though $\mathrm{AC}_\theta^{\mathrm{SC}}$ rises with $\bar{s}_\theta$. Symmetrically, nearer to $\bar{s}_\theta^{UN}$ (low network security), p_θ^0 is large, the contingency lever is strong, $\eta_\theta^{\mathrm{IC}}$ is easier to sustain, and $\mathcal{E}_\theta^{\mathrm{IC}}$ tends to exceed $\mathcal{E}_\theta^{\mathrm{SC}}$.

Finally, weighting types by priors $\zeta_h = \zeta$, $\zeta_\ell = 1-\zeta$, the same ordering holds for the aggregate index $\mathcal{E}_{\mathrm{agg}}^m = \big(\sum_\theta \zeta_\theta PB_\theta\big)/\big(\sum_\theta \zeta_\theta AC_\theta^m\big)$ whenever $\bar{s}_h, \bar{s}_\ell$ lie on the same side of their respective thresholds $\bar{\bar{s}}_h, \bar{\bar{s}}_\ell$. ■

Proof of Proposition 6. Conditional on the firm's effort $e_\theta \in \{0,1\}$ and the audit outcome $\mathcal{A}_I \in \{0,1\}$, the firm's (top) and government's (bottom) costs are: According to the cost-profiles summarized in Table

Table 10 Firm's (Top) and Government's (Bottom) Costs in the Delayed-Inspection Hybrid Contract

Firm's Effort	Inspection $\mathcal{A}_I = 1$	No Inspection $\mathcal{A}_I = 0$
$e_\theta = 1$	$-\tau_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\rho)(L_f - \phi_\theta)\right] + \psi$ $\tau_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\rho)(L_f + L_s + \phi_\theta)\right] + \kappa$	$-\tau_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\rho)(L_f - \phi_\theta)\right] + \psi$ $\tau_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\rho)(L_f + L_s + \phi_\theta)\right]$
$e_\theta = 0$	$-\tau_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\varphi)(L_f - \mu_I\phi_\theta)\right]$ $\tau_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\varphi)(L_f + L_s + \mu_I\phi_\theta)\right] + \kappa$	$-\tau_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\varphi)(L_f - \phi_\theta)\right]$ $\tau_\theta + \gamma(1-\bar{s}_\theta)\left[L_n + (1-\varphi)(L_f + L_s + \phi_\theta)\right]$

9, averaging over the firm's compliance probability η_θ and the audit probability λ_θ yields closed-form expressions for the firm's and government's expected losses:

$$\begin{aligned}
\mathcal{F}_\theta^{\text{DA}} &= -\tau_\theta + \gamma\,(1-\bar{s}_\theta)\Big[L_n + (1-\varphi)\,(L_f - \phi_\theta) + \lambda_\theta\,(1-\varphi)\,(1-\mu_I)\,\phi_\theta\Big] \\
&\quad + \eta_\theta\Big[\psi - \gamma\,(1-\bar{s}_\theta)\,(\rho-\varphi)\,(L_f - \phi_\theta) - \lambda_\theta\,\gamma\,(1-\bar{s}_\theta)\,(1-\varphi)\,(1-\mu_I)\,\phi_\theta\Big], && \text{(A. 49)} \\
\mathcal{G}_\theta^{\text{DA}} &= \tau_\theta + \gamma\,(1-\bar{s}_\theta)\Big[L_n + \big((1-\varphi) - \eta_\theta(\rho-\varphi)\big)\,(L_f + L_s + \phi_\theta)\Big] \\
&\quad + \lambda_\theta\Big[\kappa - (1-\eta_\theta)\,\gamma\,(1-\bar{s}_\theta)\,(1-\varphi)\,(1-\mu_I)\,\phi_\theta\Big]. && \text{(A. 50)}
\end{aligned}$$

Because the algebra and logic mirror the earlier proofs step-by-step, we omit the redundant details here. Accordingly, we summarize the three possible equilibrium regimes in the delayed-audit hybrid contract as follows:

PROPOSITION 8. *Let the delayed-audit hybrid contract be parameterized by $\{\tau_\theta, \phi_\theta\}$. Then the audit game admits a unique Nash equilibrium in one of three regimes:*

Region I: A pure-strategy equilibrium $\eta_\theta = 1,\ \lambda_\theta = 0$ exists if and only if $\psi \le \gamma\,(1-\bar{s}_\theta)\,(\rho-\varphi)\,(L_f - \phi_\theta)$.

Region II: There is an interior mixed-strategy equilibrium with $\eta_\theta = 1 - \frac{\kappa}{\gamma\,(1-\bar{s}_\theta)\,(1-\varphi)\,(1-\mu_I)\,\phi_\theta}$, $\lambda_\theta = \dfrac{\psi - \gamma\,(1-\bar{s}_\theta)\,(\rho-\varphi)\,(L_f - \phi_\theta)}{\gamma\,(1-\bar{s}_\theta)\,(1-\varphi)\,(1-\mu_I)\,\phi_\theta}$, if and only if $\psi > \gamma\,(1-\bar{s}_\theta)\,(\rho-\varphi)\,(L_f - \phi_\theta)$ and $\kappa < \gamma\,(1-\bar{s}_\theta)\,(1-\varphi)\,(1-\mu_I)\,\phi_\theta$.

Region III: A pure-strategy equilibrium $\eta_\theta = 0,\ \lambda_\theta = 0$ exists if and only if $\psi > \gamma\,(1-\bar{s}_\theta)\,(\rho-\varphi)\,(L_f - \phi_\theta)$ and $\kappa \ge \gamma\,(1-\bar{s}_\theta)\,(1-\varphi)\,(1-\mu_I)\,\phi_\theta$.

We can now solve for the government contract design problem.

- *Optimal Delayed-Audit Hybrid Contract in Region U_1*:

In region U_1 the socially optimal solution requires both types to invest, $e_\ell = e_h = 1$. Since the ℓ-type already invests without intervention, we solely focus on the h-type. A full-compliance pure equilibrium ($\eta_h = 1,\ \lambda_h = 0$) would require $\psi \le \gamma\,(1-\bar{s}_h)\,(\rho-\varphi)\,(L_f - \phi_h)$, but by definition of U_1 we have $\psi > \gamma(1-\bar{s}_h)(\rho-\varphi)\,L_f$, so pure full compliance cannot be implemented. The planner therefore compares:

Option 1: No contract. $\eta_h = 0$, $\eta_\ell = 1$. Then

$$\mathcal{G}_{U_1}^{\text{DA}}(\eta_h = 0, \eta_\ell = 1) = \zeta\,\gamma(1-\bar{s}_h)\big[L_n + (1-\varphi)(L_f + L_s)\big] + (1-\zeta)\,\gamma(1-\bar{s}_\ell)\big[L_n + (1-\rho)(L_f + L_s)\big].$$

Option 2: Mixed-strategy contract for h. Offer $\Omega_h^{\mathrm{DA}}=\{\tau_h,\phi_h\}$, inducing $\eta_h = 1 - \frac{\kappa}{\gamma(1-\bar{s}_h)(1-\varphi)(1-\mu_I)\,\phi_h}$, $\lambda_h = \frac{\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)(L_f-\phi_h)}{\gamma(1-\bar{s}_h)(1-\varphi)(1-\mu_I)\,\phi_h}$. Substitution into the cost-loss functions yields

$$\mathcal{G}_\ell^{\mathrm{DA}}(\lambda_\ell=0,\eta_\ell=1)=\gamma(1-\bar{s}_\ell)\big[L_n+(1-\rho)(L_f+L_s)\big], \tag{A. 51}$$

$$\mathcal{G}_h^{\mathrm{DA}}(\lambda_h>0,\eta_h>0)=\tau_h+\gamma(1-\bar{s}_h)\big[L_n+(1-\rho)(L_f+L_s+\phi_h)\big]+\frac{\kappa\,(\rho-\varphi)\,(L_f+L_s+\phi_h)}{(1-\mu_I)\,(1-\varphi)\,\phi_h}, \tag{A. 52}$$

$$\mathcal{F}_\ell^{\mathrm{DA}}(\lambda_\ell=0,\eta_\ell=1)=\gamma(1-\bar{s}_\ell)\big[L_n+(1-\rho)L_f\big]+\psi, \tag{A. 53}$$

$$\mathcal{F}_h^{\mathrm{DA}}(\lambda_h>0,\eta_h>0)=-\tau_h+\gamma(1-\bar{s}_h)\big[L_n+(1-\rho)(L_f-\phi_h)\big]+\psi. \tag{A. 54}$$

Because in the ungoverned decision the h-type firm exerts no effort, its outside-option loss is $\mathcal{F}_h^{\mathrm{UN}}=\gamma(1-\bar{s}_h)\big[L_n+(1-\varphi)\,L_f\big]$, which serves as the right-hand side of its individual-rationality constraint. Under the delayed-audit hybrid contract (parameters τ_h,ϕ_h), and in the mixed-strategy equilibrium ($\lambda_h>0,\eta_h>0$), its expected cost is $\mathcal{F}_h^{\mathrm{DA}}=-\tau_h+\gamma(1-\bar{s}_h)\big[L_n+(1-\rho)\,(L_f-\phi_h)\big]+\psi$. Hence the h-type's IR constraint is:

$$-\tau_h+\gamma(1-\bar{s}_h)\big[L_n+(1-\rho)\,(L_f-\phi_h)\big]+\psi\;\le\;\gamma(1-\bar{s}_h)\big[L_n+(1-\varphi)\,L_f\big]. \tag{A. 55}$$

Therefore, the government's optimization problem in Region U_1 is to choose τ_h,ϕ_h to minimize:

$$\begin{aligned}\min_{\tau_h,\phi_h}\;\mathcal{G}_{U_1}^{\mathrm{DA}}=&\;(1-\zeta)\,\gamma\,(1-\bar{s}_\ell)\big[L_n+(1-\rho)\,(L_f+L_s)\big]\\&+\;\zeta\left\{\tau_h+\gamma\,(1-\bar{s}_h)\big[L_n+(1-\rho)\,(L_f+L_s+\phi_h)\big]+\;\frac{\kappa\,(\rho-\varphi)\,\big(L_f+L_s+\phi_h\big)}{(1-\varphi)\,(1-\mu_I)\,\phi_h}\right\}.\end{aligned} \tag{A. 56}$$

subject to

$$-\tau_h+\gamma(1-\bar{s}_h)\big[L_n+(1-\rho)\,(L_f-\phi_h)\big]+\psi\;\le\;\gamma(1-\bar{s}_h)\big[L_n+(1-\varphi)\,L_f\big], \tag{IR^h}$$

$$0\;\le\;\tau_h,\quad 0\;\le\;\phi_h\;<\;L_f,\quad \kappa\;\le\;\gamma\,(1-\bar{s}_h)\,(1-\varphi)\,(1-\mu_I)\,\phi_h. \tag{Feasibility}$$

The objective is strictly increasing in τ_h, so the unique minimizer is $\tau_h^*\;=\;0$. Substituting $\tau_h=0$ back into the objective reduces the planner's problem to

$$G(\phi_h)=C+\zeta\Big[\gamma(1-\bar{s}_h)\big(L_n+(1-\rho)(L_f+L_s+\phi_h)\big)+\frac{\kappa(\rho-\varphi)\,(L_f+L_s+\phi_h)}{(1-\varphi)\,(1-\mu_I)\,\phi_h}\Big],$$

where C is constant in ϕ_h. Taking the derivative with respect to ϕ_h gives $\frac{dG}{d\phi_h}=\zeta\Big[\gamma(1-\bar{s}_h)(1-\rho)-\frac{\kappa(\rho-\varphi)\,(L_f+L_s)}{(1-\varphi)\,(1-\mu_I)\,\phi_h^2}\Big]$. Setting this equal to zero yields the interior candidate $\phi_h^*=\sqrt{\frac{\kappa(\rho-\varphi)\,(L_f+L_s)}{\gamma\,(1-\bar{s}_h)\,(1-\varphi)\,(1-\rho)\,(1-\mu_I)}}$. Moreover, the second derivative $\frac{d^2G}{d\phi_h^2}=\zeta\,\frac{2\,\kappa(\rho-\varphi)\,(L_f+L_s)}{(1-\varphi)\,(1-\mu_I)\,\phi_h^3}$ is strictly positive for all $\phi_h>0$, so G is strictly convex and ϕ_h^* is its unique global minimizer on $(0,L_f)$. It is also verified that this τ_h^* and ϕ_h^* satisfies both the feasibility and the IR constraints. Hence, η_h^* and λ_h^* will be updated as:

$$\eta_h^*=1-\sqrt{\frac{\kappa\,(1-\rho)}{\gamma\,(1-\bar{s}_h)\,(1-\varphi)\,(1-\mu_I)\,(\rho-\varphi)\,(L_f+L_s)}}\,,$$

$$\lambda_h^* = \frac{\psi - \gamma\,(1-\bar{s}_h)\,(\rho-\varphi)\,L_f + (\rho-\varphi)\sqrt{\dfrac{\gamma\,(1-\bar{s}_h)\,\kappa\,(\rho-\varphi)\,(L_f+L_s)}{(1-\varphi)\,(1-\rho)\,(1-\mu_I)}}}{\sqrt{\dfrac{\gamma\,(1-\bar{s}_h)\,(1-\varphi)\,(1-\mu_I)\,\kappa\,(\rho-\varphi)\,(L_f+L_s)}{1-\rho}}}\,.$$

Now, suppose the ℓ-type firm mimics the h-type and accepts the delayed-audit contract $\Omega_h^{\mathrm{DA}} = \{\tau_h, \phi_h\}$. Believing the firm is of type h, the government audits with probability $\lambda_h = \frac{\psi-\gamma\,(1-\bar{s}_h)\,(\rho-\varphi)\,(L_f-\phi_h)}{\gamma\,(1-\bar{s}_h)\,(1-\varphi)\,(1-\mu_I)\,\phi_h}$. Let $\tilde{\eta}_\ell$ denote the effort probability of the mimicking ℓ-type. Its expected cost is

$$\mathcal{F}_{\ell\backslash h}^{\mathrm{DA}} = -\tau_h + \gamma(1-\bar{s}_\ell)\big[L_n + (1-\rho)\,(L_f-\phi_h)\big] + \frac{1-\bar{s}_\ell}{1-\bar{s}_h}\,\psi - \tilde{\eta}_\ell\,\frac{\bar{s}_h-\bar{s}_\ell}{1-\bar{s}_h}\,\psi.$$

Since $\bar{s}_\ell < \bar{s}_h$, the coefficient of $\tilde{\eta}_\ell$ is negative. Therefore, the ℓ-type strictly prefers to exert effort under the deviated contract, i.e., $\tilde{\eta}_\ell = 1$. Substituting $\tilde{\eta}_\ell = 1$, the deviated cost simplifies to: $\mathcal{F}_{\ell\backslash h}^{\mathrm{DA}} = -\tau_h + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)(L_f-\phi_h)\right] + \psi$ Therefore, if the ℓ-type firm mimics the h-type, it incurs a loss of: $-\tau_h + \gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)(L_f-\phi_h)\right] + \psi$, instead of its outside option: $\gamma(1-\bar{s}_\ell)\left[L_n + (1-\rho)L_f\right] + \psi$. The difference between these two expressions is exactly: $\tau_h + \gamma(1-\bar{s}_\ell)(1-\rho)\phi_h$, which represents the *information rent* that the government bears due to hidden firm types. Under the optimal contract design, this rent equals: $(1-\bar{s}_\ell)\sqrt{\frac{\gamma\,(1-\rho)\,(\rho-\varphi)\,(L_f+L_s)\,\kappa}{(1-\bar{s}_h)\,(1-\varphi)\,(1-\mu_I)}}$. Because this amount is positive, the contract designed for the h-type is not incentive compatible, since the ℓ-type firm has a strict incentive to mimic the h-type. As, result, we have pooling contract, as both h- and ℓ- type firms will pick the same contract.

Next, in Region U_1 the planner compares $\mathcal{G}_{U_1}^{\mathrm{DA}}(\eta_h > 0,\ \eta_\ell > 0) \le \mathcal{G}_{U_1}^{\mathrm{DA}}(\eta_h = 0,\ \eta_\ell = 1)$ to identify the parameter region where it is profitable for the government to offer the hybrid contract.

Optimal Delayed-Audit Hybrid Contract in Region U_3:

In this region, the socially optimal policy requires only the ℓ-type firm to invest in security, i.e. $e_\ell^{\mathrm{so}} = 1$ and $e_h^{\mathrm{so}} = 0$. Therefore, the planner seeks to induce effort only from the ℓ-type via a delayed-audit hybrid contract, while allowing the h-type to shirk under no contract.

A pure-compliance equilibrium ($\eta_\ell = 1, \lambda_\ell = 0$) would require $\psi \le \gamma\,(1-\bar{s}_\ell)\,(\rho-\varphi)\,(L_f-\phi_\ell)$, but in U_3 we have $\psi > \gamma(1-\bar{s}_\ell)(\rho-\varphi)L_f$. Thus the planner compares:

- No contract (Region III): $\eta_\ell = 0,\ \lambda_\ell = 0$, which is:

$$\mathcal{G}_{U_3}^{\mathrm{DA}}(\eta_h = 0, \eta_\ell = 0) = \zeta\,\gamma\,(1-\bar{s}_h)\big[L_n + (1-\varphi)(L_f+L_s)\big] + (1-\zeta)\,\gamma\,(1-\bar{s}_\ell)\big[L_n + (1-\varphi)(L_f+L_s)\big].$$

- Mixed-strategy hybrid contract (Region II): Offer $\Omega_\ell^{\mathrm{DA}} = \{E_\ell = 1,\ \tau_\ell,\ \phi_\ell\}$. Thus, in equilibrium:

$$\eta_\ell = 1 - \frac{\kappa}{\gamma\,(1-\bar{s}_\ell)\,(1-\varphi)\,(1-\mu_I)\,\phi_\ell}, \quad \lambda_\ell = \frac{\psi-\gamma\,(1-\bar{s}_\ell)\,(\rho-\varphi)\,(L_f-\phi_\ell)}{\gamma\,(1-\bar{s}_\ell)\,(1-\varphi)\,(1-\mu_I)\,\phi_\ell}.$$

Substituting into the delayed-audit cost functions yields:

$$\mathcal{G}_h^{\mathrm{DA}}(\lambda_h=0,\eta_h=0)=\gamma\,(1-\bar{s}_h)\big[L_n+(1-\varphi)(L_f+L_s)\big], \tag{A. 57}$$

$$\mathcal{G}_\ell^{\mathrm{DA}}(\lambda_\ell>0,\eta_\ell>0)=\tau_\ell+\gamma(1-\bar{s}_\ell)\big[L_n+(1-\rho)(L_f+L_s+\phi_\ell)\big]+\frac{\kappa\,(\rho-\varphi)\,(L_f+L_s+\phi_\ell)}{(1-\mu_I)\,(1-\varphi)\,\phi_\ell}, \tag{A. 58}$$

$$\mathcal{F}_h^{\mathrm{DA}}(\lambda_h=0,\eta_h=0)=\gamma\,(1-\bar{s}_h)\big[L_n+(1-\varphi)L_f\big], \tag{A. 59}$$

$$\mathcal{F}_\ell^{\mathrm{DA}}(\lambda_\ell>0,\eta_\ell>0)=-\tau_\ell+\gamma\,(1-\bar{s}_\ell)\big[L_n+(1-\rho)(L_f-\phi_\ell)\big]+\psi. \tag{A. 60}$$

Moreover, outside option for ℓ-type is $\mathcal{F}_\ell^{\mathrm{UN}}=\gamma\,(1-\bar{s}_\ell)\big[L_n+(1-\varphi)L_f\big]$. Hence the IR constraint for the ℓ-type under the hybrid contract will be:

$$-\tau_\ell+\gamma\,(1-\bar{s}_\ell)\big[L_n+(1-\rho)(L_f-\phi_\ell)\big]+\psi\;\le\;\gamma\,(1-\bar{s}_\ell)\big[L_n+(1-\varphi)L_f\big].$$

Accordingly, the government's optimization problem in Region U_3 is:

$$\begin{aligned}
\min_{\tau_\ell,\phi_\ell}\ \mathcal{G}_{U_3}^{\mathrm{DA}}=\ &\zeta\,\gamma\,(1-\bar{s}_h)\big[L_n+(1-\varphi)\,(L_f+L_s)\big]\\
&+\ (1-\zeta)\Big\{\tau_\ell+\gamma\,(1-\bar{s}_\ell)\big[L_n+(1-\rho)\,(L_f+L_s+\phi_\ell)\big]+\frac{\kappa\,(\rho-\varphi)\,(L_f+L_s+\phi_\ell)}{(1-\varphi)\,(1-\mu_I)\,\phi_\ell}\Big\}, && \text{(A. 61)}\\
\text{s.t.}\quad &-\tau_\ell+\gamma\,(1-\bar{s}_\ell)\big[L_n+(1-\rho)\,(L_f-\phi_\ell)\big]+\psi\;\le\;\gamma\,(1-\bar{s}_\ell)\big[L_n+(1-\varphi)\,L_f\big], && (\mathrm{IR}^\ell)\\
&0\;\le\;\tau_\ell,\quad 0<\phi_\ell\le L_f,\quad \phi_\ell\;\ge\;\frac{\kappa}{\gamma\,(1-\bar{s}_\ell)\,(1-\varphi)\,(1-\mu_I)}. && \text{(Feasibility)}
\end{aligned}$$

First, note that $\frac{\partial\mathcal{G}_{U_3}^{\mathrm{DA}}}{\partial\tau_\ell}=1-\zeta>0$, so the objective is strictly increasing in τ_ℓ and its minimizer is $\tau_\ell^*=0$. With $\tau_\ell=0$, we define

$$G(\phi)=C+(1-\zeta)\Big\{\gamma(1-\bar{s}_\ell)\big[L_n+(1-\rho)(L_f+L_s+\phi)\big]+\frac{\kappa(\rho-\varphi)(L_f+L_s+\phi)}{(1-\varphi)(1-\mu_I)\,\phi}\Big\},$$

where C is constant. Differentiating with respect to ϕ gives $\frac{dG}{d\phi}=(1-\zeta)\Big[\gamma(1-\bar{s}_\ell)(1-\rho)-\frac{\kappa(\rho-\varphi)(L_f+L_s)}{(1-\varphi)(1-\mu_I)\,\phi^2}\Big]$. Setting this to zero yields the interior critical point $\phi^{CP}=\sqrt{\frac{\kappa\,(\rho-\varphi)\,(L_f+L_s)}{\gamma(1-\bar{s}_\ell)(1-\rho)(1-\varphi)(1-\mu_I)}}$. Next, the IR constraint (IR^ℓ) with $\tau_\ell=0$ can be rewritten as $\gamma(1-\bar{s}_\ell)\big[L_n+(1-\rho)(L_f-\phi)\big]+\psi\;\le\;\gamma(1-\bar{s}_\ell)\big[L_n+(1-\varphi)L_f\big]$, which rearranges to

$$\phi\;\ge\;\frac{\psi/[\gamma(1-\bar{s}_\ell)]\;-\;(\rho-\varphi)L_f}{1-\rho}=:\phi_{IR}.$$

One checks that $\phi^{CP}<\phi_{IR}$. Moreover, for all $\phi>\phi^{CP}$ we have $\frac{dG}{d\phi}>0$, so $G(\phi)$ is increasing on $[\phi_{IR},\infty)$. Hence the constrained minimum occurs at the endpoint $\phi_\ell^*=\phi_{IR}$. Combining these yields $(\tau_\ell^*,\phi_\ell^*)=\Big(0,\frac{\psi-\gamma\,(1-\bar{s}_\ell)(\rho-\varphi)\,L_f}{\gamma\,(1-\bar{s}_\ell)\,(1-\rho)}\Big)$, Now the optimal value of λ_ℓ and η_ℓ will be: $\eta_\ell^*=1-\frac{\kappa\,(1-\rho)}{(1-\varphi)\,(1-\mu_I)\,\big[\psi-\gamma\,(1-\bar{s}_\ell)\,(\rho-\varphi)\,L_f\big]}$ and $\lambda_\ell^*=\frac{1}{1-\mu_I}$.

Now, suppose the h-type firm mimics the ℓ-type by selecting the delayed-audit contract $\Omega_\ell^{\mathrm{DA}}=\{E_\ell=1,\ \tau_\ell,\ \phi_\ell\}$. Believing the firm is of type ℓ, the government audits with probability $\lambda_\ell=\frac{\psi-\gamma(1-\bar{s}_\ell)(\rho-\varphi)(L_f-\phi_\ell)}{\gamma(1-\bar{s}_\ell)\,(1-\varphi)\,(1-\mu_I)\,\phi_\ell}$. Let $\tilde{\eta}_h$ denote the h-type's effort probability under deviated contract. His expected cost after mimicking is:

$$\mathcal{F}_{h|\ell}^{\mathrm{DA}}=\gamma(1-\bar{s}_h)\big[L_n+(1-\rho)(L_f-\phi_\ell)\big]+\frac{1-\bar{s}_h}{1-\bar{s}_\ell}\,\psi-\tilde{\eta}_h\,\psi\Big(1-\tfrac{1-\bar{s}_h}{1-\bar{s}_\ell}\Big).$$

Since $\frac{1-\bar{s}_h}{1-\bar{s}_\ell} < 1$, the coefficient of $\tilde{\eta}_h$ is positive, so the h-type's best response is $\tilde{\eta}_h^* = 0$. Substituting it back we have $\mathcal{F}_{h|\ell}^{\mathrm{DA}} = \gamma(1-\bar{s}_h)\big[L_n + (1-\rho)(L_f - \phi_\ell)\big] + \frac{1-\bar{s}_h}{1-\bar{s}_\ell}\,\psi$, while his outside option remains $\mathcal{F}_h^{\mathrm{UN}} = \gamma(1-\bar{s}_h)\big[L_n + (1-\varphi)L_f\big]$. Hence the gain from deviation is $\Delta = \mathcal{F}_h^{\mathrm{UN}} - \mathcal{F}_{h|\ell}^{\mathrm{DA}} = \frac{1-\bar{s}_h}{1-\bar{s}_\ell}\Big[\psi - \gamma(1-\bar{s}_\ell)\big[(\rho-\varphi)L_f + (1-\rho)\phi_\ell\big]\Big]$, and by substituting the optimal $\phi_\ell^* = \frac{\psi-\gamma\,(1-\bar{s}_\ell)(\rho-\varphi)\,L_f}{\gamma\,(1-\bar{s}_\ell)\,(1-\rho)}$, the information rent will be $\Delta = 0$, showing that the h-type has no incentive to mimic the ℓ-type.

Optimal Delayed-Audit Hybrid Contract in Region U_2:

In Region U_2, the social planner's first-best requires both firms to invest ($e_h = e_\ell = 1$). However, by definition of U_2, $\psi > \gamma\,(1-\bar{s}_\theta)\,(\rho-\varphi)\,L_f$ for each $\theta \in \{h, \ell\}$, so no pure-strategy equilibrium with $\eta_\theta = 1,\ \lambda_\theta = 0$ is feasible. The government therefore has four candidate policies:

- No contract for either type: Both firms shirk and no audits occur.
- Contract only for the high-risk type: This case is identical to the Region U_1 analysis.
- Contract only for the low-risk type: This case is identical to the Region U_3 analysis.
- Contract for both types: One can check (by writing both IR and IC constraints) that no feasible solution exists under Region U_2 parameters.

Finally, to compare the effectiveness of the hybrid contract relative to the subsidy and insurance contracts, we derive the condition under which the firm's compliance probability is higher under the hybrid contract. In Regions where the government provides contract for ℓ-type we have:

$$\eta_\ell^{DH} = 1 - \frac{\kappa\,(1-\rho)}{(1-\varphi)\,(1-\mu_I)\,\big[\psi - \gamma\,(1-\bar{s}_\ell)\,(\rho-\varphi)\,L_f\big]}\,,$$
$$\eta_\ell^{\mathrm{SC}} = 1 - \frac{\kappa}{(1-\mu_s)\,\big[\psi - \gamma\,(1-\bar{s}_\ell)\,(\rho-\varphi)\,L_f\big]}\,,$$
$$\eta_\ell^{\mathrm{IC}} = 1 - \frac{\kappa}{(1-\mu_I)\,L_f}\,.$$

Hybrid contract outperforms the Subsidy contract in inducing the ℓ-type firm's compliance whenever $\eta_\ell^{\mathrm{DH}} \geq \eta_\ell^{\mathrm{SC}}$, which simplifies to $(1-\rho)\,(1-\mu_S) \leq (1-\varphi)\,(1-\mu_H)$. Assuming equal audit-error rates $\mu_S = \mu_I = \mu_H = \mu$, this reduces to $\rho \geq \varphi$. In other words, the Hybrid contract always achieves higher compliance than a pure Subsidy for the areas related to ℓ-type contract. Similarly, Hybrid contract outperforms the Insurance whenever $\eta_\ell^{\mathrm{HC}} \geq \eta_\ell^{\mathrm{IC}}$ which results in $\psi \geq \gamma\,(1-\bar{s}_\ell)\,(\rho-\varphi)\,L_f + \dfrac{1-\rho}{1-\varphi}\,L_f$.

Moreover, in Regions where the government provides contract for h-type we have:

$$\eta_h^{DH} = 1 - \sqrt{\frac{\kappa\,(1-\rho)}{\gamma\,(1-\bar{s}_h)\,(1-\varphi)\,(1-\mu_I)\,(\rho-\varphi)\,(L_f + L_s)}},$$
$$\eta_\ell^{\mathrm{SC}} = 1 - \frac{\kappa}{(1-\mu_s)\,\big[\psi - \gamma\,(1-\bar{s}_\ell)\,(\rho-\varphi)\,L_f\big]}\,,$$
$$\eta_\ell^{\mathrm{IC}} = 1 - \frac{\kappa}{(1-\mu_I)\,L_f}\,.$$

Hybrid contract outperforms the subsidy contract in inducing the h-type firm's compliance whenever $\eta_\ell^{\mathrm{DH}} \geq \eta_\ell^{\mathrm{SC}}$, which simplifies to $\kappa \geq \dfrac{(1-\rho)(1-\mu_s)\left[\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f\right]^2}{\gamma(1-\bar{s}_h)(1-\varphi)(\rho-\varphi)(L_f+L_s)}$. Similarly, hybrid contract outperforms the insurance whenever $\eta_\ell^{\mathrm{DH}} \geq \eta_\ell^{\mathrm{IC}}$ which results in $\kappa \geq \dfrac{(1-\rho)(1-\mu_s)\left[\psi-\gamma(1-\bar{s}_h)(\rho-\varphi)L_f\right]^2}{\gamma(1-\bar{s}_h)(1-\varphi)(\rho-\varphi)(L_f+L_s)}$. ∎

Proof of Proposition 7 Table 11 summarizes the resulting expected costs for both the firm (top entries) and the government (bottom entries) under each combination of effort and audit decisions. Summing the payoffs

Table 11 Firm's (top) and Government's (bottom) Costs in the Early-Audit Hybrid Contract

Firm's effort	Audit $\mathcal{A}=1$	No audit $\mathcal{A}=0$
$e_\theta=1$	$-\tau_\theta+\gamma(1-\bar{s}_\theta)\big[L_n+(1-\rho)(L_f-\phi_\theta)\big]+\psi$	$-\tau_\theta+\gamma(1-\bar{s}_\theta)\big[L_n+(1-\rho)(L_f-\phi_\theta)\big]+\psi$
	$\tau_\theta+\gamma(1-\bar{s}_\theta)\big[L_n+(1-\rho)(L_f+L_s+\phi_\theta)\big]+\kappa$	$\tau_\theta+\gamma(1-\bar{s}_\theta)\big[L_n+(1-\rho)(L_f+L_s+\phi_\theta)\big]$
$e_\theta=0$	$-\mu_S\,\tau_\theta+\gamma(1-\bar{s}_\theta)\big[L_n+(1-\varphi)(L_f-\mu_S\,\phi_\theta)\big]$	$-\tau_\theta+\gamma(1-\bar{s}_\theta)\big[L_n+(1-\varphi)(L_f-\phi_\theta)\big]$
	$\mu_S\,\tau_\theta+\gamma(1-\bar{s}_\theta)\big[L_n+(1-\varphi)(L_f+L_s+\mu_S\,\phi_\theta)\big]+\kappa$	$\tau_\theta+\gamma(1-\bar{s}_\theta)\big[L_n+(1-\varphi)(L_f+L_s+\phi_\theta)\big]$

in Table 11 over the possible audit and investment decisions (with probabilities λ_θ and η_θ) gives the following expressions for the firm's and the government's expected losses under the early-audit contract.

$$\begin{aligned}\mathcal{F}_\theta^{\mathrm{EA}}(\lambda_\theta,\eta_\theta \mid \tau_\theta,\phi_\theta) = &-\tau_\theta+\gamma\big(1-\bar{s}_\theta\big)\Big[L_n+(1-\varphi)\big(L_f-\phi_\theta\big)\Big]+\lambda_\theta(1-\mu_S)\Big[\tau_\theta+\gamma\big(1-\bar{s}_\theta\big)(1-\varphi)\,\phi_\theta\Big]\\ &+\eta_\theta\Big\{\psi-\gamma\big(1-\bar{s}_\theta\big)(\rho-\varphi)\big(L_f-\phi_\theta\big)-\lambda_\theta(1-\mu_S)\Big[\tau_\theta+\gamma\big(1-\bar{s}_\theta\big)(1-\varphi)\,\phi_\theta\Big]\Big\}.\end{aligned} \tag{A. 62}$$

$$\begin{aligned}\mathcal{G}_\theta^{\mathrm{EA}}(\lambda_\theta,\eta_\theta \mid \tau_\theta,\phi_\theta) = &\,\tau_\theta+\gamma\big(1-\bar{s}_\theta\big)\Big[L_n+\big((1-\varphi)-\eta_\theta(\rho-\varphi)\big)\big(L_f+L_s+\phi_\theta\big)\Big]\\ &+\lambda_\theta\Big[\kappa-(1-\eta_\theta)(1-\mu_S)\Big(\tau_\theta+\gamma\big(1-\bar{s}_\theta\big)(1-\varphi)\,\phi_\theta\Big)\Big].\end{aligned} \tag{A. 63}$$

The equilibrium of the audit game under the early-hybrid contract is characterized in the following proposition.

PROPOSITION 9. *Under a given early-audit hybrid contract $\{\tau_\theta,\phi_\theta\}$, the audit game admits three distinct equilibrium regimes:*

- Region I*: If $\psi \leq \gamma\big(1-\bar{s}_\theta\big)\big(\rho-\varphi\big)\big(L_f-\phi_\theta\big)$, the unique equilibrium is $\eta_\theta=1$ and $\lambda_\theta=0$.*
- Region II*: If $\psi>\gamma\big(1-\bar{s}_\theta\big)\big(\rho-\varphi\big)\big(L_f-\phi_\theta\big)$, and $\kappa<(1-\mu_S)\Big[\tau_\theta+\gamma\big(1-\bar{s}_\theta\big)(1-\varphi)\,\phi_\theta\Big]$, then there is a unique mixed equilibrium given by $\lambda_\theta=\frac{\psi-\gamma\left(1-\bar{s}_\theta\right)\left(\rho-\varphi\right)\left(L_f-\phi_\theta\right)}{(1-\mu_S)\left[\tau_\theta+\gamma\left(1-\bar{s}_\theta\right)(1-\varphi)\,\phi_\theta\right]}$, $\eta_\theta=1-\frac{\kappa}{(1-\mu_S)\left[\tau_\theta+\gamma\left(1-\bar{s}_\theta\right)(1-\varphi)\,\phi_\theta\right]}$.*
- Region III *: The firm does not invest ($\eta_\theta=0$), and the government's best response is $\lambda_\theta=0$ if $\psi>\gamma\big(1-\bar{s}_\theta\big)\big(\rho-\varphi\big)\big(L_f-\phi_\theta\big)$, and $\kappa\geq(1-\mu_S)\Big[\tau_\theta+\gamma\big(1-\bar{s}_\theta\big)(1-\varphi)\,\phi_\theta\Big]$.*

Having solved for the optimal subsidy and coverage under the early-audit contract, the resulting equilibrium compliance probabilities, and their comparison with those under pure subsidy and pure insurance, can be characterized. Because the algebra and logic mirror the earlier proofs step-by-step, we omit the redundant details here. ∎